Federation Services - SSO

Docupedia Export

Author:FIXED-TERM ZHANG Yaolong (HRL-CN)
Date:20-Oct-2026 07:21

Invented for life

Table of Contents

1 We offer Single Sign On functionality for applications (on premesis, cloud hosted, SaaS) or publishing internet facing applications in a secure way for Enterprise IT use cases. The authentication is based on the modern authentication protocols SAML or OpenID connect (OIDC) / OAuth 2.0 11

2 News and Features 12

2.1 Latest News 12

3 Bosch IdP Onboarding Process 20

3.1 Precheck 20

3.2 Process Overview 20

3.3 Help and Consulting 21

3.4 SAML Configuration (via Self-Service) 21

3.4.1 How to request new SAML Application 22

3.4.2 Additional Information around our Self-Service 22

3.4.2.1 SAML self-service Portal Overview 22

3.4.2.2 Self-Service rules 24

3.4.2.3 Multifactor Authentication (MFA) 26

3.4.2.3.1 How to enroll for MFA 26

3.4.2.3.2 Change MFA behavior 26

3.4.3 Change SAML Assertion Consumer URL 26

3.4.4 Change SAML Signing Certificate 27

3.4.4.1 How to change the Certificates? Common Issues E-Mail: SAML-SelfService: Signing certificate lifetime exceeded E-Mail: SAML-SelfService: Signing certificate expiring soon/ expired The button "+ new Certificate" is greyed out 27

3.4.4.2 How to change the Certificates? 27

3.4.4.3 Common Issues 31

3.4.4.3.1 E-Mail: SAML-SelfService: Signing certificate lifetime exceeded 31

3.4.4.3.2 E-Mail: SAML-SelfService: Signing certificate expiring soon/ expired 32

3.4.4.3.3 The button "+ new Certificate" is greyed out 32

3.4.5 NameIdentifier formats 32

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.4.6 Request new SAML application via Self-Service | Part 1 - IAP portal 34
3.4.6.1 Step 2 | Start the request 35
3.4.6.2 Step 3 | Waiting for approval 38
3.4.6.3 Step 4 | Change SAML settings for your application 42
3.4.6.3.1 Overview 43
3.4.6.3.2 Configured assertion consumer URLs 43
3.4.6.3.3 Requests related to this application 44
3.4.7 Request new SAML application via Self-Service | Part 2 - EntraID 44
3.4.7.1 Open Application Config in Azure 45
3.4.7.2 Manage Owners 45
3.4.7.3 Single Sign-On settings 47
3.4.7.3.1 Basic SAML Configuration 48
3.4.7.3.1.1 Upload Federation Metadata 50
3.4.7.3.2 Attributes and Claims 51
3.4.7.3.3 Limit user by groups assignment 51
3.4.7.3.4 SAML Certificates 53
3.4.8 SAML Configuration | Part 3 - Application 54
3.4.8.1 Get the information to configure your application 54
3.4.8.1.1 Federation Metadata XML file 55
3.4.8.1.2 SSO-Endpoints and Certificates 55
3.4.9 SAML Request Decline use cases 56
3.4.9.1 Decline use cases 56
3.4.9.1.1 Cloud Onboarding 56
3.4.9.1.1.1 No or wrong Cloud Onboarding workon number provided 56
3.4.9.1.1.2 Cloud onboarding process not yet approved or finished 56
3.4.9.1.1.3 Cloud onboarding request declined 57
3.4.9.1.1.4 Personal-related data set to "No" in Cloud Onboarding 57
3.5 OIDC Configuration 57
3.5.1 Step 1: Identity Provider Configuration 58
3.5.1.1 Initial OAUTH/OIDC App registration 58

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.5.1.2 App registration: Basic Settings 59
3.5.1.2.1 Configuration of secrets for confidential clients 61
3.5.1.2.2 Configuration of Redirect URIs 63
3.5.1.3 Manage Owners of the application 66
3.5.1.4 Additional Claims 68
3.5.1.5 Scopes 68
3.5.1.6 Authentication Context and MFA 69
3.5.1.7 Further information 69
3.5.2 Step 2: Application Configuration 70
3.5.3 Step 3: Admin Consent Approval 70
3.5.4 Configure Claims in Token 70
3.5.4.1 How to configure 71
3.5.4.2 Offered Claims 72
3.5.4.3 View Token 72
3.5.4.4 Common Problems 72
3.5.5 Entra ID Endpoint for P4S permissions 72
3.5.5.1 Proxy4Server (P4S) Access 72
3.5.5.2 Further information 73
3.5.5.3 Standard Case: Back-end server communication from restricted network zones 73
3.5.5.4 Special Case: Interactive sign-in / user access from restricted network zones 73
3.5.6 Exception: OIDC with RB-Admin 74
3.5.6.1 Create Application (Identity Provider side) 75
3.5.6.2 Configure Application (Identity Provider side) 76
3.5.6.2.1 Owners 76
3.5.6.2.2 Reply URLs 76
3.5.6.2.3 Claim Assignments 76
3.5.6.2.4 Secrets 79
3.5.6.2.5 Scope Grant Management 79
3.5.6.2.6 Deletion 80
3.5.7 OIDC Scopes and Permissions 80

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.5.7.1 OIDC Standard Scopes 80
3.5.7.2 OIDC Authentication Request 80
3.5.7.3 OIDC Consent and API permissions 81
3.6 Terms and Conditions 87
3.6.1 General 87
3.6.2 Assurances 88
3.6.3 Preconditions 88
3.6.4 Out of our Service Scope 88
3.6.5 Customer repsonsibility 88
3.6.6 Additional rules for SAML self-service 88
3.6.7 Terms and Conditions V1.1 - OUTDATED 89
3.6.8 Terms and Conditions V 1.0 - OUTDATED 90
3.7 Application Development 91
3.7.1 If you are developing a new application and need support with integrating SSO we have some tips for you: 91
3.8 Multi Factor (MFA) with applications using modern Auth (SAML/OIDC) 91
3.9 Bosch Attributes and Claims 93
3.10 Groups and Authorization 94
3.10.1 Restrictions for nested Groups 95
3.10.2 Usecase 1a: Restrict Access to Specific Groups 95
3.10.3 Usecase 1b: Send Assigned Groups in Token 96
3.10.4 Usecase 2: Send Roles in Token 97
3.10.5 Usecase 3: Send Filtered Groups in Token 99
3.10.6 Usecase 4: Grant Application Permission to another App 102
3.10.7 Usecase 5: SCIM Provisioning 103
3.10.8 Common Problems 103
3.10.9 How to configure PowerShell for Microsoft.Graph 103
3.10.9.1 Setting up a local proxy with PX 103
3.10.9.2 Setting up the PowerShell Profile(s) 104

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.10.9.3 Installing the Microsoft.Graph modules 104
3.10.10 How to create App-roles/ AD-group-Mapping scripted 104
3.10.10.1 Technical Prerequisites Upload Roles and Groups Prepare .CSV File Run the script Upload Groups only 104
3.10.10.2 Technical Prerequisites 104
3.10.10.3 Upload Roles and Groups 105
3.10.10.3.1 Prepare .CSV File 105
3.10.10.3.2 Run the script 105
3.10.10.4 Upload Groups only 109
3.10.11 SCIM - Authorization via SCIM interface 109
3.10.11.1 What is SCIM? 109
3.10.11.2 Onboarding 110
4 Customer Information and Support 111
4.1 Stay Informed 111
4.2 Our Support 111
4.2.1 How to request Troubleshooting if the SSO is not working? 111
4.2.2 How to do changes of the SSO configuration? 113
4.3 Service Health 113
4.4 Further Information 113
4.5 ADFS signing and decryption certificate renewal for BSH ADFS (stfs.bshg.com) 113
4.5.1 Q&A 115
4.5.1.1 Is the new certificate already valid and can be used in my application? 115
4.5.1.2 Can I store both certificates in my application? 115
4.6 ADFS signing and decryption certificate renewal for NGW (BOSCH-P ADFS system) 116
4.6.1 Q&A 117
4.6.1.1 Is the new certificate already valid and can be used in my application? 117
4.6.1.2 Can I store both certificates in my application? 117
4.6.1.3 If my app use EntraID as IDP, do I have to take actions? 117
4.7 Retrieve SAML response in base64-encoded, deflated and base64-encoded, or plain XML format 117

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4.8 BPC Customers only 120
4.8.1 Configuration 120
4.9 Authentication fails with bad password on ADFS from internet access 121
4.9.1 Solution/Workaround 121
4.10 ADFS signing and decryption certificate renewal for RB-ADMIN (stfs.bosch-org.com) 122
4.10.1 Q&A 124
4.10.1.1 Is the new certificate already valid and can be used in my application? 124
4.10.1.2 Can I store both certificates in my application? 124
4.11 Enablement of SAML configurations for self management 125
4.11.1 Information about SAML self-service in EntraID 125
4.11.1.1 Which actions you need to take? 125
4.11.1.2 Technical support and consulting 125
4.11.2 How to access and manage your configuration 125
4.11.3 FAQ 127
4.11.3.1 Why do I get email regarding expired token signing certificate? 127
4.11.3.1.1 Solution 127
4.11.3.2 Why do I get email regarding missing Owner? 127
4.11.3.2.1 Solution 128
4.11.3.3 Why do I get an email regarding signing certificate lifetime exceeded? 128
4.11.3.3.1 Solution 128
4.11.3.4 What if I am not the application owner anymore? 128
4.11.3.5 Is it possible to add other owners to the configuration 128
4.12 SSO Troubleshooting with Logs 128
4.12.1 Overview 129
4.13 SSO with multiple Accounts 129
4.13.1 Quick Solution 129
4.13.2 Our recommended Edge Solution 129
4.13.2.1 Additional Settings 131
4.13.3 Firefox Solution 131

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5 Authentication Flows & more 133

5.1 Authentication 134

5.1.1 Basic Authentication Flow 134

5.1.2 User Provisioning 135

5.1.3 MFA for External Access 135

5.2 Token Signing Certificate 135

5.2.1 Find the certificate 135

5.2.2 Current token signing certificate 136

5.2.3 Certificate Rollover (SAML only) 136

5.3 Cookies and Tokens 137

5.3.1 Supported SSO types 137

5.3.2 Token lifetimes 137

5.4 OAuth2.0 / OpenID Connect with ADFS 138

5.4.1 Terminology 139

5.4.2 Which Grants are avaialable and when to use which one? 139

5.4.2.1 Authorization Code Grant 139

5.4.2.2 Implicit Grant 140

5.4.2.3 Client Credential Grant 141

5.4.3 Scopes (permissions) 142

5.4.3.1 Available scopes 142

5.4.4 Detailed flow (external link to Microsoft) 143

5.5 OAuth2.0 / OpenID Connect with Entra ID (formerly AzureAD) 143

5.5.1 OAuth2.0 vs OpenID Connect 143

5.5.2 Flows 143

5.5.3 Libraries 144

5.5.4 Deciding which Flow to Use 144

5.5.4.1 Authorization Code Flow vs Implicit Flow 144

5.5.4.1.1 Benefits of using an Authorization Code 145

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.5.4.1.1.1 Increased User Experience 145
5.5.4.1.1.2 Increased Security 145
5.5.5 Authorization Code Flow 145
5.5.5.1 Roles 146
5.5.6 Implicit Flow 147
5.5.6.1 Roles 148
5.5.6.2 Flow Example 149
5.5.7 Device Code Flow 150
5.5.7.1 What is the Device Code Flow? 150
5.5.7.2 General Flow information 152
5.5.7.3 Roles 152
5.5.8 Client Credential Flow 154
5.5.8.1 Roles 154
5.5.9 JSON Web Token (JWT) 155
5.5.9.1 Example 155
5.5.9.2 Bearer Token 156
5.5.10 OAuth2.0 Glossary 156
5.6 SAML 2.0 flow 157
5.6.1 Federation Metadata 159
5.6.2 Token Request and Response 160
6 Migration Process: ADFS to Azure IdP 163
6.1 Table of Content 163
6.2 Migration of SAML based applications 163
6.3 Migration for OIDC based applications 164
6.4 Benefits of EntraID IdP 165

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

1 We offer Single Sign On functionality for applications (on premesis, cloud hosted, SaaS) or publishing internet facing applications in a secure way for Enterprise IT use cases. The authentication is based on the modern authentication protocols SAML or OpenID connect (OIDC) / OAuth 2.0

Technical Overview

The user will be authenticated against the on premise Active Directory. Our Federation Service will provide a token (XML or JWT) with the authenticated user and other information (claims) to the application. We are offering Microsoft Entra ID (former Azure AD) as standard Identity Provider.

More Information

Authentication Flows & more including the Protocols SAML and OIDC
Customer Information for customers with already connected applications

Onboarding Process

Precheck: Authentication for Application
Start the Onboarding Process

Section responsible: Bayerl Guenter (BD/WPA-WCS1) Nagler Janina (BD/WPA-WCS1)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

2 News and Features

On this page we inform you about new features and functionalities we are offering as part of our "Federation Services"

2.1 Latest News

SAML Self-Service is released... - 12.05.2025

SAML Self-Service is released... - 12.05.2025

We are happy to offer to you our SAML Self-Service. You can create and manage your SAML configuration now 100% on your own. This process is replacing our Onboarding Excels.
Find more information here: Request new SAML application via Self-Service | Part 1 - IAP portal - Directory Services - Docupedia

Reqeust process for MFA everytime is released... - 26.04.2024

Reqeust process for MFA everytime is released...

We are glad to offer to you the possibility to request MFA everytime now via our process.
As default you need MFA authentication in addition only when accessing the application from any extranet network, like e.g. from public Internet or mobile networks. To have this in place there is no need to request anything as this the default setting, which will be published when onboarding an application.
Some applications need more security and so, MFA everytime the user logs in, independent from which network. This now can be ordered directly while the onboarding in our excel document or for already onboarded applications or OIDC self-service created ones via a T&R request.
Find more information here: https://inside-docupedia.bosch.com/confluence/x/RwI9_w

New Onboarding Excel (v2.9) for SAML applications released... - 26.04.2024

New Onboarding Excel (v2.9) for SAML applications released...

Today we released the new v2.9 onboarding excel file to request SAML IdP configurations

Changes in this version:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

In the general tab there is a new checkbox (3.3) to order directly the usage of MFA for access from internet AND intranet instead of the default use case, having MFA from internet access but not from Intranet.

Find more information regarding this topic here: https://inside-docupedia.bosch.com/confluence/x/RwI9_w

Rebranding: Azure AD is now Microsoft Entra ID - 06.11.2023

Azure AD => Entra ID

Microsoft has decided to rename the product and was starting this on 01.10.2023. Therefore we are also adapting our Documentations.
https://learn.microsoft.com/en-us/entra/fundamentals/new-name

New Onboarding Excel (v2.8) released- 28.06.2023

New Onboarding Excel (v2.8) for SAML applications released...

Today we released the new v2.8 onboarding excel file to request SAML IdP configurations due to reduce possible vulnerabilities and attack vectors.
More information about the "False Identifier Anti-pattern" you can find in following Microsoft blog:
https://techcommunity.microsoft.com/t5/microsoft-entra-azure-ad-blog/the-false-identifier-anti-pattern/ba-p/3846013
In detail this means that from now it is not possible anymore to use the email address as the user identifying claim (*subject* or *http://schemas.xmlsoap.org/ws/2005/05/identity/claims/nameidentifier* or *NameId*)
The recommended value for identifiying the user is the UPN (User-Principal-Name). The advantages are:

- The UPN is a unique identifier of the user within the whole Bosch Active Directory and all Azure instances
- The UPN has the format of an email and so fits as well for all applications who needs an email as the identifier
- The UPN is as well a valid "email address" connected to your mailbox, so that the users can receive emails as well
- The UPN is stable the whole Bosch lifetime and will not be used as well after leaving the company → lifetime unique value!

T**o sum up there is no reason not to use the UPN as the authentication claim. Furthermore it is the most stable and unique identifier and we are highly recommend to use it. Email address (firstname.lastname@de.bosch.com) is not offered anymore and therfor cannot be used from now.**

New Onboarding Excel released- 17.03.2023

New Onboarding Excel for SAML applications released...

Today we released the new v2.7 onboarding excel file to request SAML IdP configurations.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

New features:

- sAMAccountName can be selected as additional claim also
- Restructured groups claim section

Migration Process available - 10.02.2023

Migration from ADFS to Azure AD

As announced below we are planning to migrate all applications to our Identity Provider Azure AD. Our timeline is to get most applications until end of 2023 migrated. Therefore we have setup a process which is dependent on the SSO-protocol. There is detailed information available on our new Migration page.

Switch off "Create OAuth2 Applications" IAP Portal on 01.04.2023

We will switch of the creation of new applications in IAP on 01.04.2023. Changes on existing applications will still be possible, migration to Azure AD is highly recommended.

Onboarding changed - 30.06.2022

Onboarding of new applications to Azure Identity Provider

We are very happy to announce that we do the full switch of our Identity Provider environment from ADFS (on prem) to Azure (cloud). starting at 1st of July 2022. This means that all new ModernAuth (SAMLv2/OIDC/OAUTHv2) configurations will be onboarded only to Azure and not to the on prem ADFS environment anymore.

With this modern, secure and scalable cloud environment we bring a lot of benefits to you like...

- Full support of future Internet based clients
- Usage of RB-Secrets (HashiCorp Vault)
- Zero Trust
- Full Single-Sign-On (SSO) experience
- Access to Azure Identity API
- Read access to the configuration (SAML)
- Individual Token Signing certificate (important for certificate rollove for SAML)
- Fully automatable Application configuration (OIDC/OAuth 2.0)

and many more...

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

This we will do for all our onboarding requests, except for

- on premise installed applications which needs to authenticate users from BSH Active Directory -> BSH ADFS environment (stfs.bshg.com)
- on premise installed applications which needs to authenticate users from RB-Admin Active Directory -> ADFS RB-Admin environment (stfs.bosch.org)

The ADFS environments will not be turned off as it is used as well in the logon process for Azure as a backend system.

No change in the order process!

For **SAML** applications you need to fill out the SAML onboarding excel document, you can find here:
Onboarding Documentation

For **OIDC/OAUTH2** configurations you can use our self-service, which is documented here:
OIDC Configuration

Migration of applications onboared to ADFS environments

In the first step only new onboardings are affected by this change. We currently working on a migration plan to migrate all alreacy onboarded SAML applications on ADFS to Azure IdP as well.
As soon as we are prepared we will come to you as application owner to clarify and plan with you the migration path for your application(s).
If you have any further questions you can contact us via Onboarding.Bosch-Idp@de.bosch.com

New Onboarding Documentation (v2.5) - 22.11.2021

We have updated and released a new version of our onboarding excel documentation.
It is available at https://inside-docupedia.bosch.com/confluence/download/attachments/1094166107/IdP_onboarding_documentation.xltx?version=2&modificationDate=1637326790000&api=v2
Main changes are

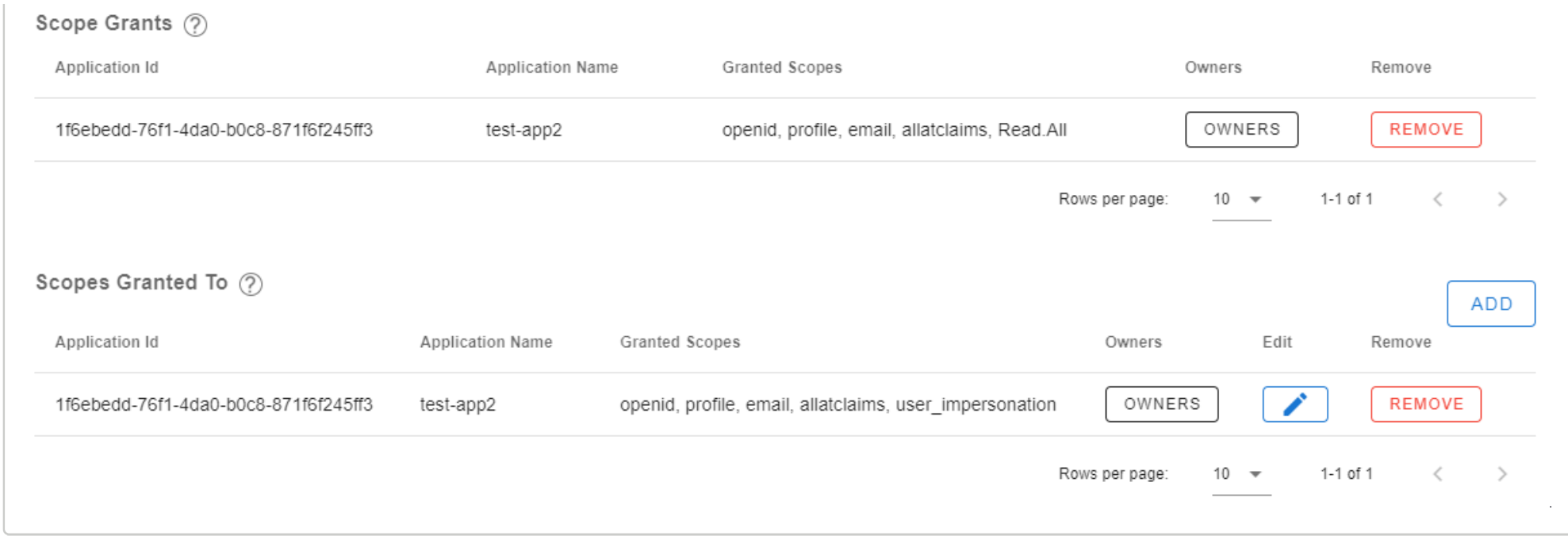
- Better integration of Azure as Identity Provider for SAML in the documentation
- Redesign of claims tab (Definition of default claims (analogous to Azure AD and removal of checkboxes to activate a claim)

From now please only use the new excel document to request new application onboardings!

Introducing Scope Grant Management - 10.08.2021

We have introduced the ability to enable other applications to acces your Web-APIs. (For more details, see here)

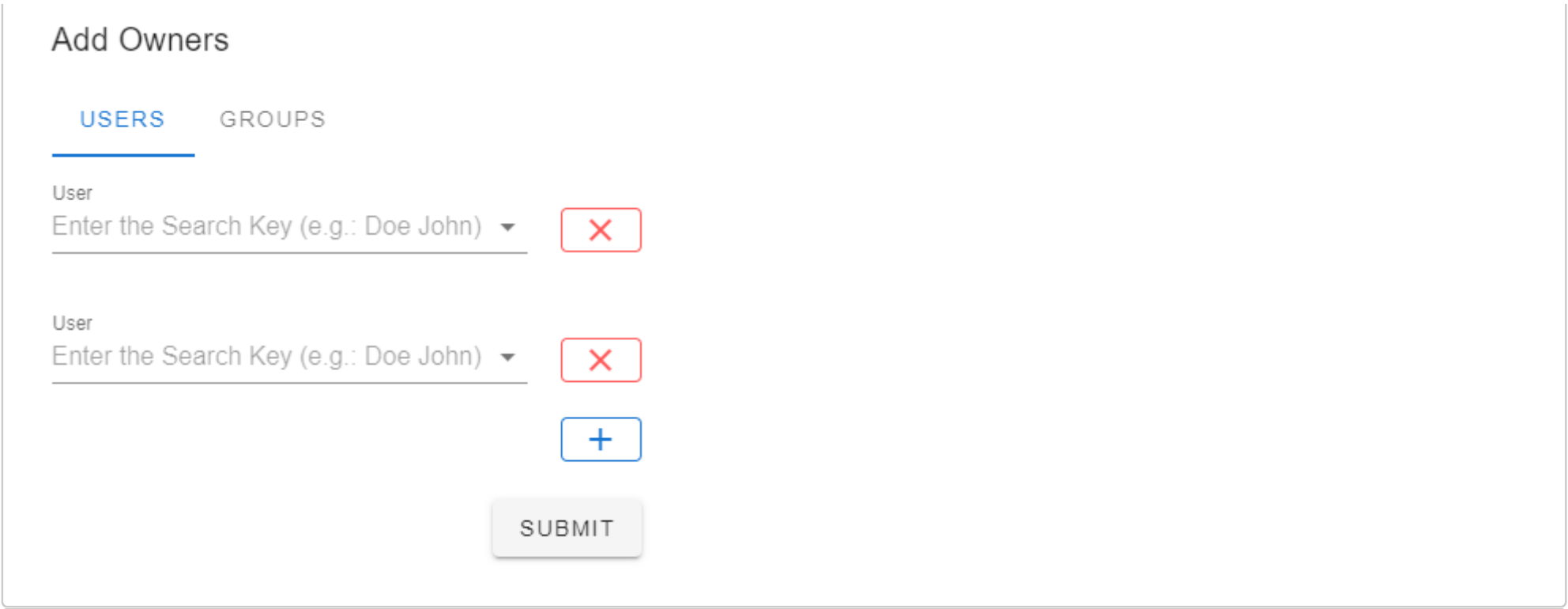
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Owner Management Improvements in ADFS Self-Service - 07.2021

We have updated the Owner Management in the ADFS Self-Service. You are now able to add multiple Owners in one Request. You can also assign Groups as Owners to Applications. All members of these Groups have the same permissions on the Applications as directly assigned users. Be aware that these Groups would have to be synced to Azure and you are still required to have at least 2 Users assigned as Owners. (For more details, see here)

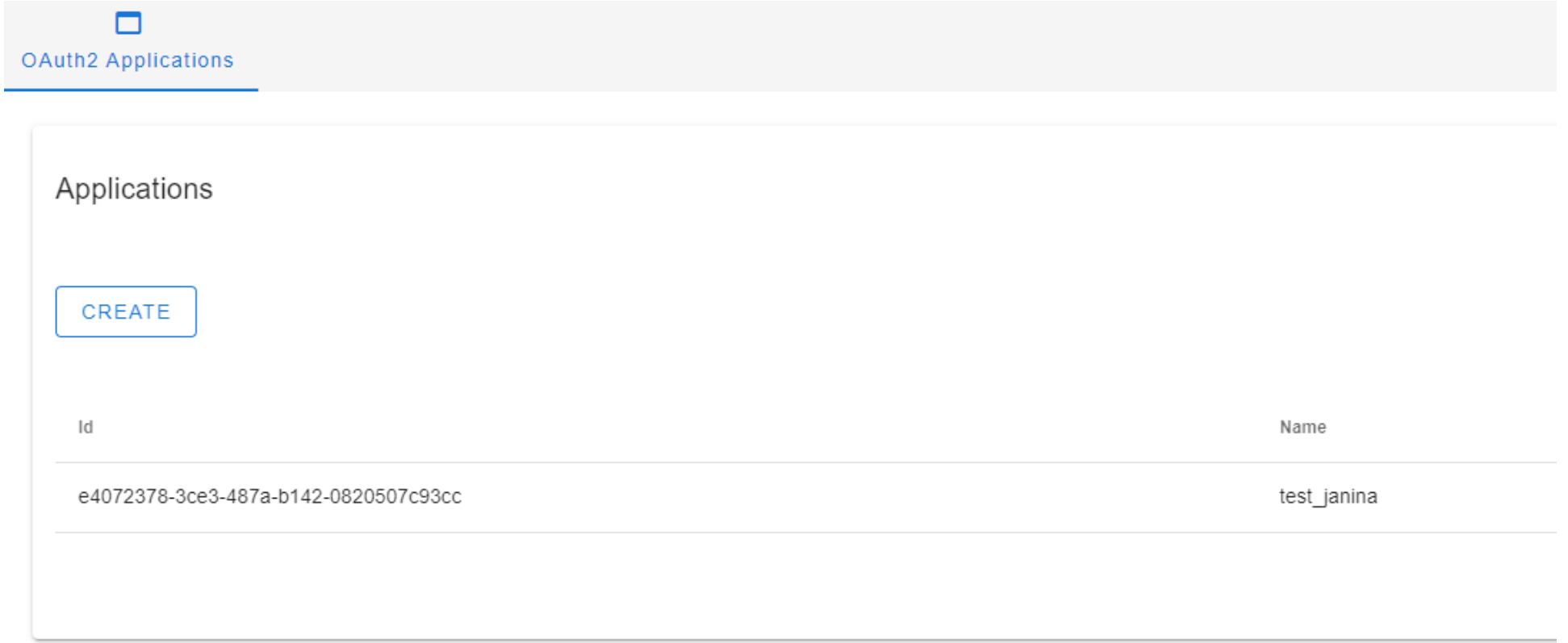
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



New Self-Service for OIDC - 06.2021

We have updated our complete process for SSO with OIDC. Everything can be now configured by yourself and independent from us! With our new Automation Plattform you can do the IdP configuration and all changes yourself. Have a look on our new documentation here

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



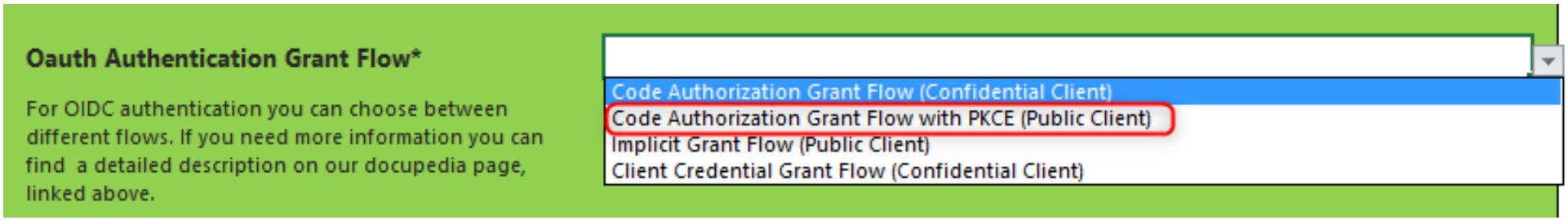
Cutoff Prefix Feature for Groups not offered anymore - 05.2021

In the past we offered a functionality to cutoff the prefix of Group Claims based on Regular Expressions. As this service won't be available in Microsoft Azure, we decided not to offer it in future Onboarding Processes anymore

PKCE-Flow released - 04.2021

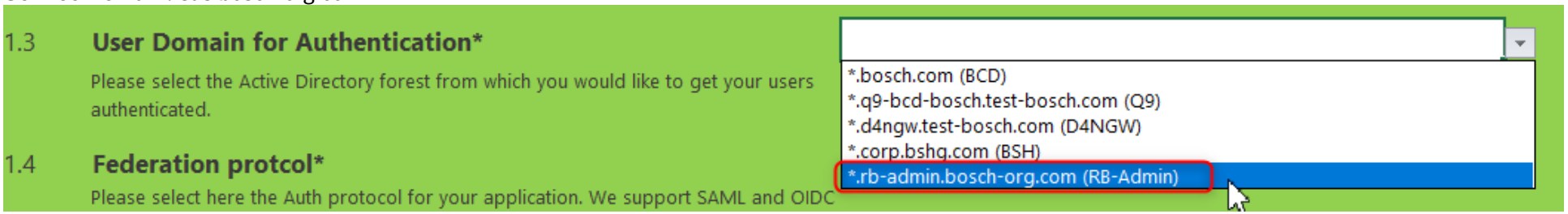
We are now offering the Code Authorization Grant Flow with PKCE for Public Clients. We recommend this flow for use cases with Public Clients (e.g. SPA, Mobile Applications).
The Official Documentation can be found here: PKCE RFC

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



New ADFS Service for RB-Admin Domain - 04.2021

We have set up this year a new ADFS-Infrastucture for the RB-Admin Domain. This is now released and you can order it in our Onboarding Documentation.
Currently the Service can be only accessed internally (Not with IDE-Clients or Managed Devices from the Internet)
Service Domain: stfs.bosch-org.com



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3 Bosch IdP Onboarding Process

The SSO Configuration Process differs depending on the supported SSO-protocol (SAML or OIDC). In both cases it is a simple 3 step process and implementation takes usually about 5 working days. There are no additional costs for this service.

3.1 Precheck

Is the Application provided by an external company?
Please check with your provider about their SSO process.

- Supported SSO-Protocol? SAML 2.0 or OIDC (OpenID Connect)/ OAuth 2.0
- Instructions for configuration available?
- Special Case: Multitenant Sign-in offered?

Is the Application developed by your team?
If not already given / implemented, please check how to integrate automatic handling of SSO flows. This is a requirement before starting the configuration. We have more details how to integrate e.g. MSAL library here

3.2 Process Overview

Depending on the supported SSO protocol we have a different process:

SAML Configuration

The SAML Configuration contains the following 3 steps:



Step 1: SAML Onboarding: Request via RB-IAP portal
Open the link below and request a new SAML configuration via our self-service.

OIDC Configuration

The OIDC (OpenID Connect / OAuth 2.0) Configuration contains the following 3 steps:



Step 1: Identity Provider Configuration
Create an App Registration in Azure Portal. We are providing some basic instuctions

Step 2: Application Configuration
Configure SSO on Application side. This is totally different for each application and we cannot support here, but we are providing some basic instructions

Step 3: Admin Consent Approval

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Onboard a SAML application to Entra ID (former Azure AD):	https://rb-iap.bosch.com/new/entraID/applications/saml

Step 2: Identity Provider Configuration

After a successful approval, the Idp configuration will be handed over to the owners. All settings like claims and EntitiyID can be configured as needed for the specific application.

Step 3: Application Configuration

Configure SSO on Application side. This is totally different for each application and we cannot support here, but we are providing some basic instuctions.

More details

Exception: If you need RB-Admin as Identity Provider: Please fill out our SAML Onboarding Documentation for RB-Admin here
Federation Metadata XML file for RB-Admin only: https://stfs.bosch-org.com/federationmetadata/2007-06/federationmetadata.xml

Please be aware that with the first authentication request a popup shows up. Fill out its dialog for requesting the admin consent. The request will be automatically forwarded to the responsible team. This step will take some time so please be patient and wait for the answer. For more details about the process feel free to check our our Admin Consent Documentation.

More details

Exception: If you need RB-Admin as Identity Provider: Please configure it on IAP-Portal as described here

3.3 Help and Consulting

You are lost? You need consulting? You have questions about SAML Onboarding?
Please send an E-Mail to ***Onboarding.Bosch-Idp@de.bosch.com*** and we can have a clarification meeting together.

In case you need any assistance and support in terms of troubleshooting or settings on the SAML configuration need to be changed **after the onboarding,** please open a **Service Desk ticket** as described here:
https://inside-docupedia.bosch.com/confluence/x/FyoLZg

3.4 SAML Configuration (via Self-Service)

We are happy to provide the new Self-Service for SAML based authentication for applications. With this Self-Service we enable you to request and maintain your SAML IdP configuration mostly without our support. To ensure the validity of security settings and processes, some of the changes need to be done via the IAP site and

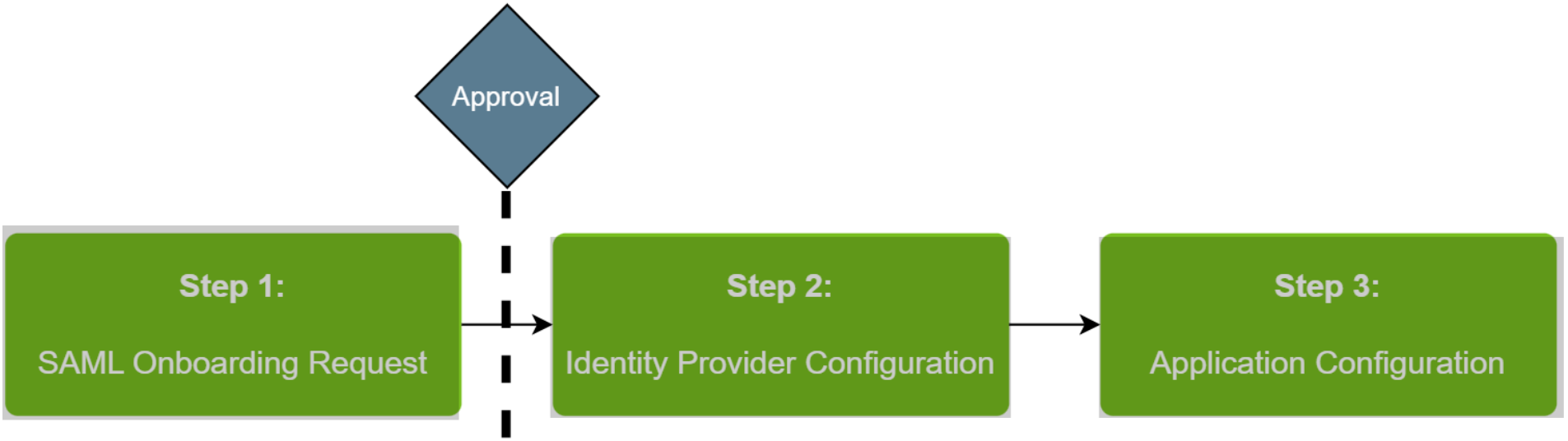
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

approved from our team.
Here you can find a step-by-step guide how to use the self-service, learn what is possible and what not and how to read and handle the status of our processor which is processing and monitoring your requests and application settings.

- How to request new SAML Application
- Additional Information around our Self-Service
  - SAML self-service Portal Overview
  - Self-Service rules
  - Multifactor Authentication (MFA)
    - How to enroll for MFA
    - Change MFA behavior

3.4.1 How to request new SAML Application

To request a new SAML application, please follow our **step-by-step guide,** just **click** on the Step you want to jump to:



3.4.2 Additional Information around our Self-Service

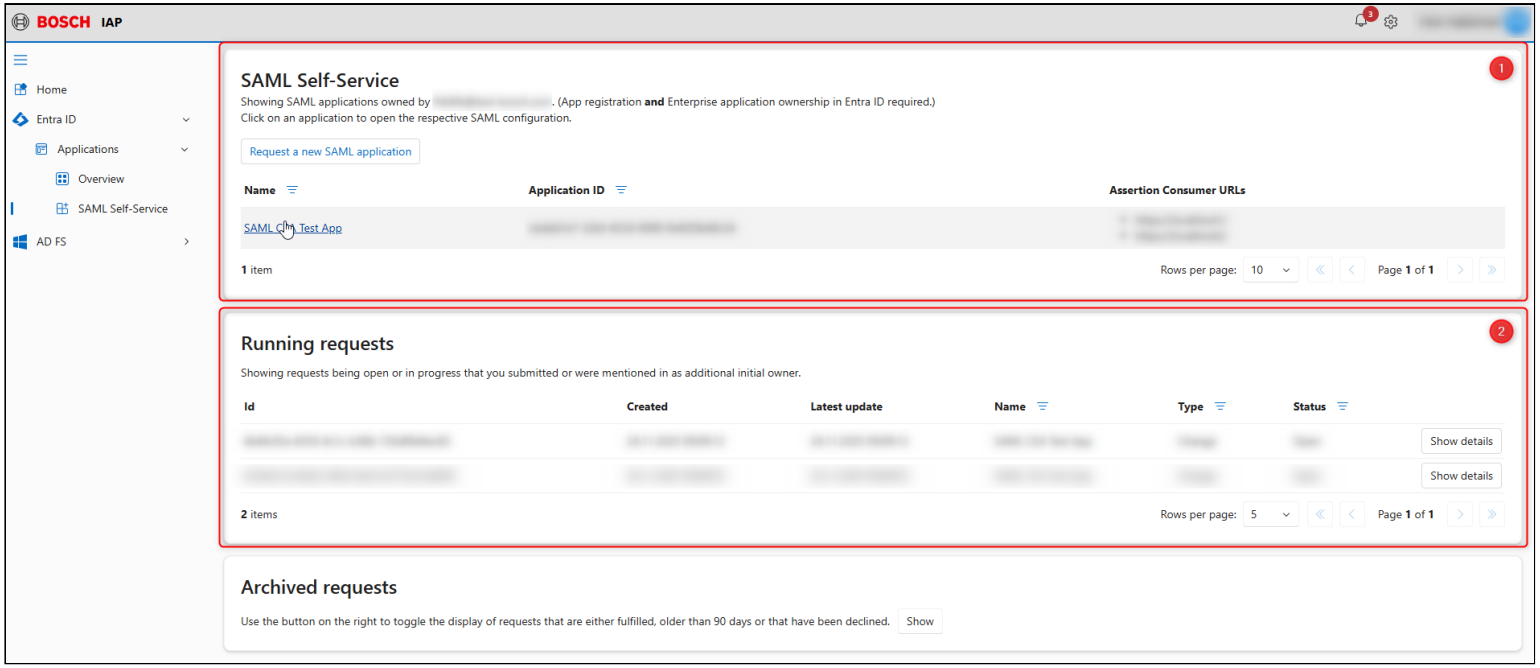
3.4.2.1 SAML self-service Portal Overview

The SAML self-service is based on our IAP environment. You can find the site by navigating to

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

BCD (*.bosch.com)	https://rb-iap.bosch.com/new/entraID/applications/saml
Test Environment: **Q9 (*.q9-bcd-bosch.test-bosch.com)**	Login with Q9 User Account is required: https://rb-iap.test-bosch.com/new/entraID/applications/saml

Dashboard



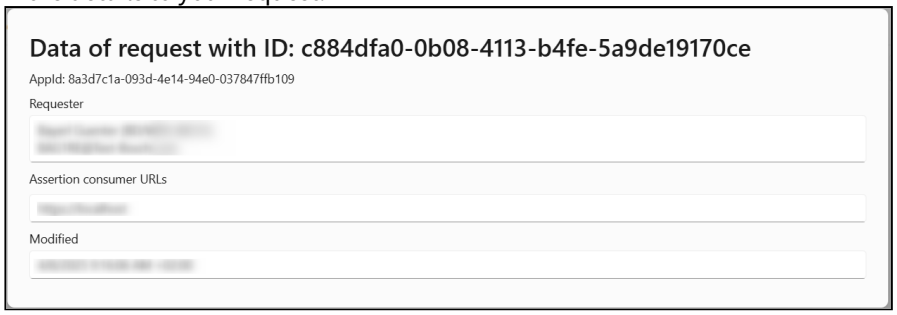
1) SAML Self-Service

In this section you will find all SAML configurations, which are completely onboarded and you are owner of. You can find more details by clicking on their name.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

2) Running requests

In this section you will find all of your requests (e.g. new applications or change of assertion consumer URL) and that are being processed. With the Show details button you get more details to your request.



To filter the requests, you can use the blue filter icon right beside the column header 

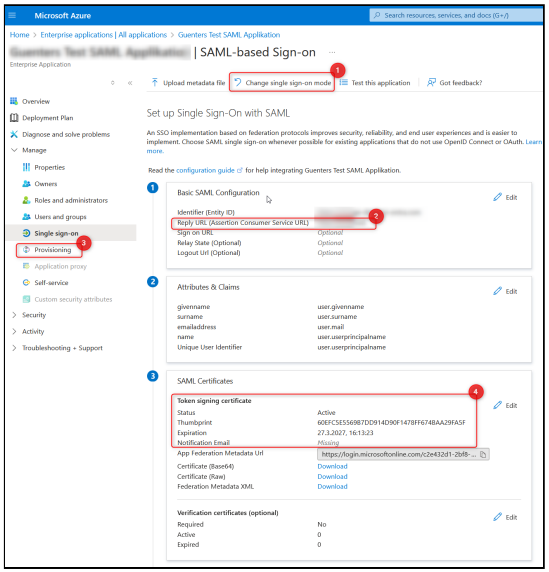
Below, at "Archived requests" you will find all requests of the past.

3.4.2.2 Self-Service rules

After a the SAML application was successfully onboarded, you are owner of the Enterprise Application and as well the App registration. Therefore you have full access permission to all settings of the
application. Due to security and process regulations, not all possible settings are allowed to be done. Which rules are important for you, you can find in the below list.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

1	**Change single sign-on mode**	The single sign-on mode **must** always be SAML and mustn't be changed to any other setting due to security reasons. While the creation process, SAML will be set as the authentication method. We will monitor this setting and reset this to the initial and correct value. Further you and our team will receive a notification email, once the setting has been changed. If this will be changed on a regular basis, we will remove ownership and disable the self-service for your application.
2	**Reply URL/ (Assertion Consumer Service URL)**	The reply or Assertion consumer service URL is the endpoint of your application, the token will be issued to. A change of this setting must be done in IAP and approved by our team (https://inside-docupedia.bosch.com/confluence/x/YJoQWAE). We monitor this attribute and overwrite it to the correct setting, stored in IAP. The onboarding team will be alarmed. It will be changed more often or on regular basis, we will remove the ownership and disable the self-service for your application.
3	**Provisioning (SCIM)**	**SCIM (System for Cross-domain Identity Management)** is an open standard designed to facilitate the automation of user identity management across different systems and domains. SCIM aims to simplify the process of managing and exchanging identity data such as user profiles, roles, and permissions between cloud services, applications, and IT systems. More information can be found here: https://rb-oneidm-help.bosch.com/en/data/scim.html Order SCIM integration *SCIM is part of the IDM service at Bosch and will be provided by the responsible team.* *To get consulting and start the SCIM onboarding process, please **contact the IDM integration mailbox** Mailbox.IdMIntegration@bosch.com*



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4	**Token signing certificate**	As application owner you are responsible to keep the token signing certificate up-to-date. Please setup a valid email address in the Notification Email setting to ensure getting a notification before the token signing certificate expires and renew the certificate accordingly. Please ensure to follow our security guidelines (EISA) in terms of certificate validity period and all other settings.

All security and process relevant settings will be monitored by our team and reset once the change will be done directly in Entra ID. You and our team will be notified via Email.

Please keep in mind, that we reserve the right to revoke ownership for the configuration and deactivate self-service for your application if attempts are made to circumvent these rules.

3.4.2.3 Multifactor Authentication (MFA)

When creating a new app, the Bosch default policy will be applied automatically and has following settings:

- No MFA is required when accessing the application from a Bosch internal network (local LAN or RB VPN connection)
- MFA is required when accessing the application from outside the Bosch network (Internet or mobile connection like e.g. 5G or LTE

3.4.2.3.1 How to enroll for MFA

In case you do not have yet enrolled for MFA, you can do this by following the described process here: https://connect.bosch.com/blogs/fc29ba88-808b-49d7-9439-4f1735f3c0f5/entry/Enrolling_for_Multi_Factor_Authentication_MFA_got_easier_and_more_secure?lang=de_de.
This is required for editing your application in the Azure Portal!

3.4.2.3.2 Change MFA behavior

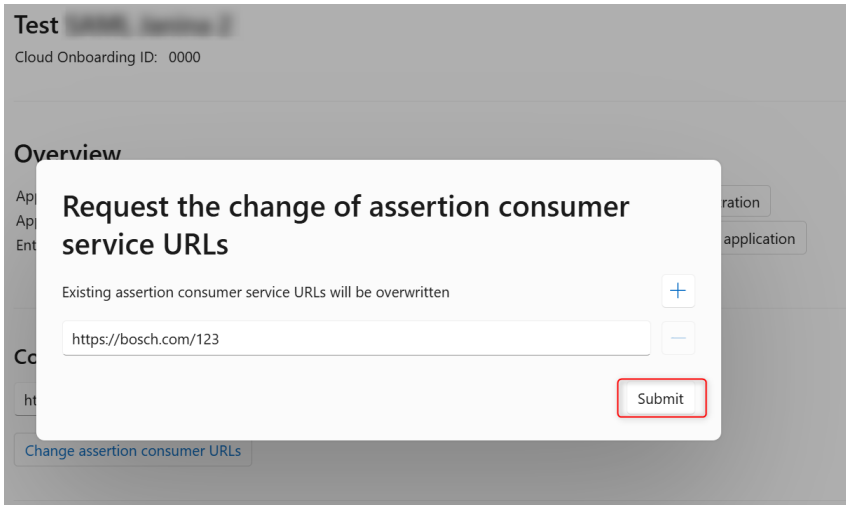
To increase the security you can e.g. order the requirement for your application to get a MFA call as well when accessing the application from the intranet. More information can be found here: Multi Factor (MFA) with applications using modern Auth (SAML/OIDC) - Directory Services - Docupedia

3.4.3 Change SAML Assertion Consumer URL

The reply or Assertion consumer service URL (Reply URL) is the endpoint of your application, the token will be issued to. **A change of this setting must be done in IAP and approved by our team.**
We monitor this attribute and overwrite it to the correct setting, stored in IAP. The onboarding team will be alarmed!

1. In order to change it for your existing application, please start a request here: SAML - IAP. Open the Application Settings and click "Change assertion consumer URLs". There you can adapt the URLs and Submit the Request

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



2. We will check if your request is valid and approve it.
3. Afterwards the Reply URL will be set automatically in your Application in the Azure Portal. You will get an E-Mail that the change was implemented

Recommendation:
For time critical changes it is recommended to request two Reply URLs: The old and the new one.
The old one can be removed with a second change request after the application is running with the new URL.

3.4.4 Change SAML Signing Certificate

SAML Signing Certificates must be exchanged regularly (at least every two years). They are used to sign the SAML Token (Response) to your application.

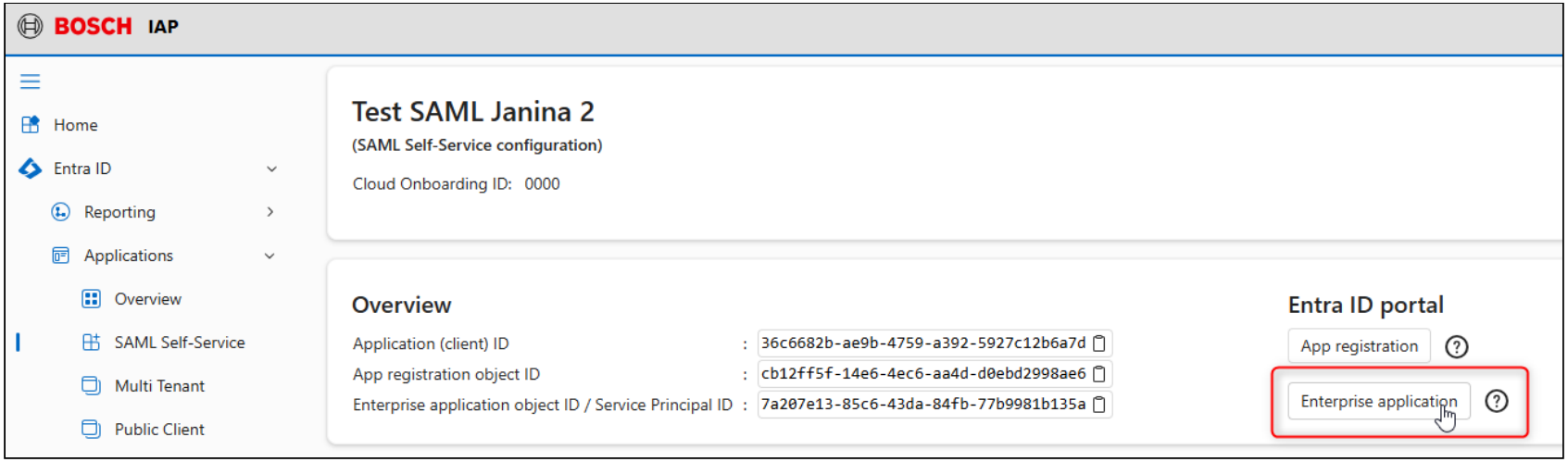
Please update your certificates in time to avoid a service downtime of your SAML application. This page describes the process with all the required steps!

3.4.4.1

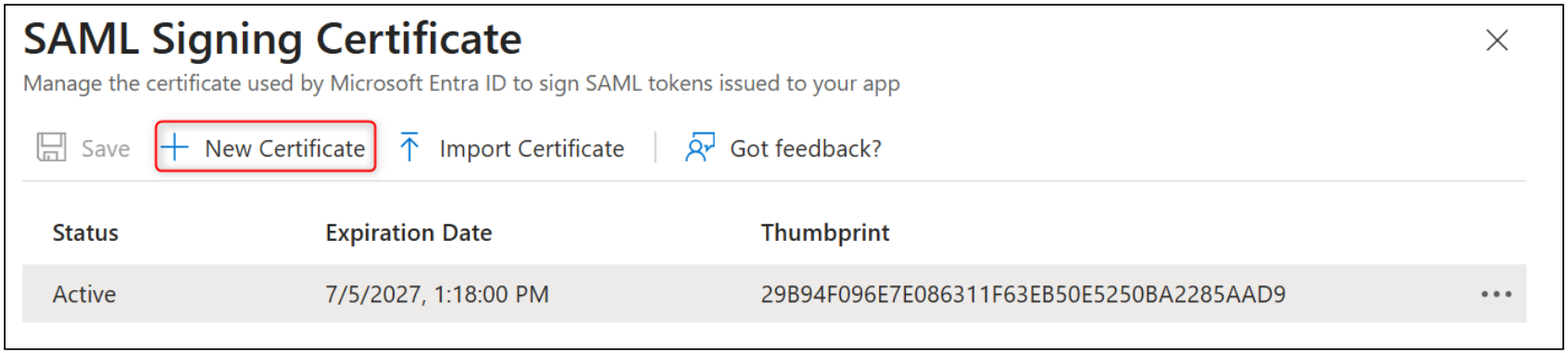
- How to change the Certificates?
- Common Issues
  - E-Mail: SAML-SelfService: Signing certificate lifetime exceeded
  - E-Mail: SAML-SelfService: Signing certificate expiring soon/ expired
  - The button "+ new Certificate" is greyed out

3.4.4.2 How to change the Certificates?

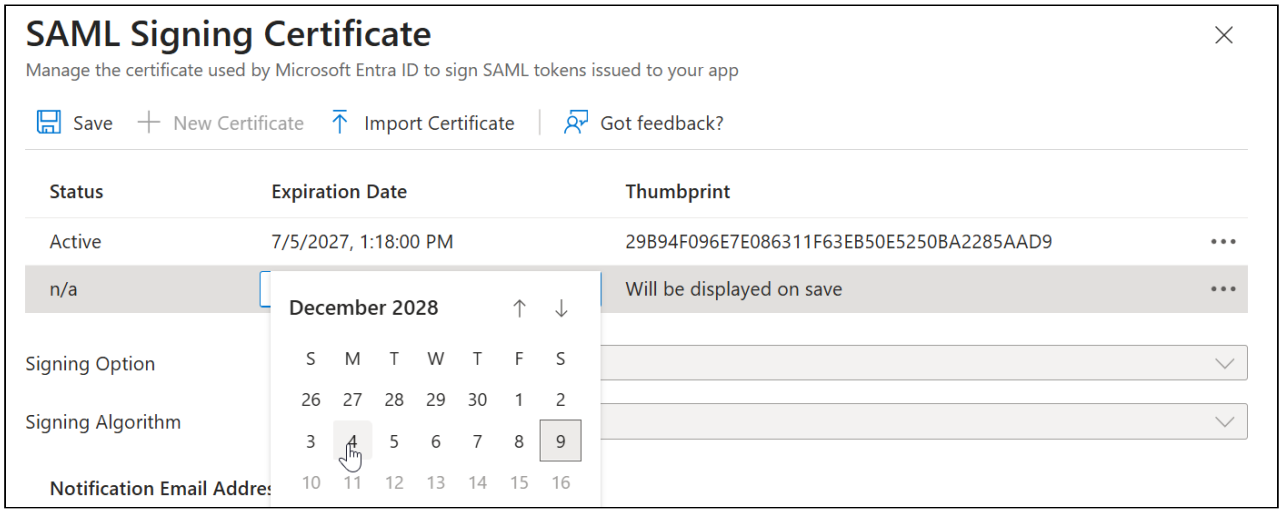
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
0 - Open Enterprise Application	Open your "Enterprise Application" in the Azure Portal, e.g. over IAP Portal: https://rb-iap.bosch.com:  *You will see all SAML applications where you are Owner - this is a prerequisite to be able to change the SAML certificates*

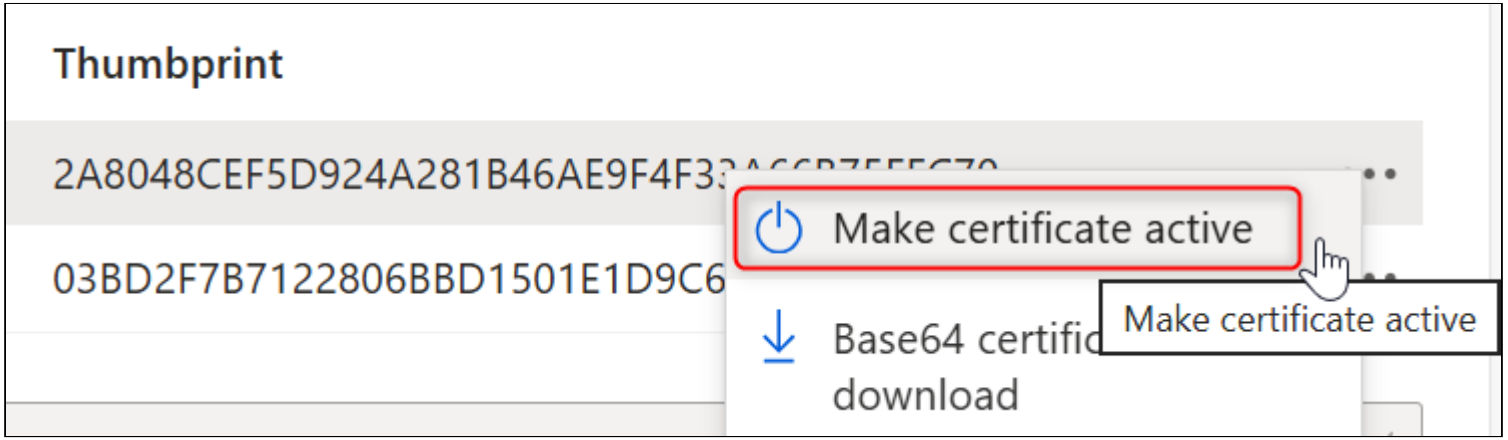
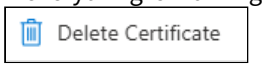
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
1 - Create new Certificate	In your Enterprise Application jump to Manage > Single sign-on  In the Section 3 "SAML Certificates" you can manage the Signing Certificate for your SAML configuration. Click "Edit" and then "New Certificate"  *If you want to import an existing SAML signing certificate, click the button "Import Certificate" and follow the instructions in the Browser. You need to upload a certificate with a private key! This setup is only used in very rare cases.*

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
2 - Configure Expiration Date	A new certificate will be added directly as you can see in the following screen. After setting the correct expiration time **(less then 2 years)** to meet the EISA security guidelines, please click Save to finally store the new certificate.  There is no possibility afterwards to change the certificate expiration. You need to delete and create a new one to set expiration dates! *For more information regarding the security guidelines and contact persons, you can find in the EISA (**EISA-CRY-107.6 - Standards for Asymmetric Cryptographic Key Material):*** https://www.intranet.bosch.com/doku/eisa/EISA-CRY-107.html#ctl$EISA-CRY-107$impl-reqs$6
3a - Configure Application	The new Certificate needs to be added in the SSO configuration of your application. For this step your vendor should be able to support you as this step different for every application. The certificate might be uploaded in a SSO-Settings Admin GUI of the application or it is automatically retrieved by loading the IDP Federation Metadata

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
3b - Activate Certificate	The new certificate is still Inactive. To activate the certificate, please click the **...** at the very right and select " Make certificate active"  As there can be only one certificate active, the old one will be set to inactive immediately and the new one activated. You are able to switch between the certificates, as long both are still valid and not expired.
3c - Test SSO	Login to your application to see if SSO is still working by using a private / incognito Browser.
4 - Delete old Certificate	If everything is working as expected, please delete your old certificate: Go to the old inactive certificate, click the **...** at the very right and select 

3.4.4.3 Common Issues

3.4.4.3.1 E-Mail: SAML-SelfService: Signing certificate lifetime exceeded

- Why did I get this E-Mail? The total lifetime of the certificate needs to be considered, not the remaining validity. Yours is longer then two years which is not compliant with EISA regulations.
- How can this be solved?
  - Replace the existing active Certificate as explained above.
  - In case there is an inactive certificate with lifetime exceeded you can simply delete it (Step 4)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.4.4.3.2 E-Mail: SAML-SelfService: Signing certificate expiring soon/ expired

- Why did I get this E-Mail?
  - If you haven't replaced your current (active) certificate **or**
  - If you haven`t deleted your inactive certificate
- How can this be solved?
  - Active Certificate: Replace the current Certificate as explained above
  - Inactive Certificate: You can simply delete it (Step 4)

My application is not in use anymore

- In this case the deletion of your SAML-SSO-Configuration is still missing:
  - Please open your "Enterprise application" as explained in the instruction above
  - On the Properties Tab there is a "Delete" button at the bottom of the page
- After you deleted the SAML-SSO-Configuration, there will be no further mails

3.4.4.3.3 The button "+ new Certificate" is greyed out

- Only Owners are allowed to change the certificate!
- Please check if you are Owner or ask the current Owners to add you

3.4.5 NameIdentifier formats

NameID format	Description
unspecified urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified	The interpretation of the content of the element is left to individual implementations.
email address urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress	Indicates that the content of the element is in the form of an email address, An addr-spec has the form **local-part@domain**. Note that an addr-spec has no phrase (such as a common name) before it, has no comment (text surrounded in parentheses) after it, and is not surrounded by "<" and ">".

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

NameID format	Description
persistent urn:oasis:names:tc:SAML:2.0:nameid-format:persistent	Indicates that the content of the element is a persistent opaque identifier for a principal that is specific to an identity provider and a service provider or affiliation of service providers. Persistent name identifiers generated by identity providers MUST be constructed using pseudo-random values that have no discernible correspondence with the subject's actual identifier (for example, username). The intent is to create a non-public, pair-wise pseudonym to prevent the discovery of the subject's identity or activities. Persistent name identifier values MUST NOT exceed a length of 256 characters. The element's NameQualifier attribute, if present, MUST contain the unique identifier of the identity provider that generated the identifier. It MAY be omitted if the value can be derived from the context of the message containing the element, such as the issuer of a protocol message or an assertion containing the identifier in its subject. Note that a different system entity might later issue its own protocol message or assertion containing the identifier; the NameQualifier attribute does not change in this case, but MUST continue to identify the entity that originally created the identifier (and MUST NOT be omitted in such a case). The element's SPNameQualifier attribute, if present, MUST contain the unique identifier of the service provider or affiliation of providers for whom the identifier was generated. It MAY beomitted if the element is contained in a message intended only for consumption directly by the service provider, and the value would be the unique identifier of that service provider. The element's SPProvidedID attribute MUST contain the alternative identifier of the principal most recently set by the service provider or affiliation, if any (see Section 3.6). If no such identifier has been established, then the attribute MUST be omitted. Persistent identifiers are intended as a privacy protection mechanism; as such they MUST NOT be shared in clear text with providers other than the providers that have established the shared identifier. Furthermore, they MUST NOT appear in log files or similar locations without appropriate controls and protections. Deployments without such requirements are free to use other kinds of identifiers in their SAML exchanges, but MUST NOT overload this format with persistent but non-opaque values

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

NameID format	Description
	Note also that while persistent identifiers are typically used to reflect an account linking relationship between a pair of providers, a service provider is not obligated to recognize or make use of the long term nature of the persistent identifier or establish such a link. Such a "one-sided" relationship is not discernibly different and does not affect the behavior of the identity provider or any processing rules specific to persistent identifiers in the protocols defined in this specification. Finally, note that the NameQualifier and SPNameQualifier attributes indicate directionality of creation, but not of use. If a persistent identifier is created by a particular identity provider, the NameQualifier attribute value is permanently established at that time. If a service provider that receives such an identifier takes on the role of an identity provider and issues its own assertion containing that identifier, the NameQualifier attribute value does not change (and would of course not be omitted). It might alternatively choose to create its own persistent identifier to represent the principal and link the two values. This is a deployment decision.
transient urn:oasis:names:tc:SAML:2.0:nameid-format:transient	Indicates that the content of the element is an identifier with transient semantics and SHOULD be treated as an opaque and temporary value by the relying party. Transient identifier values MUST be generated in accordance with the rules for SAML identifiers, and MUST NOT exceed a length of 256 characters. The NameQualifier and SPNameQualifier attributes MAY be used to signify that the identifier represents a transient and temporary pair-wise identifier.

3.4.6 Request new SAML application via Self-Service | Part 1 - IAP portal

Step 1: SAML Onboarding Request

To request a new SAML configuation you need to follow the below steps. Please read as well our terms and conditions, which you can find here. This guide describes the needed steps in detail and provides more important information.
Please read the instructions in detail. If you have any futher question, please contact us via our onboarding mailbox at Onboarding.Bosch-Idp@de.bosch.com.

Step 1 | Open IAP website

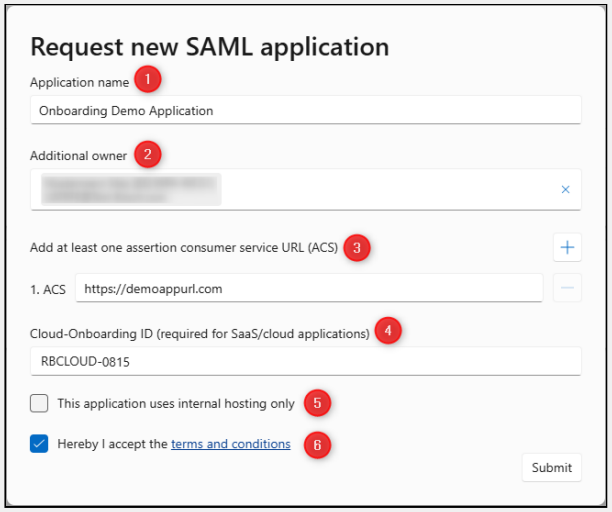
The first step is to open the IAP website to start the request from the displayed dashboard. via

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

BCD (*.bosch.com)	https://rb-iap.bosch.com/new/entraID/applications/saml
Q9 (*.test-bosch.com)	https://rb-iap.test-bosch.com/new/entraID/applications/saml

3.4.6.1 Step 2 | Start the request

1. Click the button Request new SAML application on the dashboard. The following screen appears:



1	**Application Name** Please choose a short speaking but meaningful name for your application (max. 120 characters). There is no technical impact.
2	**Additional owner** We need at least 2 owners for the application as contacts and as responsible persons for the configuration. In the initial request you can only add one additional owner. Later in the Entra ID enterprise application configuration you can add more owners if you need.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	3	**Assertion Consumer URLs** These are the endpoints, to which the IdP sends the issued SAML token. This value can only be changed via IAP and is a required field during the request. Based on this URL we can see if this is an internal or cloud hosted application. Based on that value we can also check the need of the cloud onboarding. More Assertion Consumer Service URL can be added or removed by clicking the **+** or **-** button on the right side. Assertion Consumer Service URL with parameter In case you have parameters in your Assertion Consumer Service URL, as for example https://www.myurl.com?parameter=abc then it is important that you: • add a / in front of the ? if the parameter is directly after the root domain, like e.g. https://myurl.com/?*parameter=abc* • it is not allowed to have the "?" in the root domain URL

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- you can add the ? without a / if the parameter is not directly after the root domain, like e.g. https://myurl.com/somethingels?*parameter=abc*

Assertion Consumer Service URL from federation metadata xml file

In case you have a federation metadata xml file provided from your vendor/application, please ensure to use the correct one from the file. You can find the right value in the xml file as follows und the tag "AssertionConsumerService" within the "Location="" property:



If this is not the case, your reply URL imported later on to the EntraID configuration will be overwritten with the one, you configured while the onboarding.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	4	**Cloud-Onboarding ID (for SaaS applications only)** In case your application is hosted outside of Bosch datacenters or Bosch managed cloud environments like AWS or Azure (like e. g. typically SaaS applications) you need an approved and finished Cloud onboarding Workon process. To enable us to check the status of this process, please provide the valid RBCLOUD-xxxx workon number. If you have not started or finished the cloud onboarding, please stop here the request and first do the cloud onboarding process. You can find more information on the docupedia page of the owned service: https://inside-docupedia.bosch.com/confluence/x/e9PVo If the cloud onboarding is not valid, finished or approved or you did not provide a correct number, we need to decline your request. A declined request cannot be updated later on. The request must be restarted from scratch.
	5	**Internal hosting** In case you have an **internal hosted application** without need of cloud onboarding, please mark this checkbox accordingly. This removes any Cloud-Onboarding ID that was provided before and checks the configured assertion consumer URLs against a whitelist for internal hostings on submit.
	6	**Terms and Condition** To submit the request, Terms and conditions need to be accepted after reading.

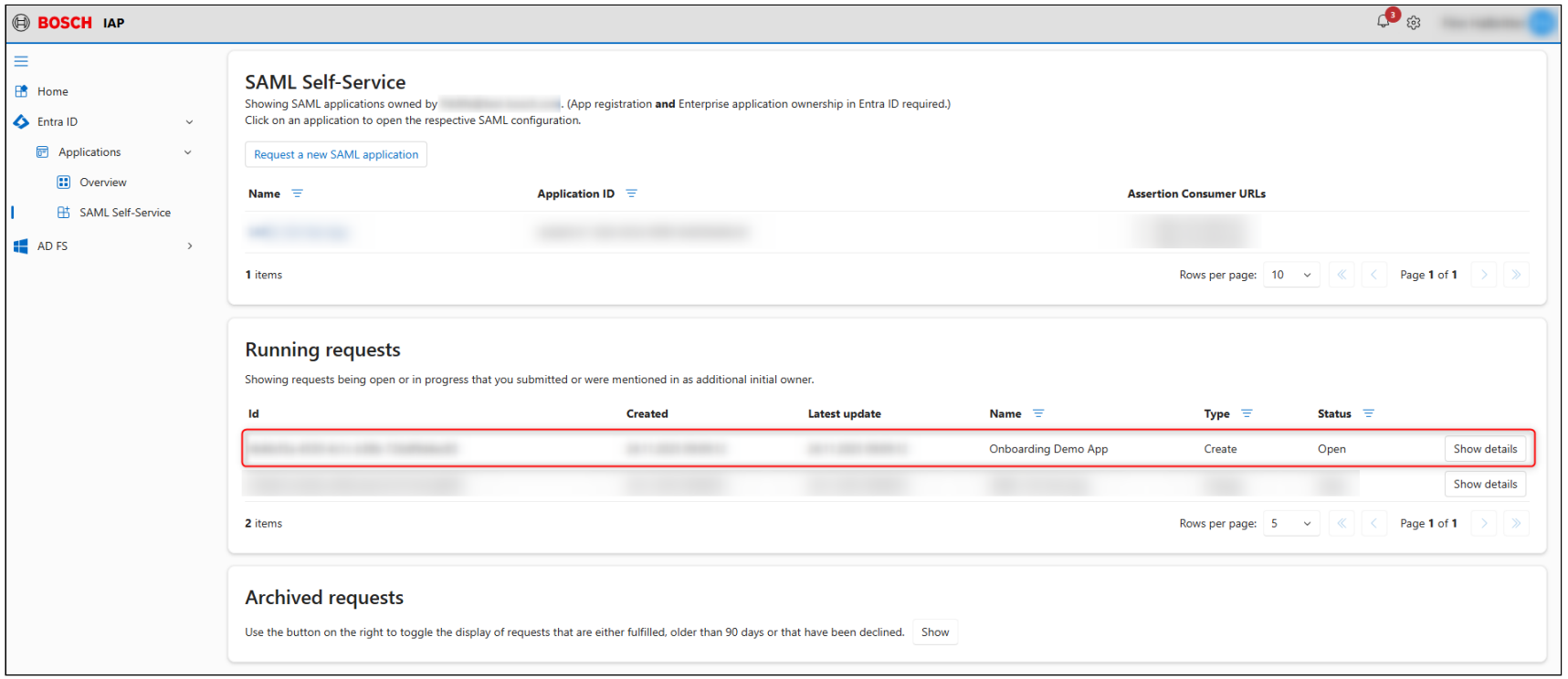
2. Only the above mentioned information needs to be added to the request. All further information, like e.g. Entity ID or claims can be set directly in the Entra ID enterprise app configuration. Once you have entered valid data and filled out all fields, you can send the request by clicking the Submit button.

3.4.6.2 Step 3 | Waiting for approval

1. Once the request has been sent, you will receive a mail as confirmation that your request has been submitted successfully. It will be checked by our team for plausibility.

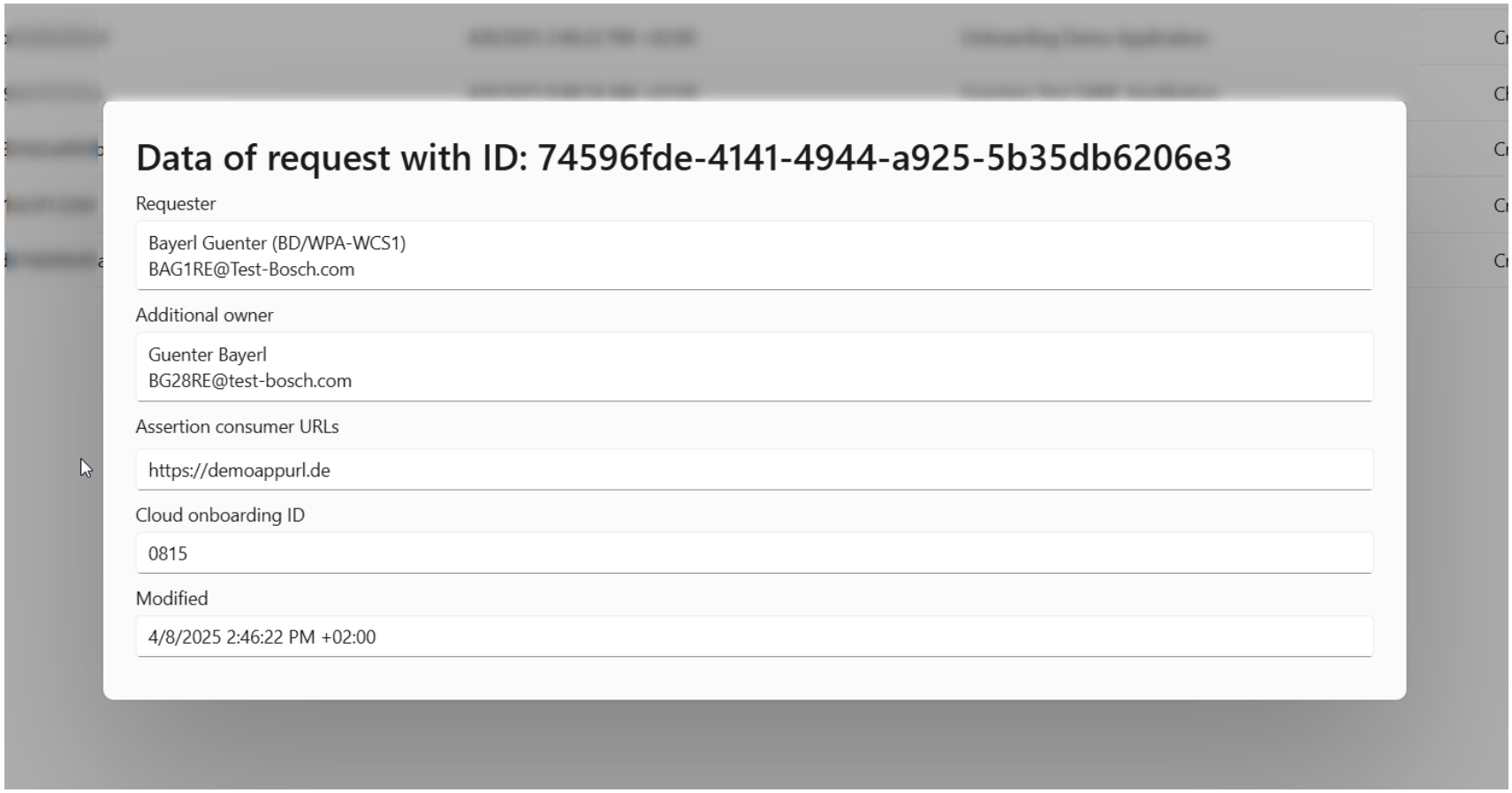
   You can see the status of your request in the "Running requests" overview as you can see in the next screenshot.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



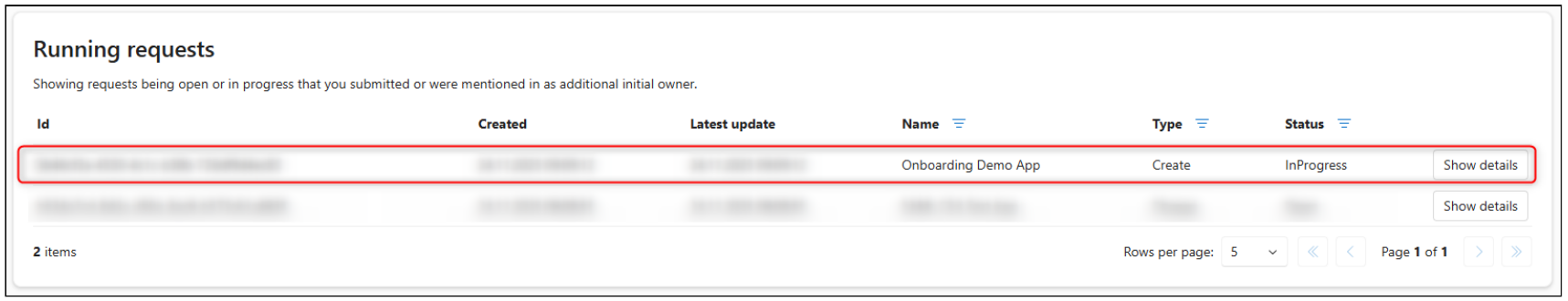
You can see again the details of your request by clicking the Show details button

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



2. In the next step, the team picks your request and perform the checks. The status changes to "In Progress" as you can see in the next screenshot

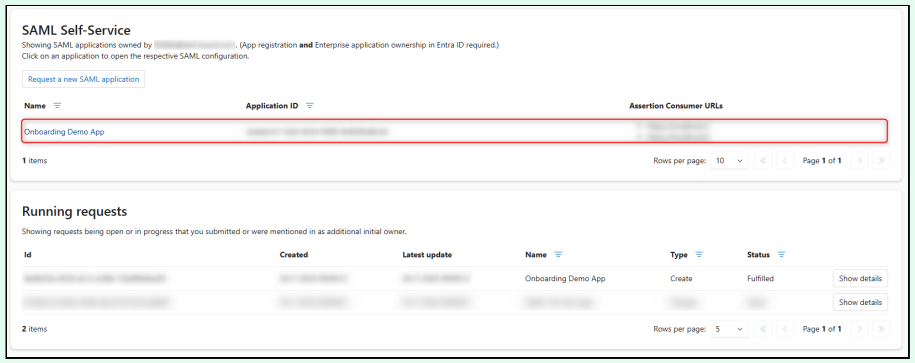
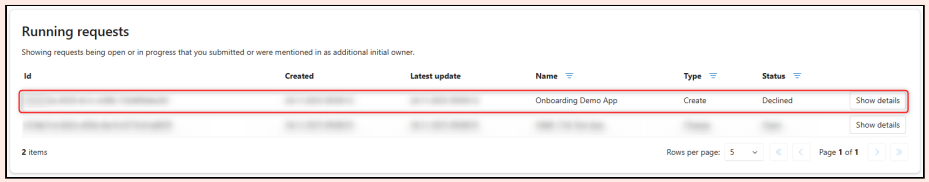
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Once the check is finished, you will get a notification if the request is approved or declined.

Request is approved	Request is declined
In case of an approval, your application appears in the "SAML Self-Service" section and you will receive an Email notification. The onboarding has been finished successfully and from now on you can manage your application by yourself. You will find all links and details by clicking on the name of the applcation.	In case of a decline, the application stays in the "My Requests" section but with the status "Declined". You will receive as well an Email with further details. The onboarding ends here and you are not able to change settings on that request. Please fix the issued based on the information you receive in the mail and start the onboarding process from beginning. You can find a list of possible decline reasons here: https://inside-docupedia.bosch.com/confluence/x/BdRATwE

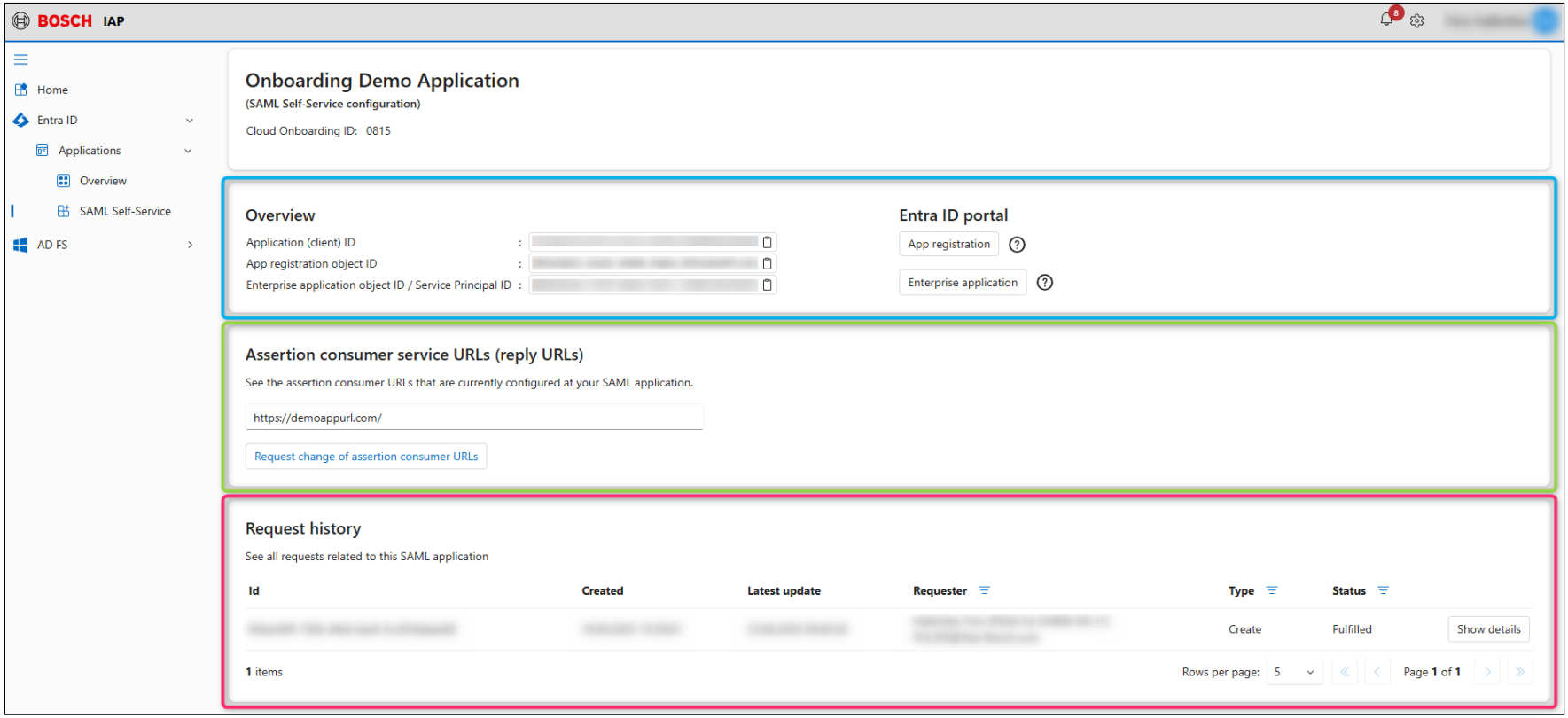
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Request is approved	Request is declined
	

3.4.6.3 Step 4 | Change SAML settings for your application

From now you can manage your SAML configuration by your own. The entry point to all possible settings you can find within the overview, you can access by clicking the "Show" button in your "My SAML applications" overview. The following screen appears:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



3.4.6.3.1 Overview

In the section "Overview", you can find some general information, like e.g. application ID. Further you will find two buttons to directly jump into the EntraID pages where you can change the settings. For more details **follow the 2nd part of the guide**.

To jump to the ***App registration*** (e.g. to configure roles) of your configuration, please click on the button App registration

To jump to the ***Enterprise application*** (e.g. to configure claims and groups) of your configuration, please click on the button Enterprise application

3.4.6.3.2 Configured assertion consumer URLs

You are not allowed to change the Reply URL (Assertion Consumer Service URL) within the Microsoft EntraID overview due to security reasons. Please use the green section here, to change the URLs. It will be synchronized from IAP to EntraID after the request was checked and approved by our team.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.4.6.3.3 Requests related to this application

Here you can find an overview of all requests you or another owner has done for this application. You can see mor details by clicking the Show details button.

3.4.7 Request new SAML application via Self-Service | Part 2 - EntraID

Step 2: Identity Provider Configuration

The second part of the step-by-step guide will focus on the EntraID part. Here you can manage owners, SAML handshake parameters, like EntityID or SSO logout endpoint or certificates which you need for setting up your SAML configuration. As owner it is technically possible to change all settings on the Enterprise application and the App registration.
A general instruction by Microsoft can be found here: Enable SAML single sign-on for an enterprise application - Microsoft Entra ID | Microsoft Learn

Important
Due to security reasons you are not allowed to change some settings, which are listed below. We will monitor such settings and reset them to the default values or as set in the IAP system. The affected settings are:

- **Reply URL (Assertion consumer service URL)**
  In general it is possible to change the Reply URL in your IAP configuration, as the change needs to be checked and approved by our team. Once it is approved, the setting will automatically overwrite the setting in EntraID.

- **Authentication method**
  The authentication method must be always SAML. All other settings will be overwritten to the default.

- **Activation of SCIM**
  SCIM is not offered by our team. Please have a look to https://rb-oneidm-help.bosch.com/en/data/scim.html and contact the IdM team at Mailbox.IdMIntegration@bosch.com

- Step 2: Identity Provider Configuration
- Open Application Config in Azure
- Manage Owners
- Single Sign-On settings

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

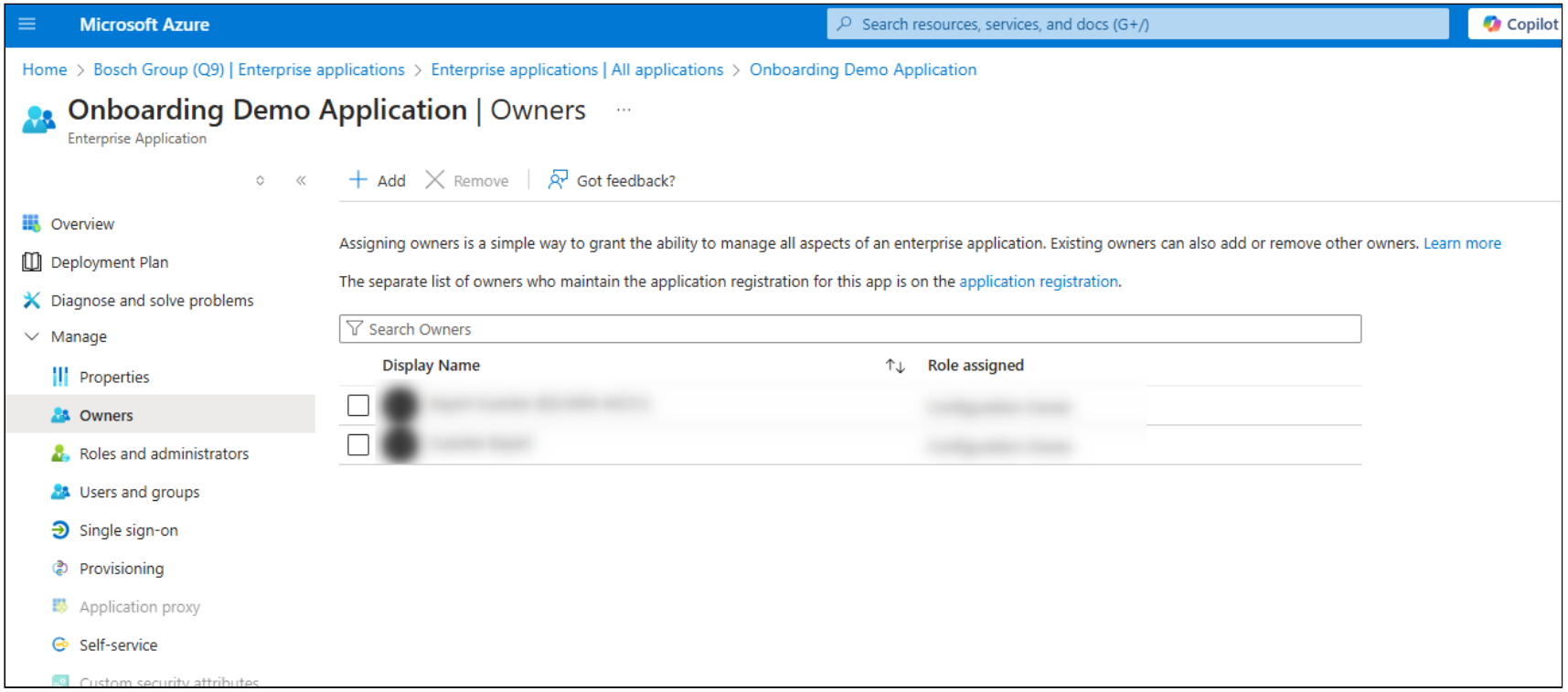
- Basic SAML Configuration
  - Upload Federation Metadata
- Attributes and Claims
- Limit user by groups assignment
- SAML Certificates

3.4.7.1 Open Application Config in Azure

From the IAP-Portal you can jump to the **Enterprise Application** of your SAML app in Azure. There you can do the settings described on this page:

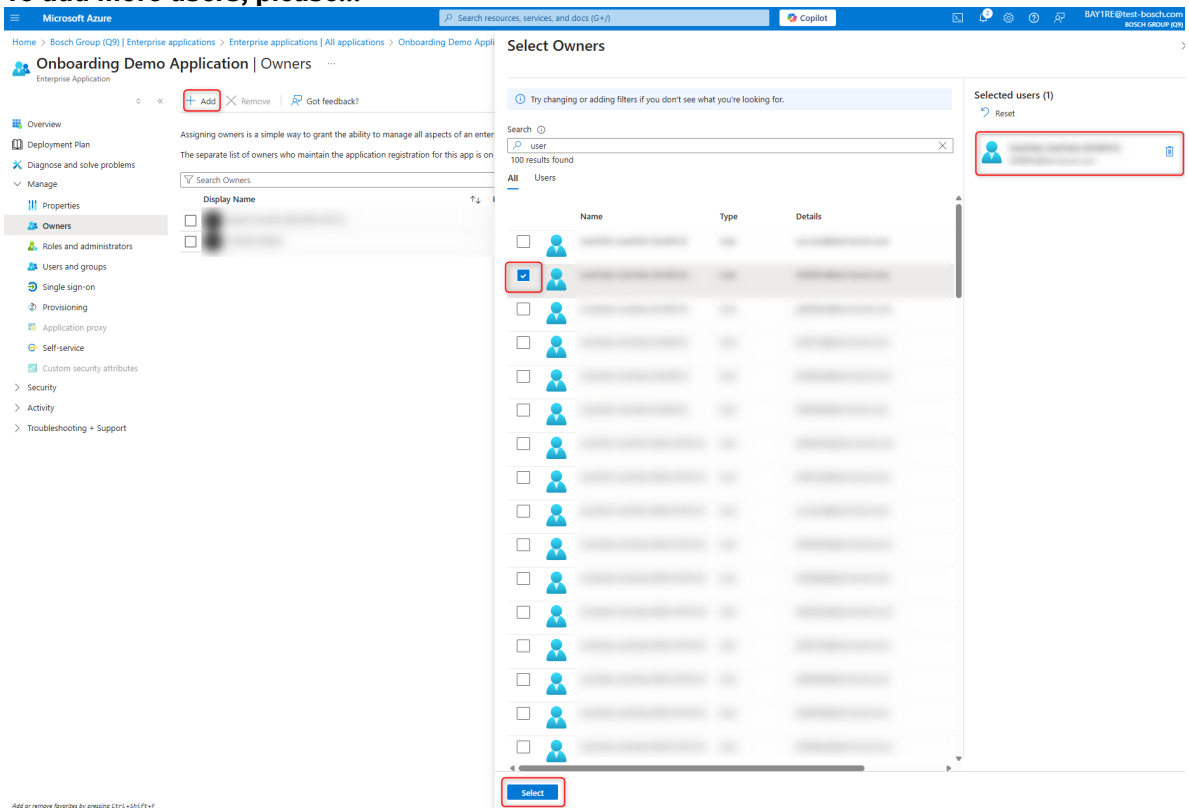
3.4.7.2 Manage Owners

Owners of the application have full permissions to all settings within the enterprise application. An owner can set and change Single Sign-on settings, like EntityID, claims and manage Users and Groups. In the owner section you can add and remove the owners which should be able to change such settings for your application. Please ensure, that there are always at least a minimum of two owners configured in the enterprise application.
Owners can only be user accounts and no groups!



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

To add more users, please...



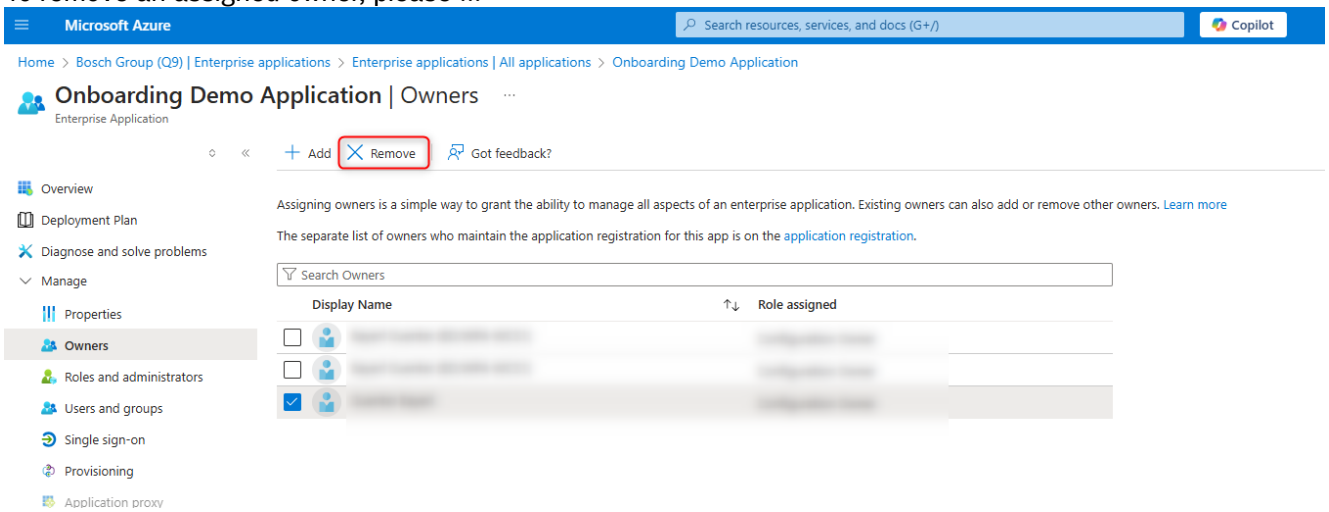
1. click the 

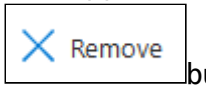
button at the top of the owners overview.
2. search for the username, you want to add in the open dialog and select the user (As soon, you select the checkbox in front of the username, the user appears in the list on the right side.
   You can directly search for another user and add it to the list as well. Do so, as many users you want to add.)
3. If all users are selected, click the 

button on the bottom to add the users to the owners list.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

To remove an assigned owner, please ...



1. select the user(s) in the owners overview by selecting the checkbox in front of the username
2. click the 

button to remove the users from the owners list.

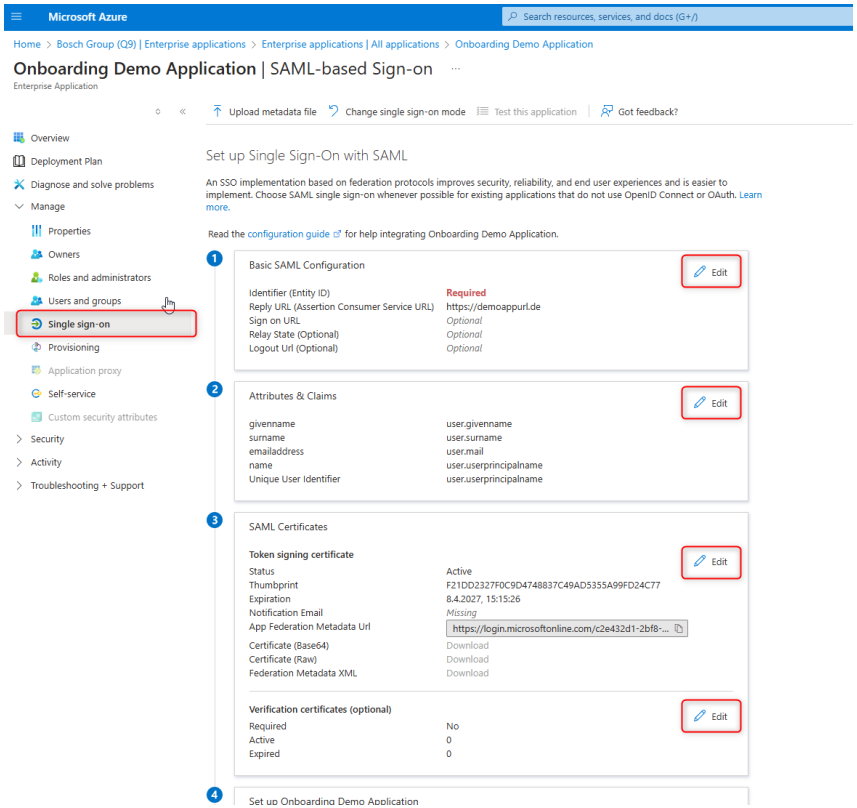
3.4.7.3 Single Sign-On settings

To add or change the basic SAML settings, like EntityID, Single Logout endpoint, please open "Single Sign-On" in the main navigation. The following screen appears.

To change settings in one of the sections, click 

in the section, to be changed.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



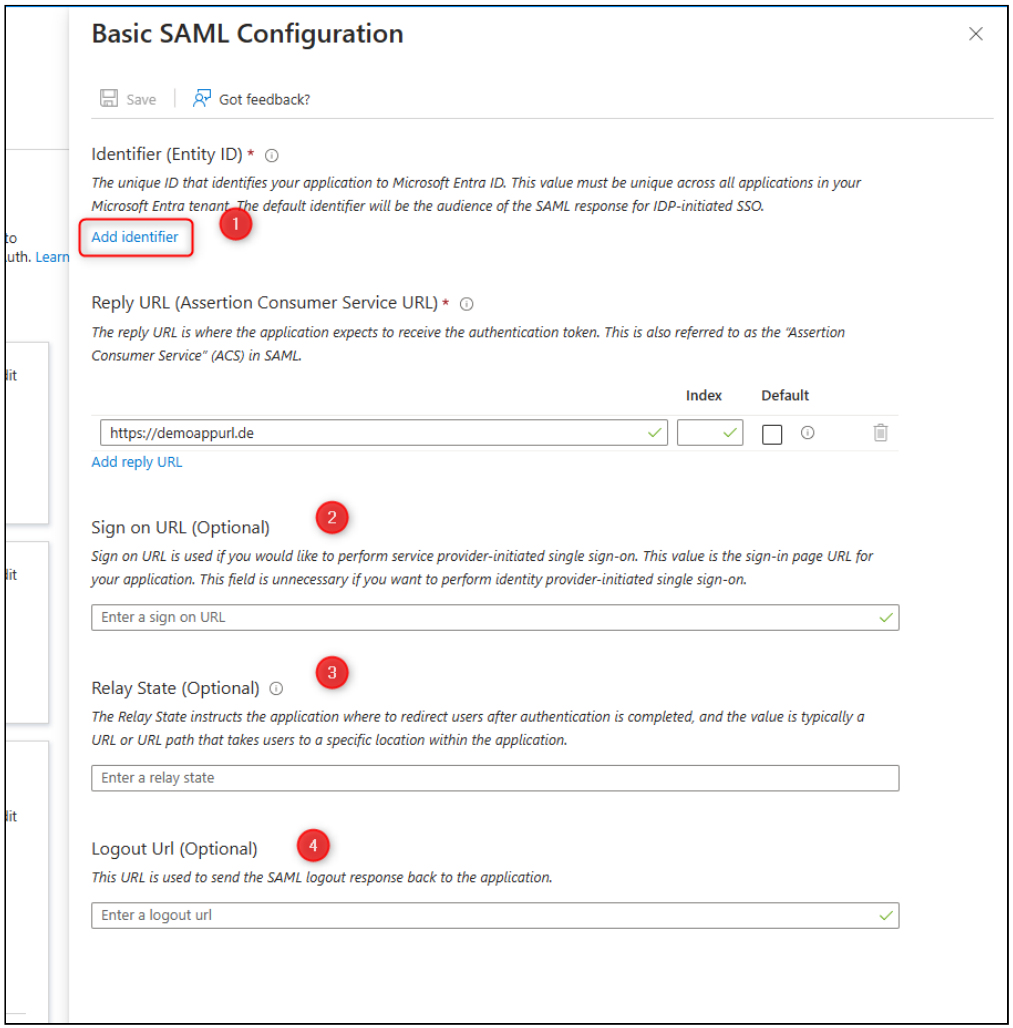
3.4.7.3.1 Basic SAML Configuration

In this section you can configure the basic technical parameters, like EntityID and SSO endpoints of your application. You can find more details on the Microsoft pages (https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/what-is-single-sign-on).

Important

Please be aware that changing the Reply URL (Assertion Consumer Service URL) is not allowed to be changed here. Please return to the IAP portal and do all changes (see https://inside-docupedia.bosch.com/confluence/x/YJoQWAE). All changes made here, will be overwritten by our service to the settings, stored in IAP.

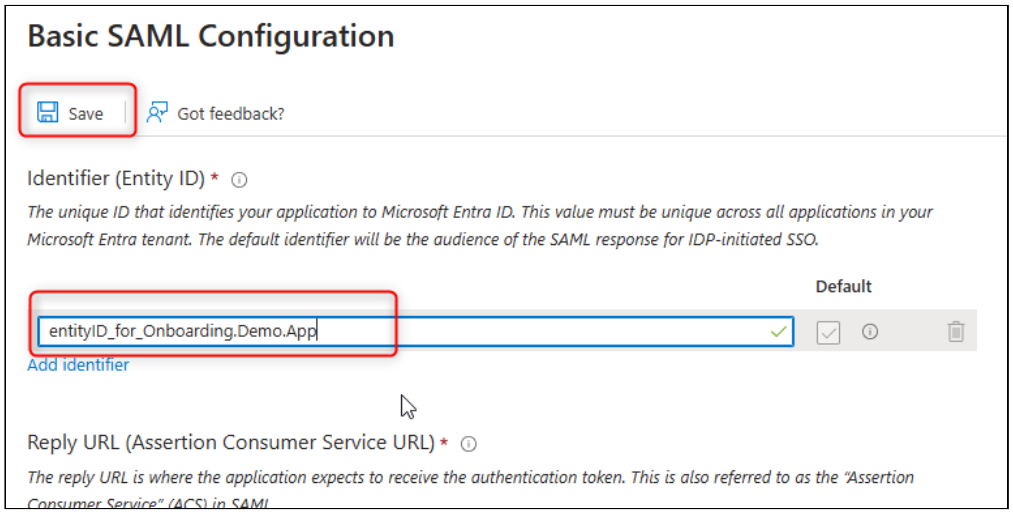
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Identifier (Entity ID) *mandatory

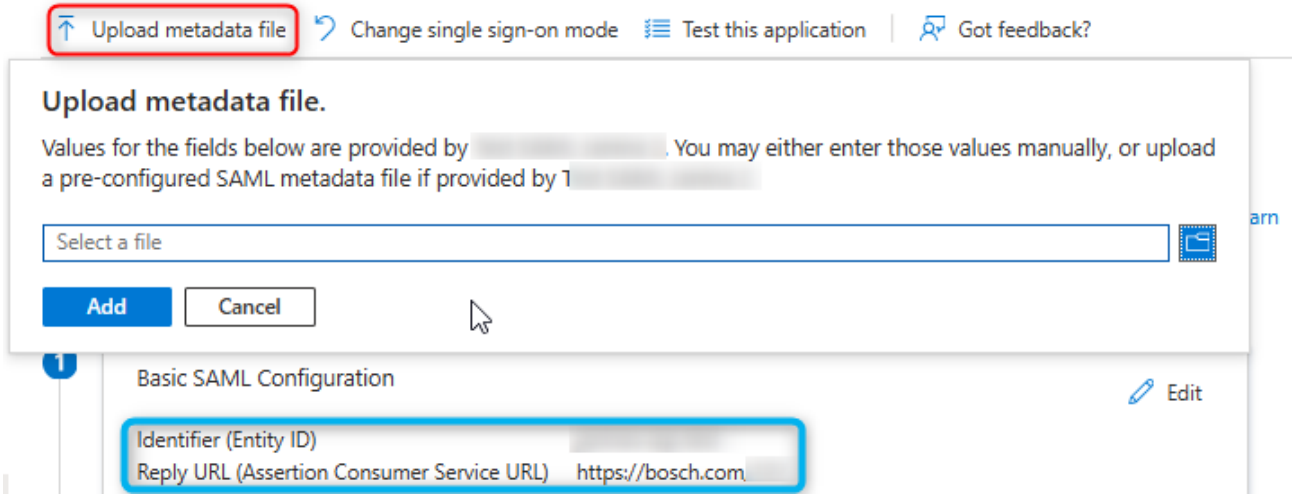
The Entity ID is a mandatory field. It represents the unique identifier within the IdP environment. With the request to authentication, the application provides exactly this value to uniquely identify which configuration must be used to authenticate the user and provide the SAML token. The EntityID id a string and is case sensitive.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



3.4.7.3.1.1 Upload Federation Metadata

Instead of adding the Entity ID manually, a Service Provider Metadata File (.xml) can be uploaded. If the vendor of the application offers such a file, it can be uploaded in the Azure configuration and it will automatically overwrite settings of the Entity ID and Reply URL. Therefore please make sure that the Reply URL is the same that you requested in the SAML Onboarding Request!



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.4.7.3.2 Attributes and Claims

To adopt the claims to the need of the application, you can setup the claim set accordingly. For more detailed information, please have a look to our claims overview, which you can find at Bosch Attributes and Claims - Directory Services - Docupedia. General instructions from Microsoft can be found here: https://learn.microsoft.com/en-us/entra/identity-platform/saml-claims-customization

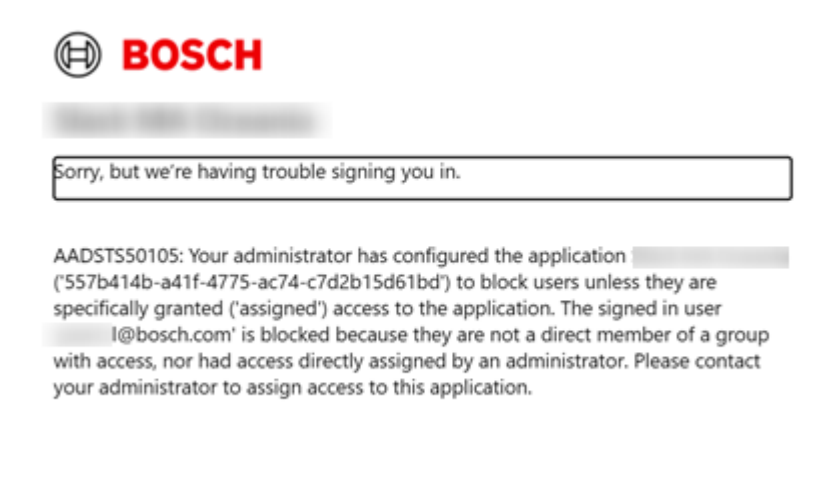
For more information about group claims, we offer an overview here: Groups and Authorization

3.4.7.3.3 Limit user by groups assignment

By default the configuration is setup that only users which are assigned to the application in the "users and groups" section will get a SAML token issued by the Entra ID.

Possible Error

If you have no group assigned and the Assignment Required set to "Yes" the **SAML-login will fail** with the error message AADSTS50105 ([...] has configured the application [...] to block users unless they are specifically granted ('assigned') access to the application [...])

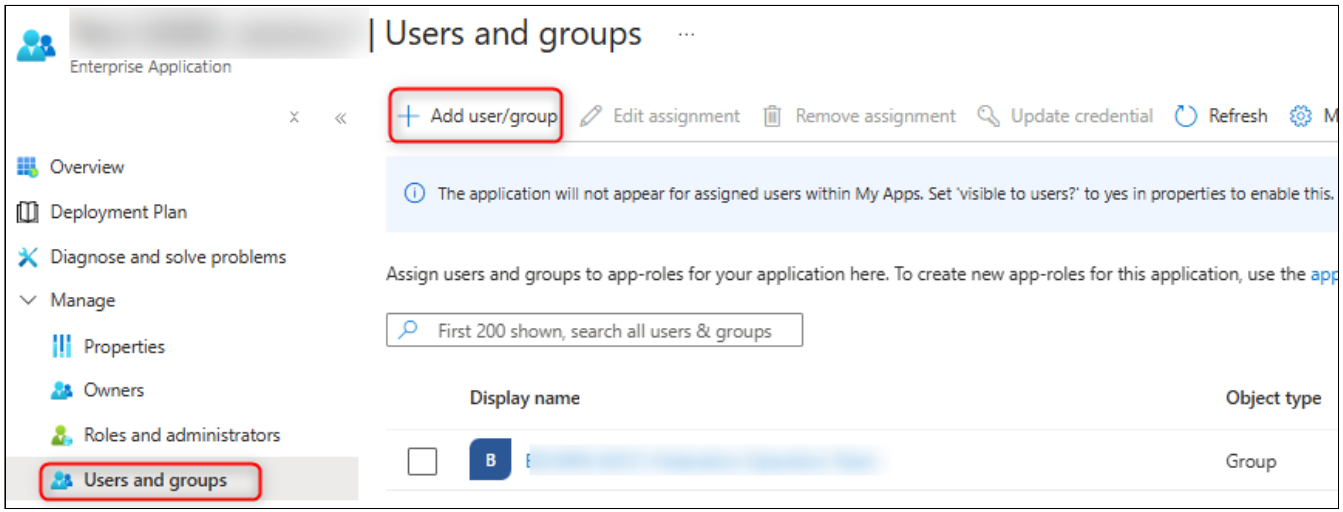


Therefore please follow the steps below (either Option A or Option B) to resolve this

Option A: Assign Groups

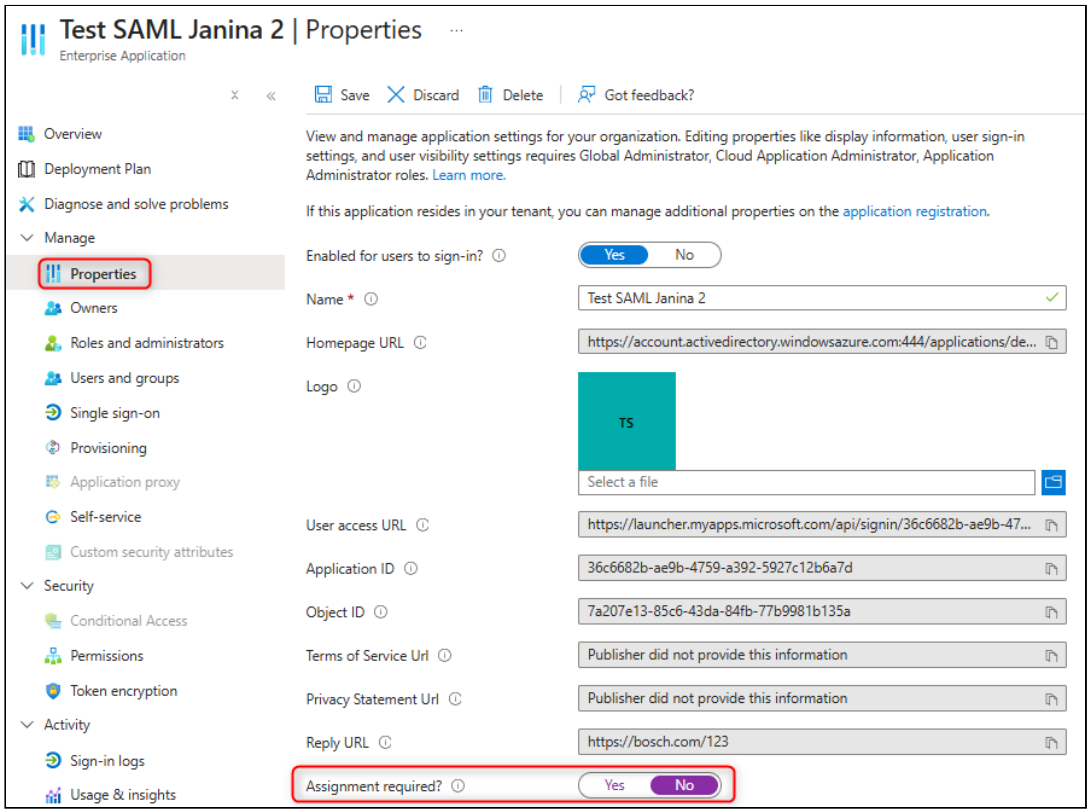
Assign groups to the applications configuration in the section "Users and groups". Please be aware only direct members can be used for this. We recommend to use idm2bcd groups/roles or itsp-managed AD groups for this scenario.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Option B: Remove Restriction
OR: If there is no need for this restriction (for example your authorization concept is built inside the application) you can adapt this in the Properties of your SAML configuration in EntraID by changing the setting "Assignment required" to "No". With this setting every Bosch user will get a SAML token for your application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



3.4.7.3.4 SAML Certificates

In the SAML certificates section you can manage the token signing certificate for your SAML configuration. You can see and download the current valid certificate and you can also create a new certificate. Furthermore, you can manage the Email addresses which should be notified in case the current token signing certificate is about to expire.

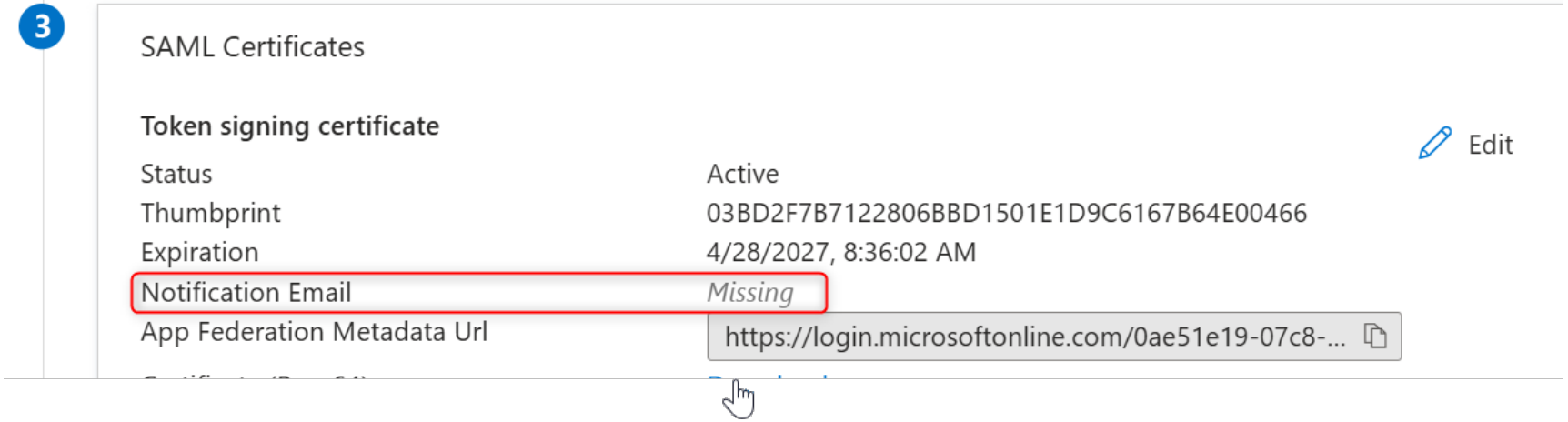
This certificate needs to be replaced regularly. Please update your certificates in time to avoid a service downtime of your SAML application as explained in Change SAML Signing Certificate - Directory Services - Docupedia

Important
Please ensure to meet the EISA security guidelines in terms of exchange of certificates within two years!

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

For more information regarding the security guidelines and contact persons, you can find in the EISA (***EISA-CRY-107.6 - Standards for Asymmetric Cryptographic Key Material)***
https://www.intranet.bosch.com/doku/eisa/EISA-CRY-107.html#ctl$EISA-CRY-107$impl-reqs$6

Manage notification email addresses
To get notifications when the certificate is about to expire, please manage one or more valid Bosch internal email addresses which should be informed. The notification will be sent out approx. 4 weeks before the certificate is about to expire.



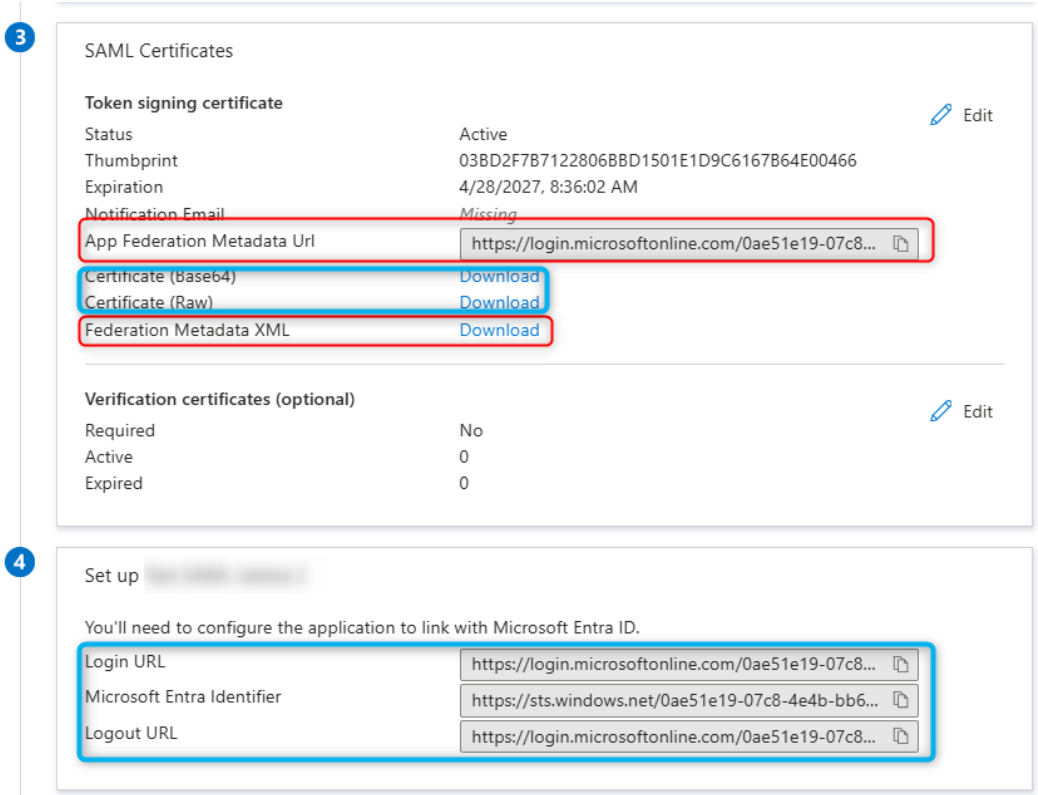
3.4.8 SAML Configuration | Part 3 - Application

Step 3: Application Configuration

3.4.8.1 Get the information to configure your application

Finally you need the information, how to setup your application to forward authentication requests to the EntraID and validate the responses.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



3.4.8.1.1 Federation Metadata XML file

Therefore you need the **federation metadata file,** a standardized xml file where you can find the needed information within.
Many applications support to import or link to the federation metadata xml file to catch all needed information directly. Some of the applications also support an auto update of the information. In case you update the certificate, the federation metadata file on the Idp changes as well. So the application can be always up-to-date.

You have two options (see picture above):

1. Download the URL
2. Copy the link to post it to your configuration

Which option you need, depends on your application

3.4.8.1.2 SSO-Endpoints and Certificates

Some applications expect the Identity Provider Details as single entries:
The **certificates** can be downloaded from Entra ID directly (see picture above) and you will find them as well in the federation metadata xml file.
Single Sign-On and Single Sign-Out **endpoints:**

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- Microsoft Entra Identifier (EntityID): https://sts.windows.net/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/
- Login URL: https://login.microsoftonline.com/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/saml2
- Logout URL: https://login.microsoftonline.com/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/saml2

The endpoint information can be found in Entra ID (see picture above) and as well in the federation metadata xml

3.4.9 SAML Request Decline use cases

3.4.9.1 Decline use cases

When requesting a new SAML configuration for EntraID, you need to fulfill some preconditions which you can find in our Terms and Conditions part at https://inside-docupedia.bosch.com/confluence/x/LoiMY.
Each request will be checked to meet our preconditions. In case, it is not the case, we need to decline the request. We provide you with the link to the section with the reason, so that you are able to correct it and resend the reuqest.

3.4.9.1.1 Cloud Onboarding

Cloud or SaaS onboarding is a process, not owned by our team. To find more information regarding the process, contacts or if a cloud onboarding is needed for your application, please follow the information at SaaS Onboarding - WorkON - IoT & Digitalization - Docupedia.
In case cloud or SaaS onboarding is needed for your application, you must provide the workon number (RBCLOUD-xxxxx) of the already finished and approved workon process within the request. In case it is missing, not relateable to your application, not yet approved or declined, we will decline the request. We will send you the expanation of the reason by providing the link to the correct sub entry.

3.4.9.1.1.1 No or wrong Cloud Onboarding workon number provided

Your assertion consumer service URL points out, your application is not installed at the on premesis network but in the cloud. For your application, an approved cloud onboarding is needed. Please follow the link SaaS Onboarding - WorkON - IoT & Digitalization - Docupedia to get more information about the process.
In your request you did not provide a cloud onboarding workon number or a number which is not associated with your application. If you did not start the cloud onboarding process, please follow the process and restart the request, once your cloud onboarding is finished or approved.
If you have already finished the process with an approved workflow, please restart the request as well with the number provided.
If there is no cloud onboarding needed for your application, plaease forward the confirmation mail, you got from the cloud onboarding process owner to proof, for your application, a cloud onboarding is not needed.

3.4.9.1.1.2 Cloud onboarding process not yet approved or finished

You have already started the cloud onobarding process but it is not finished and approved so far.
To continue the SSO onboarding, a finished and finally approved cloud onboarding is needed. Please resend the request, as soon your Cloud Onboarding process is finished

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.4.9.1.1.3 Cloud onboarding request declined

If your applicaiton needs a cloud onboarding but it has been declined by the cloud onboarding team, we will not onboard your application to SSO. Please come back once you have a valid cloud onboarding and resend the request again.

3.4.9.1.1.4 Personal-related data set to "No" in Cloud Onboarding

Attribute "personal-related data" is set to No in your cloud onboarding documentation. This is not correct, as with the SSO token, personal data will be sent to and stored inside the application.
We approved your configuration, as you set the attribute "Personal data - ISP" to Yes in LeanIX.
The responsibility of doing security checks and documentation correctly.

3.5 OIDC Configuration

Overview

- Step 1: Identity Provider Configuration
  - Initial OAUTH/OIDC App registration
  - App registration: Basic Settings
    - Configuration of secrets for confidential clients
    - Configuration of Redirect URIs
  - Manage Owners of the application
  - Additional Claims
  - Scopes
  - Authentication Context and MFA
  - Further information
- Step 2: Application Configuration
- Step 3: Admin Consent Approval

To follow industry standards, we adapt the official OIDC framework which is an Identity layer built on top of the OAuth 2.0 authorization framework RFC 6749 for the SSO integration. OIDC allows third-party applications or services (the one you are building or consuming from another vendor) to verify the identity of the Bosch associate or external partner and to obtain basic user profile information. Whereas OAuth2.0 is about accessing resources and honoring authorization concepts, ODIC is required for the user authentication. Using OIDC protocol and integration provides the benefit to use one single Identity provider - such as the Bosch Entra ID SSO service - to identify and authenticate users across multiple applications and services in a seamless way.
It is important to properly integrate the official OIDC framework for the Bosch SSO to not only be compliant with internal Security Governance regulations but also to follow along industry standards.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

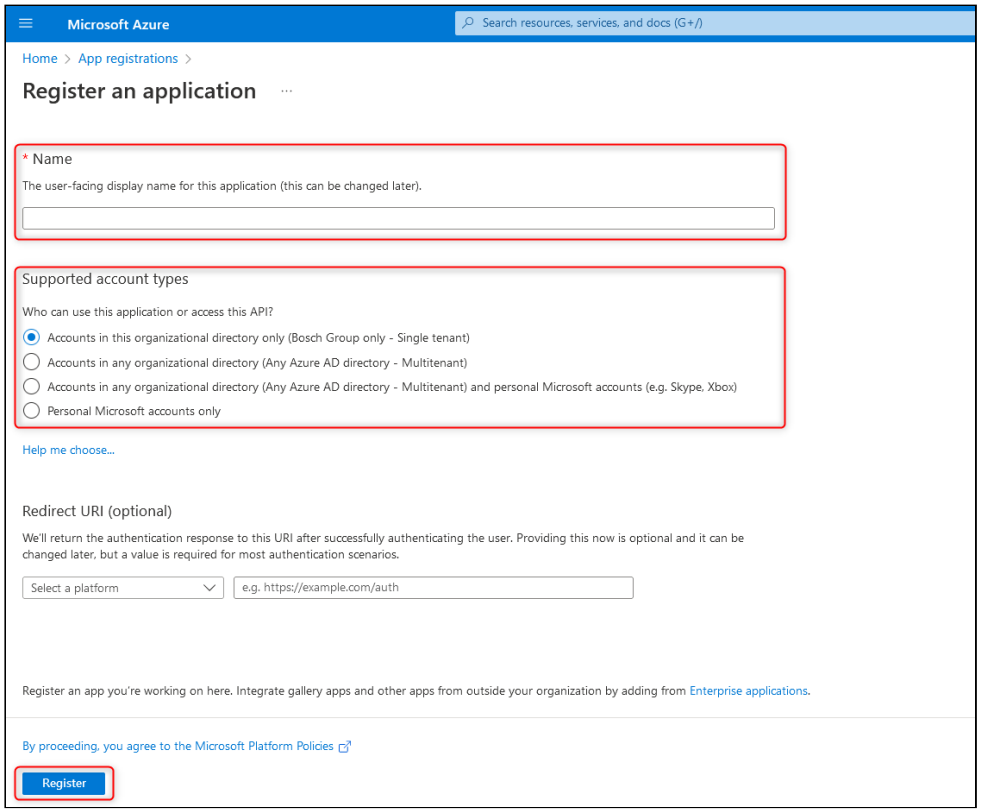
3.5.1 Step 1: Identity Provider Configuration

Your configuration can be done on Azure portal. There you can create an App Registration

To use the Entra ID identity and access platform to authenticate users for your application you have to register the application initially. Only for registered applications authentication and authorization with the Entra ID accounts is possible.

3.5.1.1 Initial OAUTH/OIDC App registration

Browse to https://entra.microsoft.com/#view/Microsoft_AAD_RegisteredApps/ApplicationsListBlade/quickStartType~/null/sourceType/Microsoft_AAD_IAM with your Bosch office account to start the registration dialog by clicking the button + New registration at the top of the page. The following dialog screen will appear...



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Please choose and enter a meaningful and unique **name** for your application and select the correct supported account type. The Redirect URIs will be entered in a later step. Keep this empty for the moment.

Supported account type
In the supported account type section you can define which users are allowed to authenticate for your application. The default setting is "Accounts in this organizational directory only (Bosch Group only - single tenant". Please keep this item selected. It means that only corporate Bosch accounts will be authenticated for this applications.

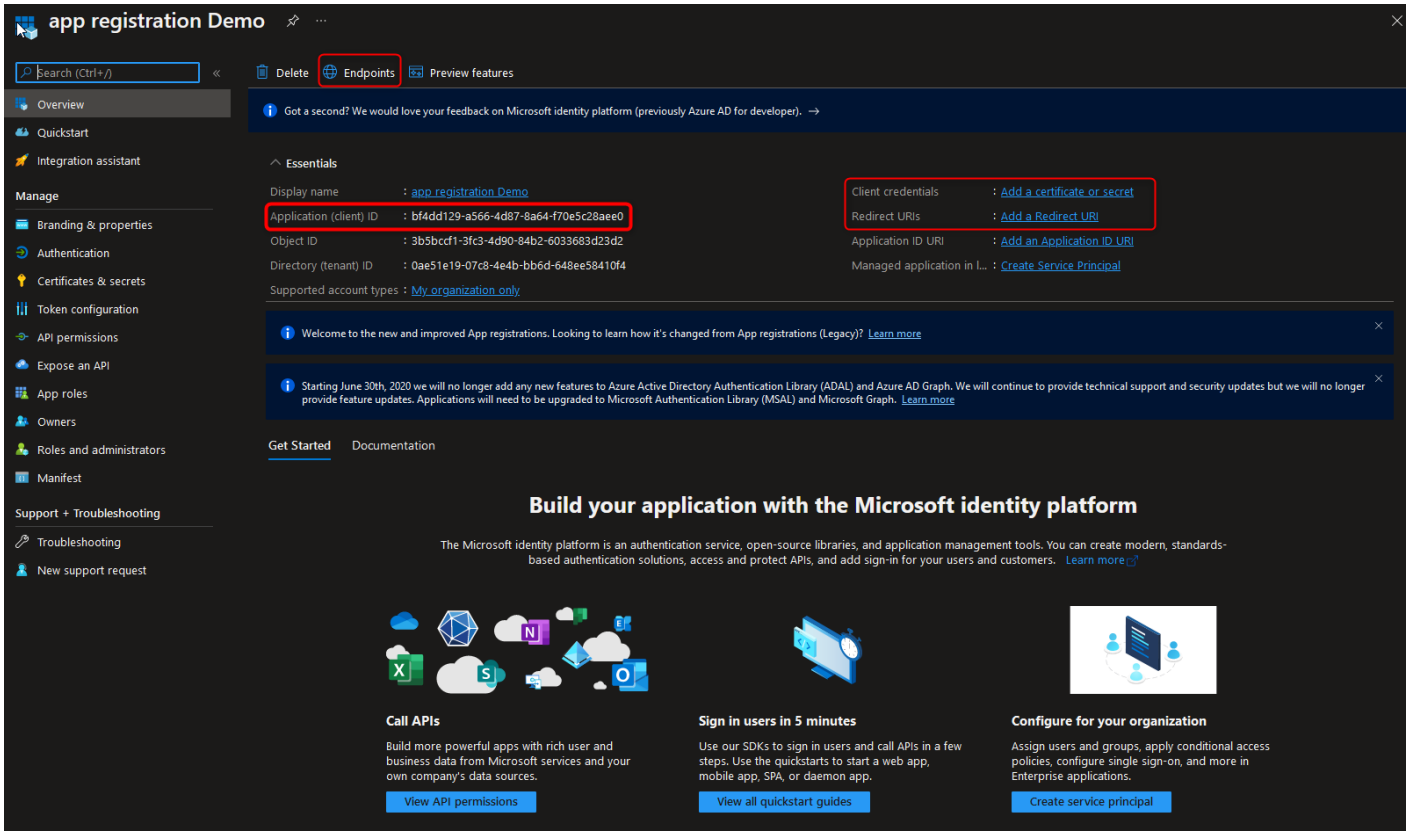
The options Multitenant or personal accounts are not allowed to be used at BOSCH!

When done click the button **Register** to get your application registered. You will be forwarded to the overview page of your registered application as shown in the next screenshot

3.5.1.2 App registration: Basic Settings

Here you can find important information like the **Client ID** or the **overview** for the needed endpoint information and you have links to the next needed steps in the registration process. In the screenshot below some important parts are highlighted.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



1. **Client ID**
   The client ID is needed in your OAUTH/OIDC configuration. It is used to uniquely identify the application and you have to define it in the settings of your application.
2. **Endpoints**
   With this button you can find the needed Entra ID endpoints for the configuration in your application (e.g. the token endpoint, the authorization endpoint or as well the link to the .well-known/openid-configuration metadata endpoint)
3. **Client Crentials link**
   Follow this link to create a secrete or certificate which are used for confidential client applications. you can use either a certificate and/or a secret (handled like a password) to protect your client.
   Jump to detailed description

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4. **Redirect URIs link**
   A redirect URI is an endpoint where the Identity provider redirects the user and issues security tokens after a successful authentication.
   This could be a link/url to the endpoint of your web application or as well another URI like in mobile applications.
   Redirect URIs in the app registration process will be configured based on their platform type (Web application, Single page application, mobile application, ...)
   Jump to detailed description

3.5.1.2.1 Configuration of secrets for confidential clients

The following steps are for confidential clients e.g. if your application is using the Code Authorization Flow or the Client Credential Flow (more details can be found here). Therefore they are required for most applications, but e.g. should not be set for Single-Page-Applications (SPA)
You will get to this dialog by clicking the link in the applications overview page (described above) or by selecting the "Certificates & secrets" navigation entry in the left navigation bar.
Once you are in the dialog you can select "Certificate" or "Client secrets"

1. **Certificate**
   In this section you can upload a certificate to be used as a "secret". It is recommended to use certificates as they are more secure then secrets!

Certificate Recommendations
There are no special requirements for these Certificates. You can use self-signed (create e.g. via OpenSSL, Powershell, ...), your SSL-certificate (if it is not rotated automatically) or certificates from a well-known certificate authority.
Be aware of the regulations from CD 9000 for Certificates:

- Exchange Certificate within 2 years:
  EISA-CRY-107 - Cryptographic Key Management
- For RSA min 3072 Key Length and SHA-256:
  EISA-CRY-103 - Cryptographic Mechanisms: Algorithms, Key Lengths, and Protocols

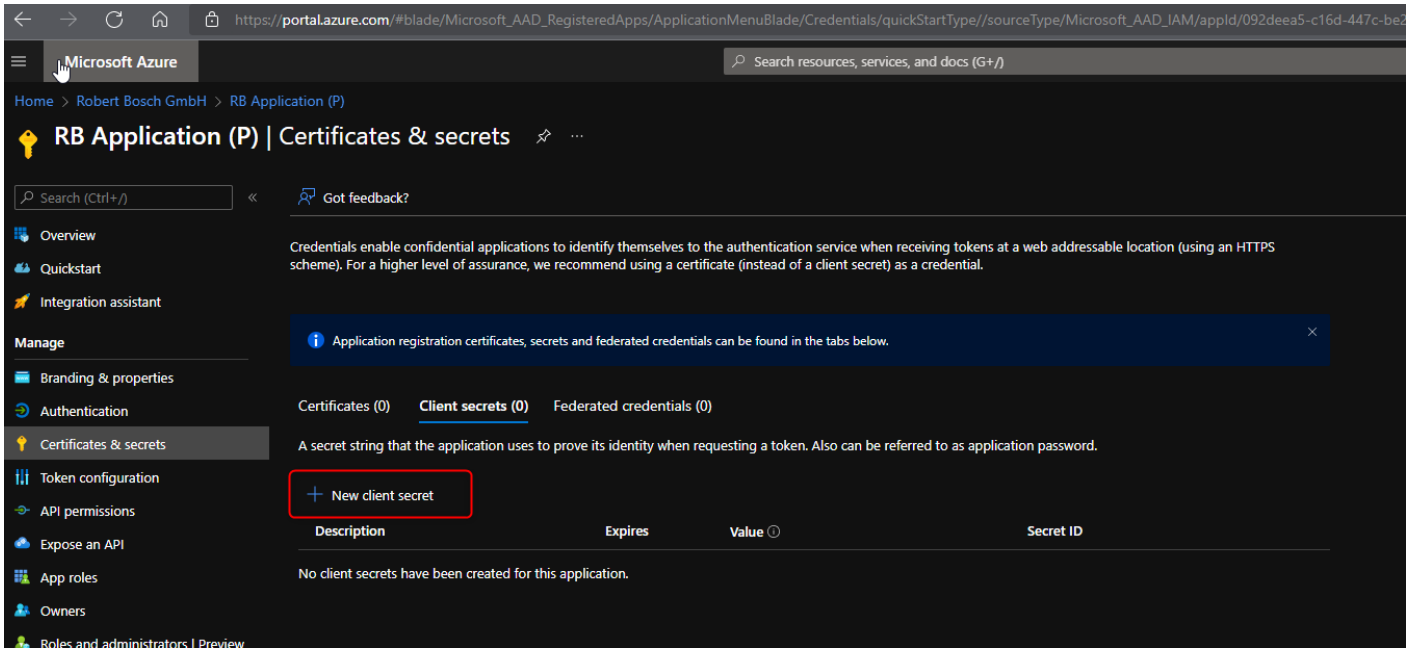
2. Client secrets
To create a new secret for your confidential client you need to click the button "+ New client secret". On the right side a new dialog will appear you you cat create the secret. Give the secret a meaningful name and choose the expiration time. Please ensure to meet the limitiation and rules of the EISA, which you can find here: https://www.intranet.bosch.com/doku/eisa/EISA-ACC-301.html#ctl$EISA-ACC-301$impl-reqs$6

The setting will be set with clicking Add at the bottom of the dialog.

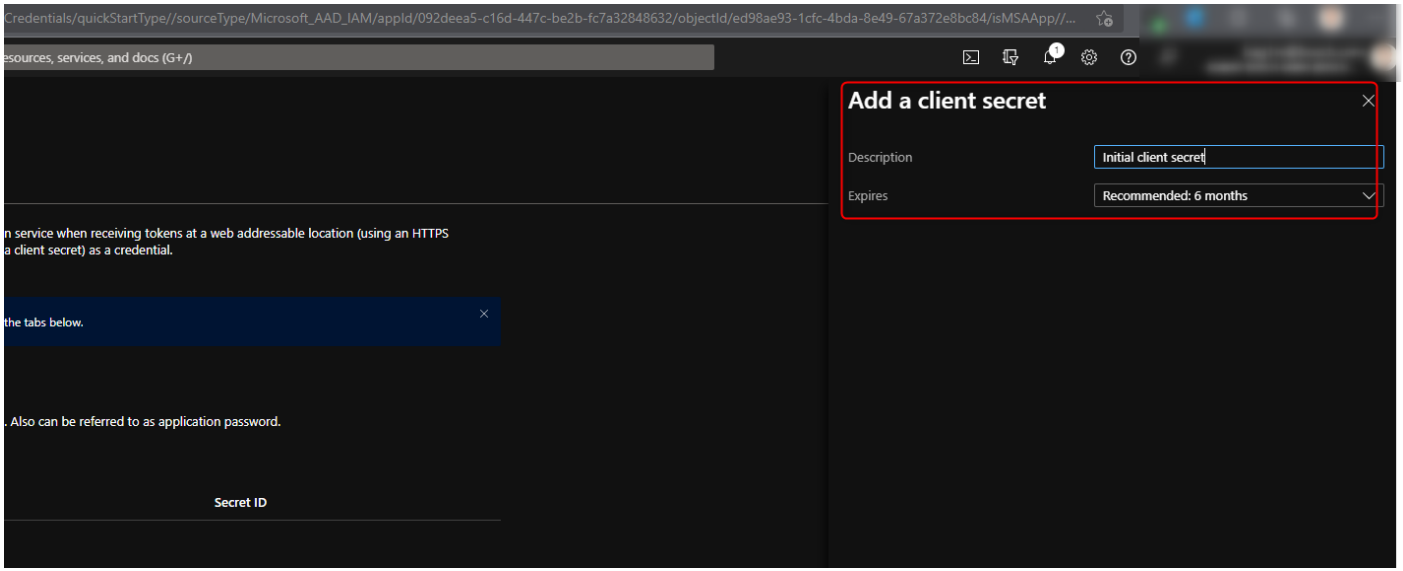
Copy the secret now and store it on a safe place

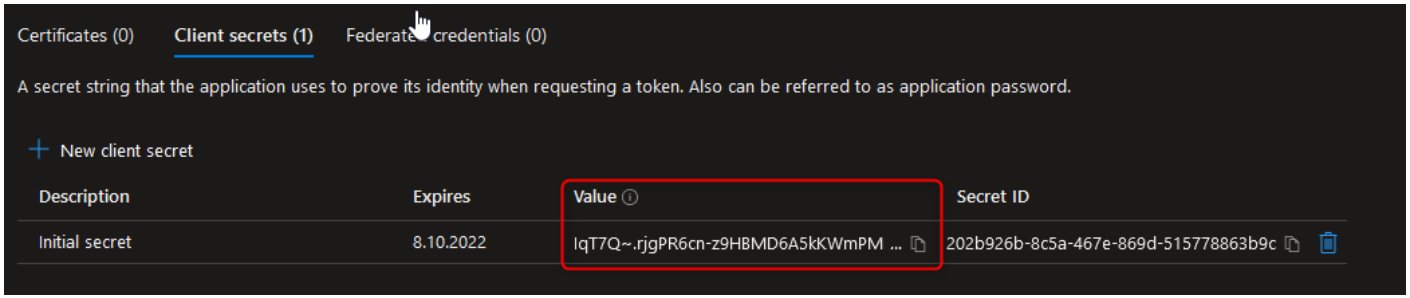
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The client secret will be displayed only once after the creation. It will not be stored and cannot be displayed anymore later on. So please copy the secret (column Value) immediately and save it to a secure place, e.g. RB-PAM, RB-Secrets or a KeePass file.
Treat the secret the same as a password and don't share it with other persons! In case you still need to share it with your team, please ensure to meet the limitiations and rules of the EISA, which you can find here: https://www.intranet.bosch.com/doku/eisa/EISA-ACC-202.html#ctl$EISA-ACC-202$impl-reqs$5



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



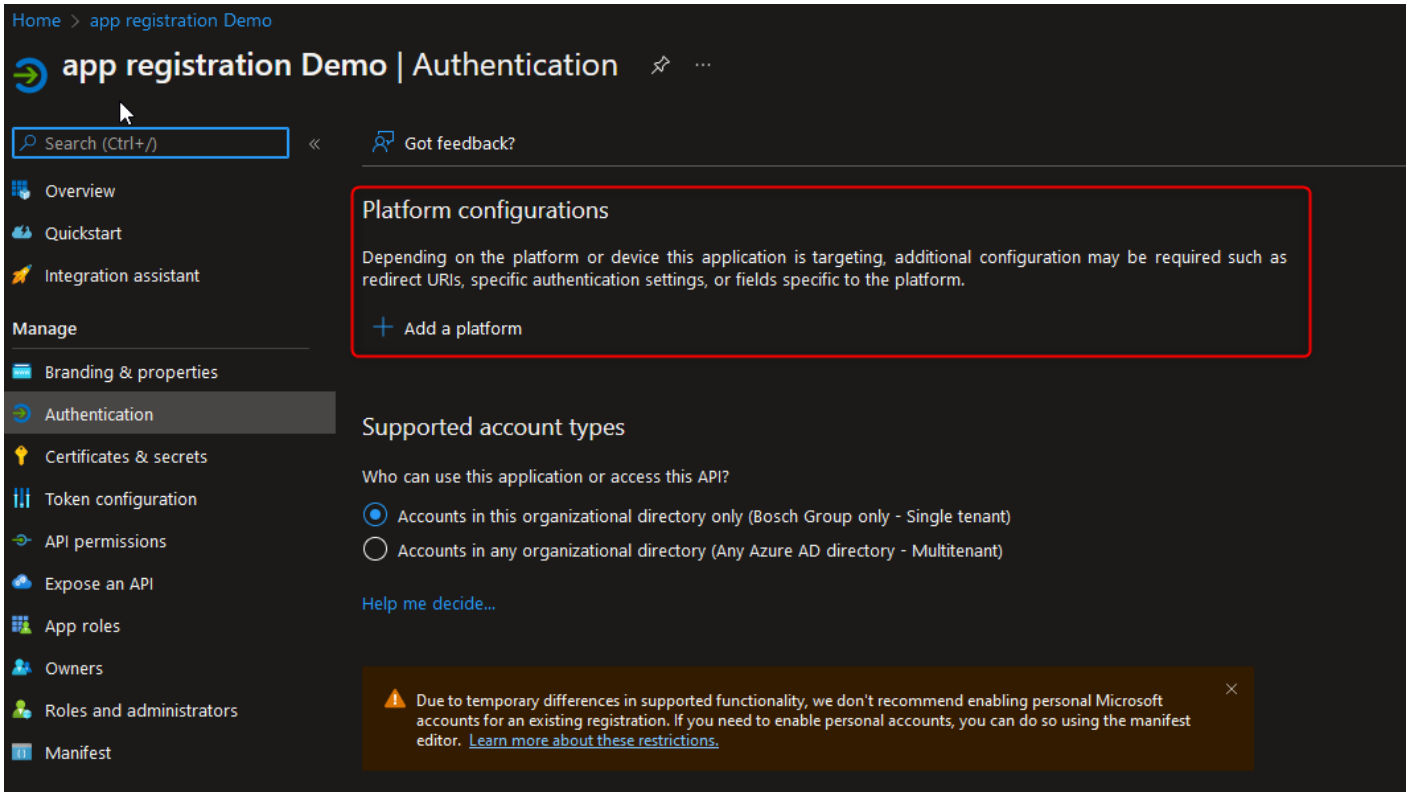


It is possible to build your own **automation** for credential rotation that we are explaining here: Automated Application Credential Management

3.5.1.2.2 Configuration of Redirect URIs

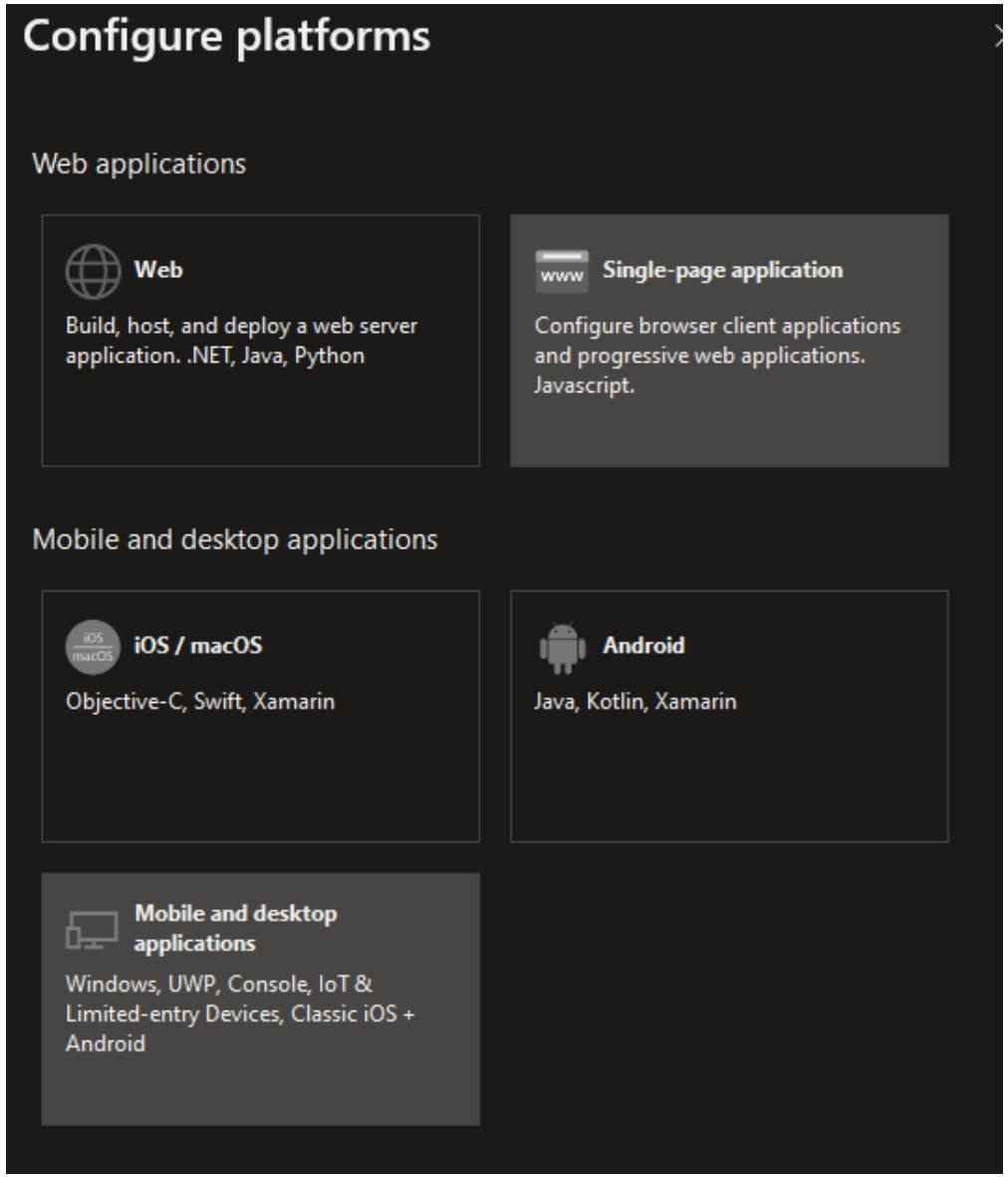
Like described earlier redirect URIs will be configured based on their platform types. You can get to the section by pressing the link in the application registrations overview page or by choosing "Authentication" in the left navigation bar and click the button + Add a platform

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



The following screen appears on the right side ...

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



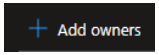
Please choose the item which describes your application and enter the parameters in the upcoming screens.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

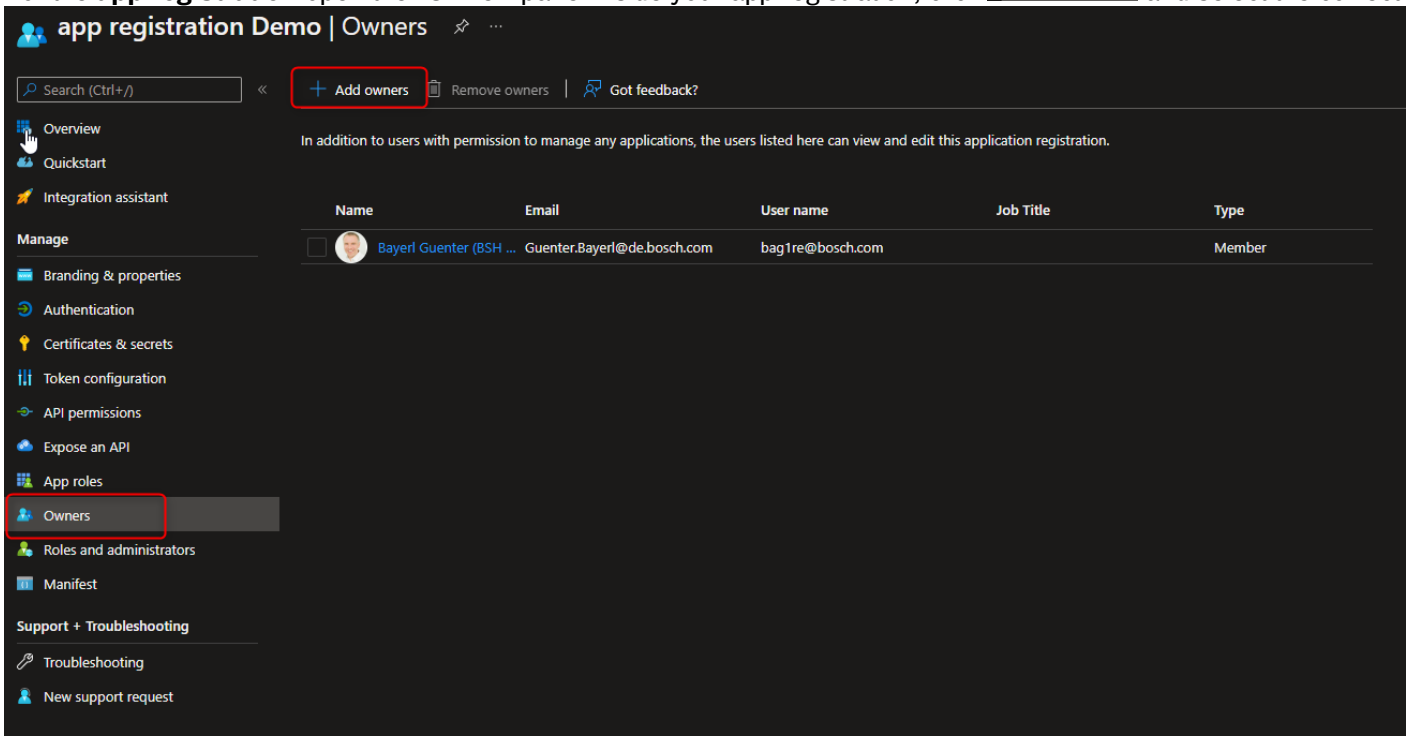
A detailed description of the platform types and as well to the other configurations described on this page you can find at the official Microsoft documentations:
https://docs.microsoft.com/en-us/azure/active-directory/develop/quickstart-register-app#configure-platform-settings
After this step your application is registered successfully in Entra ID and can be used to authenticate users for your application with OAUTH/OIDC.

3.5.1.3 Manage Owners of the application

While the initial app registration the current user will be added as the app registrations and enterprise applications owner and so is able to manage all application settings. For every app there is a must to have at least 2 valid owners configured.
An fast an easy option is to set this via the IAP-Portal: Applications - Overview.
But in case you will configure OIDC claims we recommend to set them manually in Entra ID:

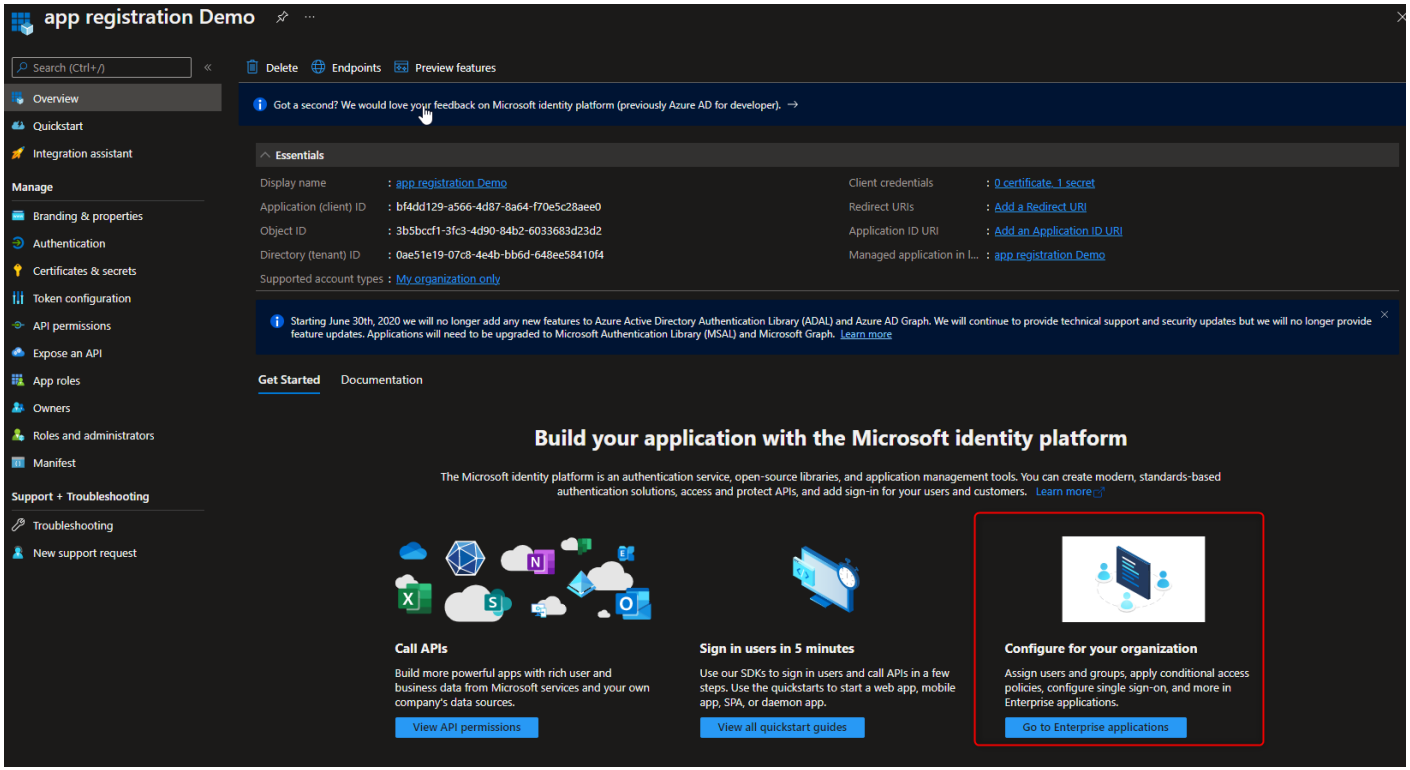
For the **app registration** open the "Owner" panel inside your app registration, click 

and select the correct owner.



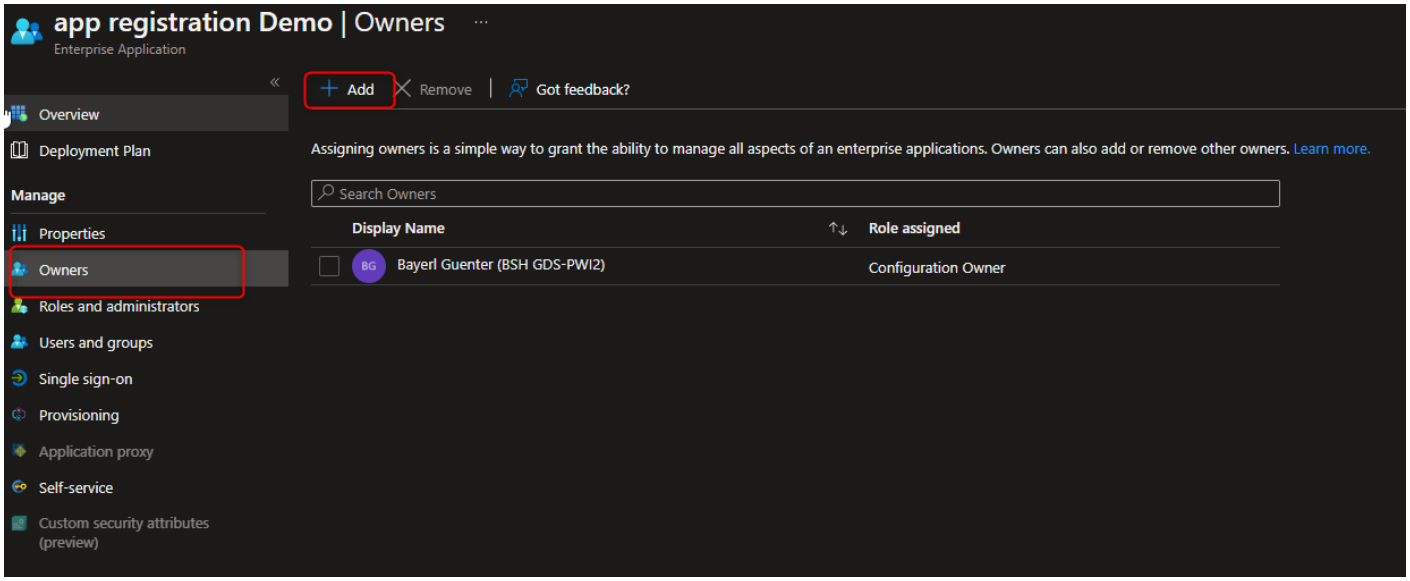
For the **enterprise application (service principal)** you can change this the same way. The easiest way to get to the enterprise application panel, you can go to the Overview of your app registration and click the button to switch to the enterprise application like you can see in below screenshot.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



In the enterprise app as well go to the Owner panel and add at least one additional owner (The account initially registered the app is also already owner of the enterprise application).

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Important information about owner assignment
Ensure the owners are always up to date. As an owner you have the possibility to configure and manage all kind of settings for the application - also the security relevant information like client secret. Therefor it is important to remove all users which doesn't need this permission.
As described above ensure that always at least two owners are in the configurations in case someone is able to maintain the configuration in case of absence or any other reason.

3.5.1.4 Additional Claims

Claims are Attributes that can be send in a token. An overview about claim configuration from Microsoft can be found here and offers to send UPN (joe1fe@bosch.com) or E-Mail. For **additional claims** there is a preview available, we are providing an instruction for this: Configure Claims in Token
It is possible to send a **group claim** but this is due to restrictions (max number of groups) not recommended. Please check out Groups and Authorization There are a lot of options for **Authorization over SSO** with roles / groups.
To **view your token** you can use the API Client Tool "Bruno" or inspect your token in our IAP Portal: Applications - Overview

3.5.1.5 Scopes

OIDC standard scopes and permissions
In Order to get Admin Consent Approval (Step 3) you have to do some adaptions in the API permissions tab: Add the standard OIDC-scopes (mandatory is openid) and remove the permissions for User.Read if possible.
More details are explained in our subpage OIDC Scopes and Permissions

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Access Tokens
Default Access Tokens in Entra ID are for Microsoft Graph API. You can recognize this checking the value of the claim "aud" ("00000003-0000-0000-c000-000000000000" or „https://graph.microsoft.com“).
An access token for your application has your clientid as value of the claim "aud" (Your application should always check this claim as part of token verfication). To get this access token you can add the **scope "<yourclientid>/.default"**. Additionally it is possible to set a different Application ID URI (Overview Tab) and define further custom scopes (Expose an API Tab).
More information from Microsoft about this can be found here.

3.5.1.6 Authentication Context and MFA

An authentication context defines a requirement that allows you to apply **granular policies** to sensitive data and actions at the app level based on your own logic. E.g. there are Options to enforce Multi-Factor-Authentication for certain roles to increase security. Documentation: Auth Context
For **general restrictions** (requesting MFA or restricting access to SAWs) have a look on our page for Multi Factor (MFA) with applications using modern Auth (SAML/OIDC)

3.5.1.7 Further information

Entra ID Endpoint for P4S permissions: If your application is hosted OnPrem the back-end server might require a **communication with the Entra ID.** How to request the required permission for this communication pattern over Bosch Proxy4Server (P4S)
If you want to use our **Test Entra ID** Environment (different Azure Tenant), then a login with your respective test account is required (e.g. <Q9-UserID>@test-bosch.com)

It is highly recommended to use **Entra ID v2 tokens**. Therefore use the respective endpoints and adapt the Manifest in the App Registration.

```
"requestedAccessTokenVersion": 2
```

Further information for token validation you can find here: OAuth2.0 / OpenID-Connect Token Validation - Directory Services - Docupedia

Links to Micrsoft Documentation
Find more information on the official Microsoft documentation:

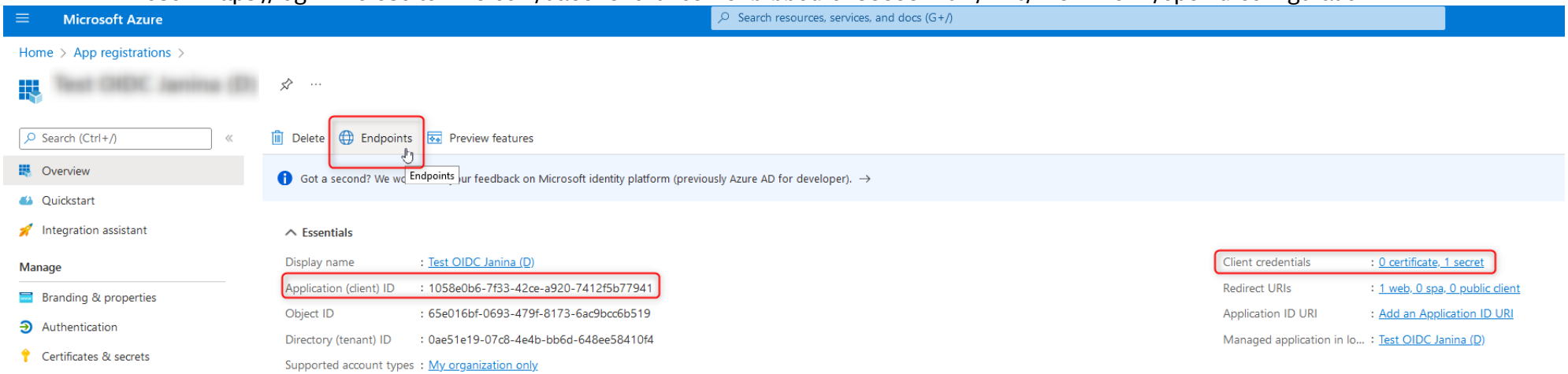
- Quickstart: Register and expose a web API - Microsoft identity platform
- Quickstart: Configure an app to access a web API - Microsoft identity platform
- Provide optional claims to your app
- Microsoft identity platform code samples

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.5.2 Step 2: Application Configuration

All Information for the Federation Configuration on Application side can be found in your App Registration in Azure Portal

- Additionally the **ClientID** and for confidential clients the **Client Secret** are required
- For OIDC all **endpoints** are included in the "Well known openID configuration file"
  - Bosch: https://login.microsoftonline.com/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/v2.0/.well-known/openid-configuration



3.5.3 Step 3: Admin Consent Approval

Initiate now the first authentication. Please be aware that the first time you need to request admin consent. Please fill out the dialog and send the request to the responsible team. This will take some time so please be patient and wait for the answer. You can also request it via an Pre-Approval workflow.
For more details about the process feel free to check our our Admin Consent Documentation, You can also check out the most common API declines here

3.5.4 Configure Claims in Token

It is possible to send Claims (Attributes) in a JWT-Token (ID and Access Token). A popular example would be to send the samAccountName / NTID (e.g. joe1fe) of a User. This page explains how to configure the Claims in the Azure portal.

If you want to configure group claims, we have a dedicated page explaining this in detail: Groups and Authorization

Related Microsoft Documentation: here

- How to configure
- Offered Claims
- View Token

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- Common Problems

3.5.4.1 How to configure

Prerequisite:

- You have to be an owner of the app registration and enterprise application. Otherwise, you wont be able to see the claim management experience
- Adapt your "Manifest" in the App registration: "acceptMappedClaims": true,

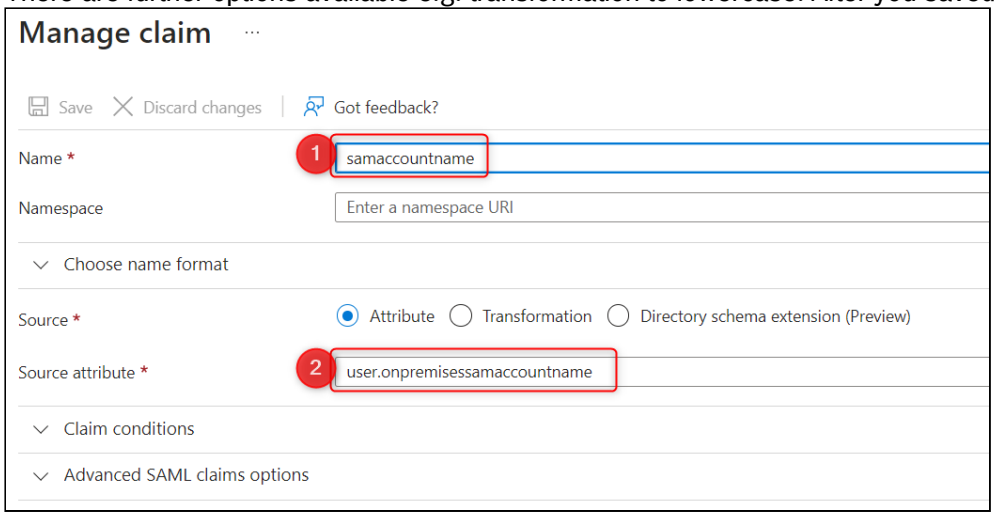
Go to the Enterprise Application of your application (e.g. over Overview > Managed application in local directory). In the Tab "Single-Sign-On" you find the Option to edit "Attributes and Claims"



There you can select "Add a new Claim" and configure your Claims.

1) Is the name of the Claim in the token. You can define this yourself
2) Is the fixed name of the attribute in Azure that you want to have

There are further options available e.g. transformation to lowercase. After you saved the configuration the new Claims will appear in your JWT-tokens.



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.5.4.2 Offered Claims

It is the same claims as offered for SAML tokens. A list can be found here: Bosch Attributes and Claims

3.5.4.3 View Token

To **view the attributes in your token** you can use the API Client Tool "Bruno" or inspect your token in our IAP Portal: Applications - Overview

3.5.4.4 Common Problems

Problem	Solution
Adding / modifying of custom claims in Enterprise Application not possible. "Edit" and "Save" button is greyed out	Owners of the Enterprise Application need to be re-added in Entra ID portal. Please do not remove your access completely so that at least two persons are set! If owners were not added in the Entra ID portal directly might run into this issue (due to a bug in the Microsoft UI in Entra- or Azure-portal, the removal and re-adding of owners is not working for assignments via MS Graph)
"error":"invalid_request","error_description":"AADSTS50146: This application is required to be configured with an application-specific signing key. It is either not configured with one, or the key has expired or is not yet valid	Older Azure Application Configurations might run into this issue. In this case you have to adapt your "Manifest" in the App registration: "acceptMappedClaims": true,
AADSTS501461: AcceptMappedClaims is only supported for a token audience matching the application GUID or an audience within the tenant's verified domains. Either change the resource identifier, or use an application-specific signing key.	You could change the identifierUris in the app's manifest to a verified domain like e.g. api://<AppID>.bosch.com
Claims are not part of the Access Token	Please check that this is the access token for your application. More background information can be found here: OIDC Configuration

3.5.5 Entra ID Endpoint for P4S permissions

If your application is hosted OnPrem and you plan to integrate a native Entra ID OIDC implementation, the **back-end server might require a communication with the Entra ID IdP** for all OIDC flows. As the Entra ID IdP is hosted as an IaaS model on public Internet powered by Microsoft Azure platform, the token endpoints are public Internet endpoints. Thus, the OnPrem application server must be able to reach those Internet hosted endpoints: For server communication, you need to request **Bosch Proxy4Server (P4S)** access and actually configure the proxy service on the back-end server that needs to reach the Entra ID endpoints.

3.5.5.1 Proxy4Server (P4S) Access

Your server needs to access to Proxy for Server itself. Therefore a **Firewall rule must be requested** (Template: https://cls.seccom.bosch.com/warp/iptt/14/)
Further information about P4S service offerings and processes can be found here: https://inside-docupedia.bosch.com/confluence/x/5wj0Hg

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The relevant **endpoints (like login.microsoftonline.com) are allowed by default on Proxy4Server.** There is no specific rule on Proxy4Server required.
(See Free-4-All Policy - Network Security Policy Management - Docupedia)

3.5.5.2 Further information

In the past the rules on Proxy4Server were not default and needed to be requested depending on the usecase. For more technical background information you can have a look on our old documentation:
Click here

3.5.5.3 Standard Case: Back-end server communication from restricted network zones

If your application is hosted OnPrem and you plan to integrate a native Entra ID OIDC implementation, the **back-end server might require a communication with the Entra ID IdP** depending on the implemented OIDC flow. We do share the following information to provide guidance how to request the required permission for this communication pattern. This is mainly required for Authorization Code Flow as well as if you plan to validate issued tokens by the back-end service.
As the Entra ID IdP is hosted as an IaaS model on public Internet powered by Microsoft Azure platform, the token endpoints are public Internet endpoints. Thus, the OnPrem application server must be able to reach those Internet hosted endpoints. For server communication, one need to apply for the **Bosch Proxy4Server (P4S)** configuration and actually configure the proxy service on the back-end server that needs to reach the Entra ID endpoints. Please make sure that your back-end service can establish a communication via proxy settings and apply for the below mentioned URL as a new request or add the URL to an existing P4S rule.

Endpoints to apply for on Proxy4Server (back-end server communication)
As all Entra ID OIDCv2 endpoints are hosted by the login.microsoftonline.com, it is sufficient to apply the P4S rule for the destination host (internet host) as a P4S host rule.

```
login.microsoftonline.com
```

CRL Endpoints (optional)
If the back-end service also performs CRL check of the login.microsoftonline.com endpoint (SSL), please also apply for the CRL URLs accordingly. This is only needed in very few cases. These URLs are not listed here as they could change based on Microsoft hosting architecture. Thus, please look up the current CRL URLs (e.g. by opening the SSL-certificate in the browser) and add it as an additional P4S rule.

3.5.5.4 Special Case: Interactive sign-in / user access from restricted network zones

In case you want to access EntraID integrated applications from **client/ end device** hosted in a restricted network zone (e.g. from a dedicated jumphost or from a mobile app on devices connected to a restricted network zone) based on an **interactive sign-in**, access to the EntraID endpoint are as well required. Depending on the restricted zone access and defined framework the EntraID sign-in can be achieved as follows:

- If end devices are allowed to access the standard Bosch proxy for establishing Internet access: One just needs to apply for the standard Bosch proxy firewall access and ensure to set the standard Bosch proxy network configuration on the end devices. No further actions required once the end devices can establish a communication to the standard proxy infrastructure.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- If end devices are not allowed to use the standard proxy for establishing Internet access, but must use Bosch Proxy4Server: One can leverage Bosch Proxy4Server infrastructure by applying for the firewall rule from the end device network range to the Bosch Proxy4Server (https://cls.seccom.bosch.com/warp/iptt/14/), set the P4S proxy configuration on the end devices as well as apply for the following endpoints in P4S rules:

```
login.microsoftonline.com
login.microsoft.com
aadcdn.msauth.net
aadcdn.msauthimages.net
aadcdn.msftauth.net
aadcdn.msftauthimages.net


stfs.bosch.com -> already available as default
```

Optional
In case the back-end system must reach further APIs like the Microsoft Graph API to access M365 interfaces, please ensure that you apply for those API URLs as well depending on your use case.

3.5.6 Exception: OIDC with RB-Admin

ADFS

All Information for the **Federation Configuration for OIDC on ADFS@RB-Admin (Identity Provider) side** can be found here. We offer a plattform where you can create and change your OIDC settings yourself.

How to find the Plattform?
Choose in the Table below your Identity Provider and use the respective link.

ADFS	Link	Description

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

ADFS@RB-Admin	https://rb-ada.rb-admin.bosch-org.com/	Special ADFS. Authentication for RB-Admin-Users

Hint: You have to log in with a user from the same Active Directory

- Create Application (Identity Provider side)
- Configure Application (Identity Provider side)
  - Owners
  - Reply URLs
  - Claim Assignments
  - Secrets
  - Scope Grant Management
  - Deletion

3.5.6.1 Create Application (Identity Provider side)

Under "ADFS > OAuth2 Applications" you can click the "CREATE" button in order to create a new Application Instance on ADFS side.

No	Property	Description	Modifiable later
1	Name	The name of the application. This property has no technical functionality and only exists for documentational purposes. It cannot be empty or exceed 120 characters.	✓
2	Instance	Whether this application represents a productive or a develop/quality application.	✗
3	Type	**This is a very important decision! If your application supports it please create a confidential client.** Whether the application is a public (Implicit Flow, Code Authorization Flow with PKCE) or a confidential client (Code Authorization Flow, Client Credential Flow). See here for an explanation. If you select 'Confidential Client', you will receive a client secret once after the application has been created.	✗
4	Additional Owner	The additional owner of the application, because all applications have to have at least 2 users as owners assigned. You can search for a user by NT user, first name, last name or email address. You will be added as an owner automatically. You can add and remove more owners later, even groups.	✓

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

No	Property	Description	Modifiable later
5	Cloud Onboarding WorkOn Number (Optional)	The Cloud Onboarding WorkOn Number. Only required for Cloud Applications.	✗
6	Terms and conditions accepted	Has to be accepted. The terms and conditions can be accessed here.	✗
7	Subscribed to SPoI	Has to be accepted. For all kind of maintenance, certificate changes or planned downtimes we will inform our customers through the offical process SPoI. The SPoI can be subscribed here.	✗

3.5.6.2 Configure Application (Identity Provider side)

3.5.6.2.1 Owners

An owner of an ADFS OAuth2 application serves 2 purposes:

- Contact person for ADFS administrators
- Full access to the configuration of the application in IAP (adding more owners, editing claims, ...)

You can add or delete owners, but at least 2 user as owners are required. Search for the Users by Lastname + First Name (Doe John) or NT-ID (e.g. joe1fe).
Since 19.07.2021, you have to option to add groups as owners. You can add and remove as many groups as you like, but at least 2 users must still be assigned as owners.
Be aware that you can only assign groups that are synced to Azure. You can check in the Azure Portal whether a group is synced or not by searching for it. If you require a groups to be synced to Azure, drop a mail to CI/PWI2-Azure-Application-Administration containing the group domain + name.

3.5.6.2.2 Reply URLs

Reply URLs are the endpoints on Service Provider / Application side where the token will be send to. For a more detailed definition of Reply URLs, see here.
You can add as many Reply URLs as you like. The following restrictions apply to all Reply URLs configured in IAP:

- A Reply URL has to be a well-formed absolute URI
- A Reply URL cannot start with `http://` (except for `http://localhost`)
- A Reply URL cannot exceed 1024 characters
- A Reply URL cannot contain `?`, `#`, `*` or `,`

You should not use `http://locahost` in your productive system.

3.5.6.2.3 Claim Assignments

In this section you can define addtional claims or information we should issue with the token to the application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

No	Description
1	Name is the Claim Name / Attribute Name in the token
2	We offer a transformation of the values "TO UPPER" and "tolower". This is important if the application expects case sensitive claim values.
3	We offer 3 different Types: Input Claim, Group Claim and Static Claim. They are described in detail below

Input Claim (LDAP Attribute)

An Input Claim is an attribute of the signed in user and can provide the application with some information (LDAP Attribute) about who the token belongs to. For example, the Input Claim 'samAccountName' represents the NT-User or logon name of the signed in user (e.g. XYZ2FE). Overview of all Attributes:

Claim name	Description	Example
Claims configured by default		
SamAccountName	NT User ID of the user	doj1fe
UserPrincipalName	unique value for the user including NT-ID and the domain in email format	doj1fe@bosch.com
Domain	Domain of the User (emea, de, us, apac, br)	de.bosch.com
Further Claims (A-Z)		
City	Location	Stuttgart-Feuerbach
co	Country name	Germany
c	Country Code	DE

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Claim name	Description	Example
Company	Company name	Robert Bosch Gmbh
Department	Department abbreviation	CI/ISI2
DisplayName	Name as shown in eg Outlook	Doe John (CI/ISI2)
EmailAddress	Email Address(es)	john.doe@de.bosch.com
GivenName	Firstname of the user	John
MobilePhone	Mobile phone number of the user	+49(172) 123 456 78
Office	Room and building number	FE 701/2 J1.01
sn	Last name of the user	Doe
State	State of the User	Baden-Wuerttemberg
StreetAddress	Street of office location	Borsigstrasse 4
telephoneNumber	the office telephone number of the user	+49(711)811-1234
Title	title of the user	Dr.

Group Claim
It is possible to send Active Directory group memberships of a user as a claim in the token. An Application can process this claim and use it for a role concept within the Application.
With "Issue as Sid" the group name in the token will be not the name of the group but it's SID (a unique ID).
You can apply a filter (in Regex) to limit the list to groups that are relevant to your application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Example:

Name	Filter
roles	Idm2bcd_MyApplication_

Result:
An access token that contains all groups that start with 'Idm2bcd_MyApplication_' where the signed in user is a member of in a claim called 'role'.

More information about possible group types can be found here.

Static Claim
A Static Claim is a static value that will be same for all users in all tokens issued for this applications. It is a fixed Key-Value Pair.
Example:

Name	Value
ApplicationInstance	Development

3.5.6.2.4 Secrets

> This section only applies to confidential clients, because public clients have no secret. A public Client cannot be converted after the applicationhas been created. To see whether your application is a confidential client, scroll down to the bottom of the application configuration page and look for the 'Type' of the application.

At the top right of the application page, there is a button called 'RESET SECRET'. You can click this button to generate a new secret, if you have lost your current secret or just you want to rotate it. You will then be prompted to confirm the action.

> Be aware that this action cannot be undone.

The new secret will then be presented at the top of the application page. The old secret will stay valid for 2 days, so that you have time to update it in your application(s). We doe not store any secrets, so after you moved away from this page or clicked refresh, you will never be able to see the secret again.
Please take a look at the EISA to check how often you have to rotate your secret. Currently (13.07.2021) you have to rotate it every 180 days, except you fulfill the requirements of EISA-ACC-301.9 - then it is every 2 years.

3.5.6.2.5 Scope Grant Management

An ADFS Application created in the ADFS Self-Service consists of 2 parts: A client (Public/Confidential) & a Web-API. This setup enables you to sign in users using the client and get a token issued for the corresponding Web-API with the same Id as the client. The resulting access token will contain the the Id of the Web-API in

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

the Audience Claim, which has to be used by it to verify that the access token is really intended for the specific Web-API (See reserved claims). By default, you cannot sign in users for any other Web-API registered in the ADFS.
The Scope Grant Management enables you to granularly define which ADFS Applications are able to access your Web-API with specific scopes. When **granting access for another Application**, you can select one or more of these optional Scopes: Read.All, ReadWrite.All or user_impersonation. The Scopes *openid, profile, email, allatclaims* will be automatically added for all Grants.
You can only grant access for other applications to applications you own. If you want to access an applications that is owned by another person/department, you have to ask the owner of that application to register your application by providing your application id to them.
A registered grant can be revoked by the Owners of both applications. Be aware that you cannot undo this action and you may have to ask the owner of the application you want to have access to to register it again.

3.5.6.2.6 Deletion

You can find the Delete Buttopn at the top right of the application configuration page. If you click this button you will be prompted to confirm the deletion.
After confirming the deletion, the application will be removed instantly and you won't be able to sign into it anymore

Caution

This Action cannot be undone. A deleted application cannot be restored!

3.5.7 OIDC Scopes and Permissions

Here you can find more details about Scopes and API permissions for OIDC Applications.

3.5.7.1 OIDC Standard Scopes

OIDC SSO integration is based on scopes that are introduced in the OAuth 2.0 RFC 6749 and the OIDC scopes are used by an application during authentication to identify the person and receive further profile information of the signed-in user. These OIDC scopes are defined based on an industry standard as follows:

- openid (mandatory)
- email (optional, provide the users primary email address)
- profile (optional, profile information last surname, given name etc)

For the sole SSO purpose, please use these three scopes in the authentication request to obtain the ID token that identifies the signed-in user and provides further user profile information. Please do not rely on the Microsoft Graph scope "User.Read" for SSO integration purposes. The SSO integration must be established using the OIDC standard.

3.5.7.2 OIDC Authentication Request

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The above introduced OIDC scopes must be part of the authentication request of the application / service that you are either coding or using from a vendor. Depending on the OIDC flow architecture - which you can refer to https://inside-docupedia.bosch.com/confluence/x/ml1KWg - and coding language, the integration may vary but we take the following **example** to highlight the correct scope configuration:

https://login.microsoftonline.com/{tenant}/oauth2/v2.0/authorize?client_id={client-ID}
&response_type=code
&redirect_uri=http%3A%2F%2Flocalhost%2Fmyapp%2F
&response_mode=query
&scope=openid+email+profile
&state=12345
&code_challenge=YTFjNjI1OWYzMzA3MTI4ZDY2Njg5M2RkNmVjNDE5YmEyZGRhOGYyM2IzNjdmZWFhMTQ1ODg3NDcxY2Nl
&code_challenge_method=S256

As you can see - it will be sufficient to add the standard OIDC claims as the scope parameter of the authorization request to Entra ID to correctly implement SSO.

3.5.7.3 OIDC Consent and API permissions

Using the OIDC scopes requires an initial admin consent which is required on the first integration / request to use SSO and obtain user information (Step 3). This is a one-time activity once you request a scope the first time. Once granted, no further consent requests are required on the next sign-in requests. The consent approval can be triggered via two processes - you only need to use **one** of the presented options:

1. **Built-in Microsoft consent workflow**: https://inside-docupedia.bosch.com/confluence/x/Fo68RQ

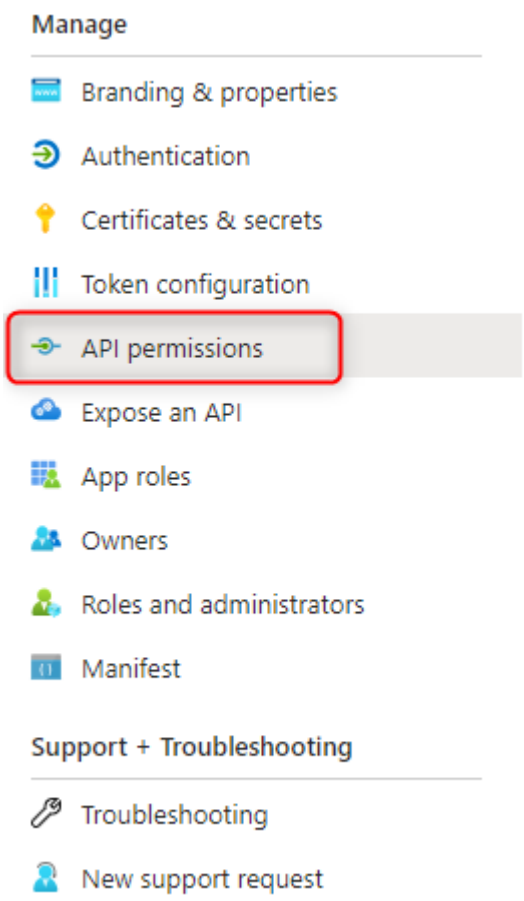
   In this case, all you need to do is adding the OIDC scopes (openid+email+profile) to your authentication request as the scope parameter as outlined above. If these scopes have not been granted beforehand, the outlined built-in workflow will start. Please provide the justification (e.g. implement Bosch SSO in your app) and send the request. Once it gets granted, you will be notified and can use SSO. If you use the built-in consent workflow, you do not need to follow up on the second pre-approval option and outlined tasks below.

2. **Pre-Approval consent workflow**: https://inside-docupedia.bosch.com/confluence/x/ZSUuf

   In case you cannot trigger the built-in workflow or do want to obtain the consent before you ask your customer to sign-in to the application, you can configure the OIDC scopes for SSO upfront in your app. To do so, please go to the Entra ID app registration blade and select the "API permission"

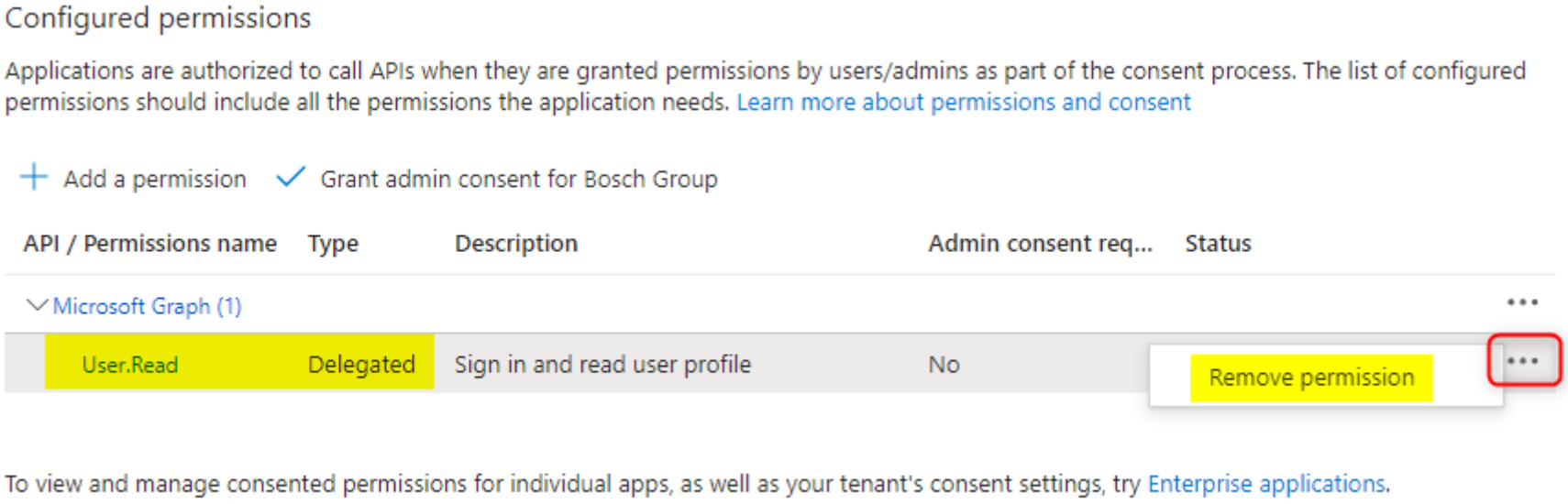
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

area:



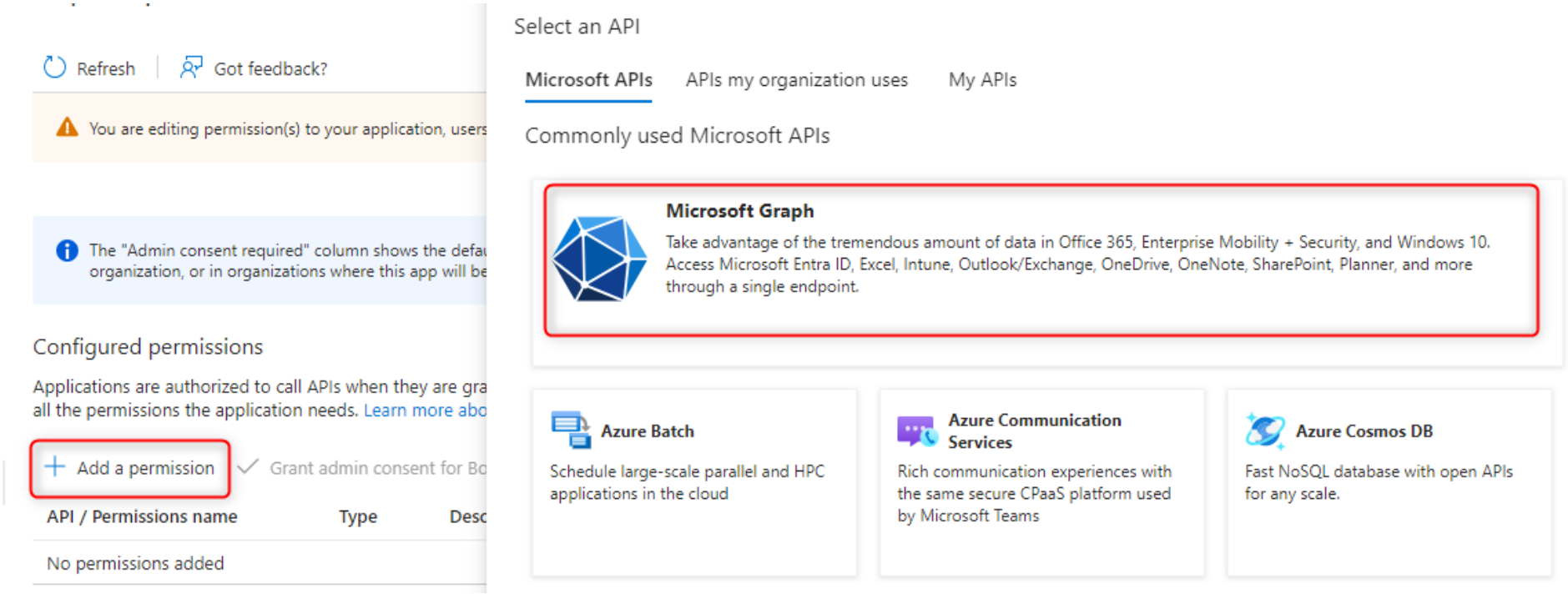
By default the Microsoft Graph API permission of "User.Read" is set on each application. Though this Microsoft proprietary scope can be used to sign-in as well, we do not follow this approach as it neither fulfills SSO industry standard integration nor meets the Bosch IT governance requirements to apply Identity protection mechanisms on the sign-in process. Thus, if you are solely looking into SSO, **please remove the default defined "User.Read" permission** as follows: *(in case you need "User.Read" in addition to the SSO integration you can keep it but you must ensure to always use the standard OIDC claims for your application SSO sign-in)*

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



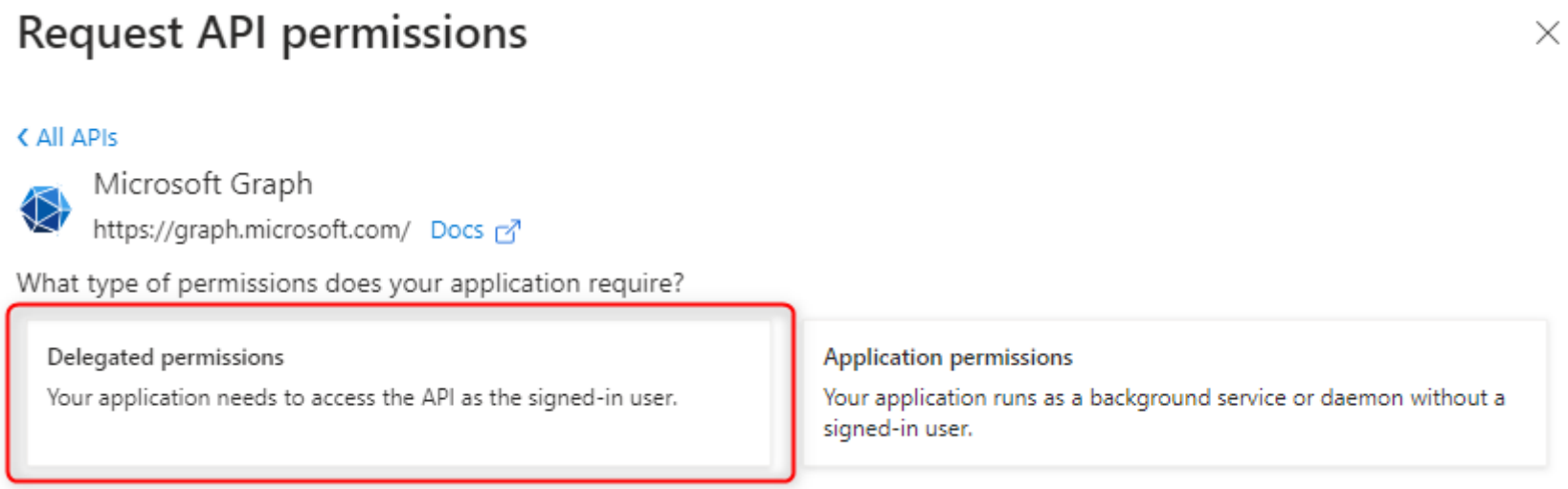
To add the OIDC standard scopes, please select "Add a permission" and confirm the "Microsoft Graph" platform:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



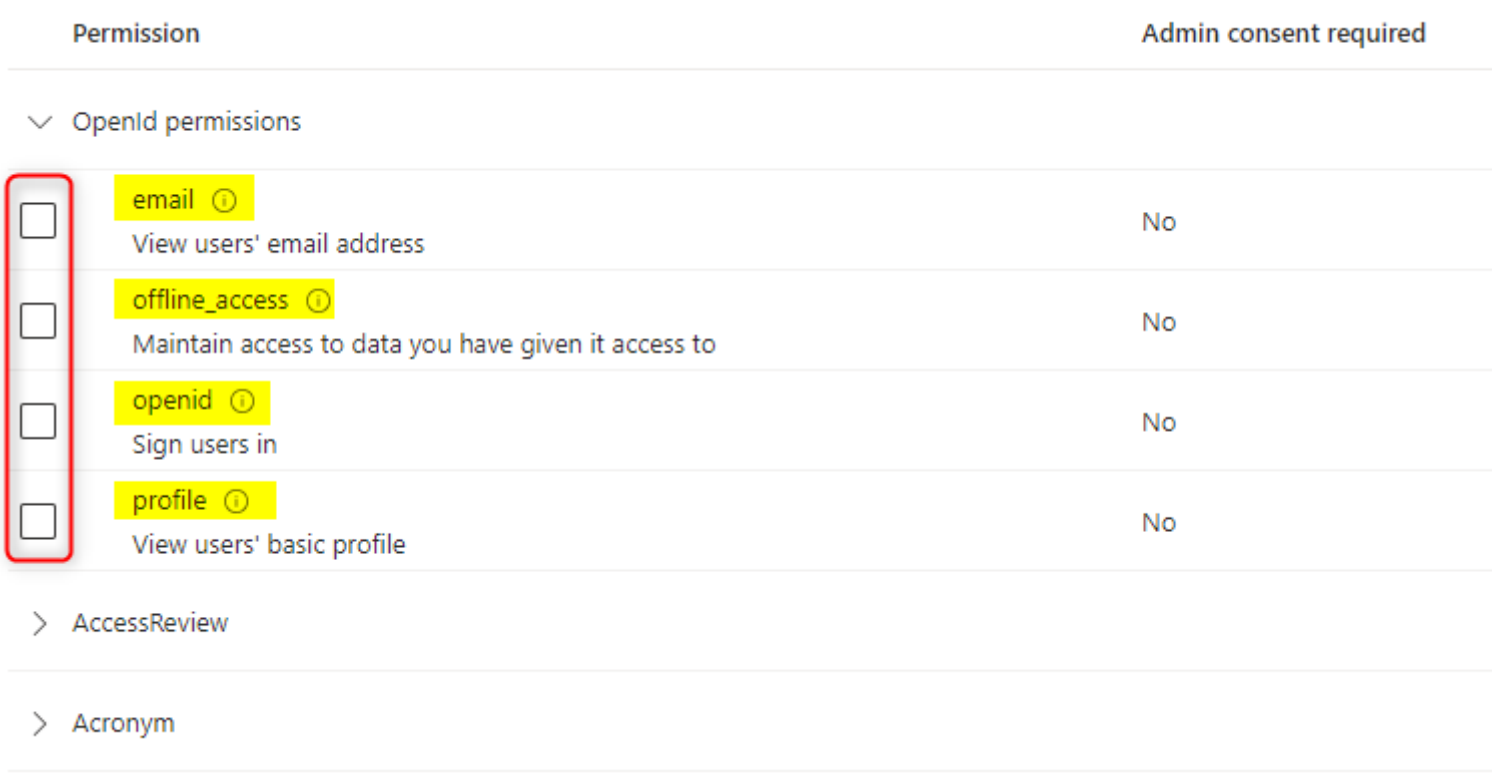
As the SSO sign-in is an interactive flow, please proceed with delegated permissions:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



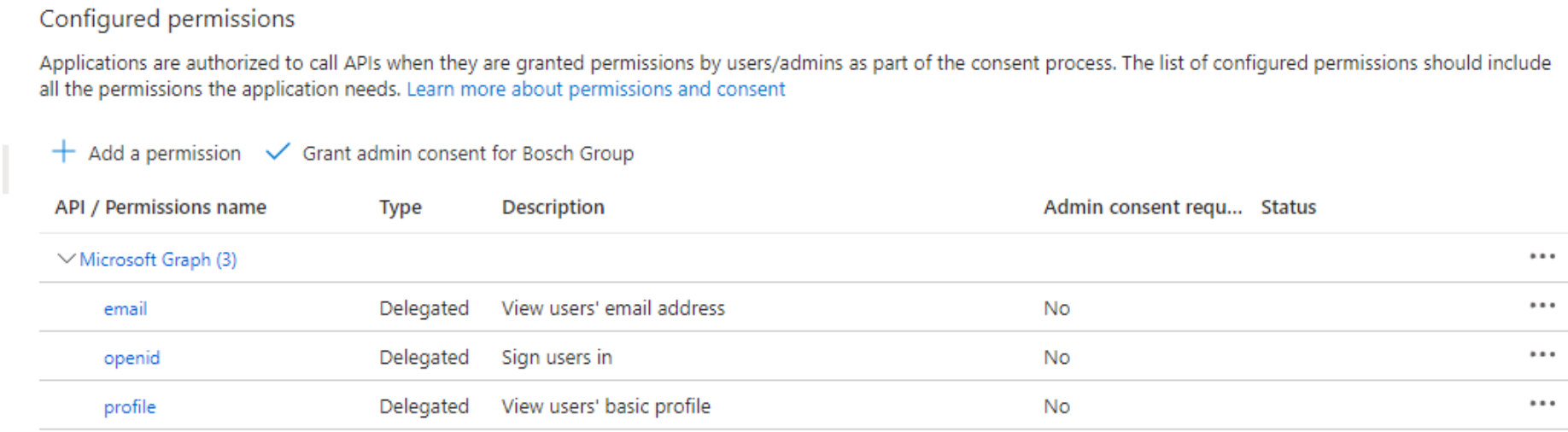
The OIDC SSO scopes will be presented to you as the very first scope options - please mark the check boxes of the OIDC scopes you want to use. At least "openid" is mandatory to complete a SSO integration but you can add the other scopes in addition if you require further information like the primary email address of additional profile information. By requesting profile information, please be aware that your application must be compliant with data regulation requirements (e.g. GDPR) as by receiving user profile information your app processes personal user data. Thus, please only use this scope if the personal user data processing has been clarified for your application. The "offline_access" scope is only relevant and required if you intend to use refresh tokens:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Please continue with "Add permission" at the bottom of the dialog. Now, all selected scopes should be added to the API permission blade e.g.:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



This is the intended state of API permissions for the OIDC Bosch SSO integration - please keep in mind the personal data processing requirements if the "profile" scope is selected. As the next step, you can go ahead and request the consent of the newly added scopes via T&R Service Desk as outlined in the above mentioned link for the pre-approval process (https://inside-docupedia.bosch.com/confluence/x/ZSUuf).

Return to general instruction for OIDC Configuration here

3.6 Terms and Conditions

Version 1.2 - 06.11.2023

> By using the Service you agree to be bound by these Terms. If you disagree with any part of the terms then you may not use the Service.

3.6.1 General

We offer Single Sign On functionality for applications (on premesis, cloud hosted, SaaS) or publish internet facing applications in a secure way for Enterprise IT use cases. The authentication is based on SAML or OpenID connect.
The user will be authenticated against the on premise Active Directory. Our service will provide a token (XML or JWT) with the authenticated user and other information (claims) to the application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.6.2 Assurances

While developing and integrating new applications to the Bosch IT infrastructure you are ensuring to meet the security and legal requirements of all Bosch regulations. Depending on the architecture and other criterias the respective boards (e.g. DSO or Cloud Onboarding) need to be contacted for approval. There is no additionally approval for the SSO connection needed.

3.6.3 Preconditions

There are several preconditions which must be fullfilled to be able to use Entra ID (former Azure AD) as the Identiy Provider

- Application is a web based application and HTTPS has to be used
- Identities must be available locally in the application
- Users which access the application need to have an user account in one of our connected Active Directories - depending which environment you have choosen (see above)
- Users can access applications from the Internet (only cloud applications and applications, published to the Internet via our IdP)
    - A seperate authentication on our Identity Provider system is needed
    - User has to authenticate additional with MFA (Multifactor Authentication). Enrollment process can be found here

3.6.4 Out of our Service Scope

- Configurations on Service Provider / Application side
    - Managing the identities inside the application. This topic has to be handled separate.
      You can find information about how to handle on the Bosch IDM sites or contact via Mailbox.IdMIntegration@bosch.com
    - Regarding SCIM interface, you can as well have a look to https://rb-oneidm-help.bosch.com/en/data/scim.html
    - Application role management
    - Configuration of the federation trust and Development

3.6.5 Customer repsonsibility

- You as the customer are responsible to inform us in case the ownership or contact person changes. The correct process is to request the change via SMT ticket to Directory Services / FEDERATION SERVICE INFRASTRUCTURE OPERATION
  (In case we have no valid contact anymore, we are not able to inform you e.g. about expiring token signing certificates which could lead into an application outage)
- In case a Token Request Signing certificate or a payload encryption certificate is required, you as the customer are responsible to...
    - provide the correct public key during the onboarding process.
    - monitor the validity and expiration of the certificates.
    - inform us about expiration of any of the certificates and organize an appointment to replace with a new valid certificate.
    - ensure the certificates follow all Bosch security and legal requirements.

3.6.6 Additional rules for SAML self-service

With the hand over of ownership of the SAML EntraID configuration to the customer, you agree to following rules and conditions:

- It is not allowed to change of Single Sign-On mode in the Enterprise application configuration
- It is not allowed to change the Reply URL / Assertion consumer Service (ACS) URL directly in EntraID, but in the IAP Dashboard

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- It is not allowed to activate SCIM (Provisioning) in the Enterprise application configuration for authentication. SCIM must be separated from the authentication and requested with the IDM team
- The application owner is responsible to ensure all securtiy guidelines as e.g. the EISA are fulfilled. For example the certificate lifetime is regulated in the EISA.

More details regarding the points you can find on the onboarding documentation pages here: https://inside-docupedia.bosch.com/confluence/x/vvfWTAE

3.6.7 Terms and Conditions V1.1 - OUTDATED

Version 1.1 - 11.02.2022

> By using the Service you agree to be bound by these Terms. If you disagree with any part of the terms then you may not use the Service.

General
We offer Single Sign On functionality for applications (on premesis, cloud hosted, SaaS) or publish internet facing applications in a secure way for Enterprise IT use cases. The authentication is based on SAML or OpenID connect.
The user will be authenticated against the on premise Active Directory. Our service will provide a token (XML or JWT) with the authenticated user and other information (claims) to the application.

Assurances
While developing and integrating new applications to the Bosch IT infrastructure you are ensuring to meet the security and legal requirements of all Bosch regulations. Depending on the architecture and other criterias the respective boards (e.g. DSO or Cloud Onboarding) need to be contacted for approval. There is no additionally approval for the SSO connection needed.

Preconditions
There are several preconditions which must be fullfilled to be able to use ADFS or Azure AD as the Identiy Provider

- Application is a web based application and HTTPS has to be used
- Identities must be available locally in the application (user id must match the unique Identifier of the token)
- Users which access the application have got an user account in one of our connected Active Directories - depending which environment you have choosen (see above)
- Users can access applications from the Internet (only cloud applications and applications, published to the Internet via our IdP)
    - A seperate authentication on our Identity Provider system is needed
    - User has to authenticate additional with MFA (Multifactor Authentication). Enrollment process can be found here

Out of our Service Scope

- Configurations on Service Provider / Application side

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- Managing the identities inside the application. This topic has to be handled separate.
  You can find information about how to handle on the Bosch IDM docupedia sites.
- Application role management
- Configuration of the federation trust and Development

3.6.8 Terms and Conditions V 1.0 - OUTDATED

Version 1.0 - 09.03.2021

By using the Service you agree to be bound by these Terms. If you disagree with any part of the terms then you may not use the Service.

General
We offer Single Sign On functionality for applications (on premesis, cloud hosted, SaaS) or publish internet facing applications in a secure way for Enterprise IT use cases. The authentication is based on SAML or OpenID connect.
The user will be authenticated against the on premise Active Directory. Our service will provide a token (XML or JWT) with the authenticated user and other information (claims) to the application.

Assurances
While developing and integrating new applications to the Bosch IT infrastructure you are ensuring to meet the security and legal requirements of all Bosch regulations. Depending on the architecture and other criterias the respective boards (e.g. DSO or Cloud Onboarding) need to be contacted for approval. There is no additionally approval for the SSO connection needed.

Preconditions
There are several preconditions which must be fullfilled to be able to use ADFS as the Identiy Provider

- Application is a web based application and HTTPS has to be used
- Identities must be available locally in the application (user id must match the unique Identifier of the token)
- Users which access the application have got an user account in one of our connected Active Directories - depending which environment you have choosen (see above)
- Users can access applications from the Internet (only cloud applications and applications, published to the Internet via our IdP)
  - A seperate authentication on our Identity Provider system is needed
  - User has to authenticate additional with MFA (Multifactor Authentication). Enrollment process can be found here

Out of our Service Scope

- Configurations on Service Provider / Application side

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- Managing the identities inside the application. This topic has to be handled separate.
  You can find information about how to handle on the Bosch IDM docupedia sites.
- Application role management
- Configuration of the federation trust and Development

3.7 Application Development

3.7.1 If you are developing a new application and need support with integrating SSO we have some tips for you:

Protocol: We recommend to use OIDC

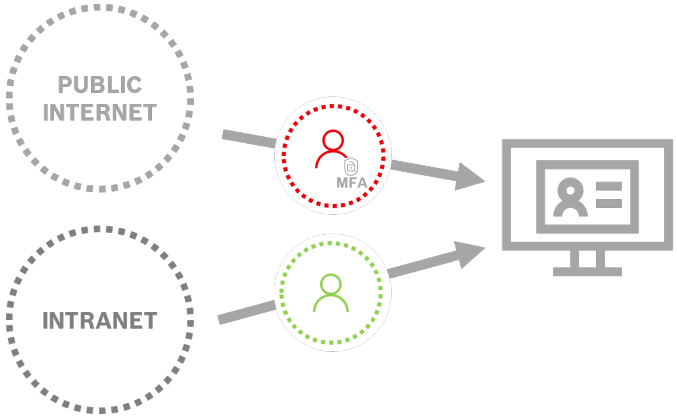
Library: We recommend you to use the MSAL library from Microsoft

Addtioanlly, we have a dedicated guide for Token Validation. All these validation steps are automatically included, when you are implementing MSAL libraries.

3.8 Multi Factor (MFA) with applications using modern Auth (SAML/OIDC)

Multi Factor Authentication (MFA) is used to secure the identity of Bosch users for example while logging in to applications using modern authentication (SAML and OIDC).
Further organizational and technical details regarding Microsoft MFA service at Bosch, the enrollment process for internals and externals and other information you can find
on the docupedia site of the MFA service responsible group at https://inside-docupedia.bosch.com/confluence/x/g7QzR.
For the onboarding we offer two different configuration types:

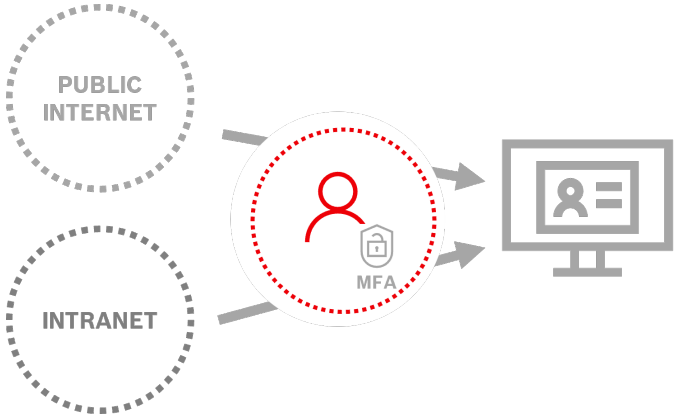
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Default MFA setting - Need MFA from **extranet** (public internet) access only

With the default setting, you can authenticate via SAML or OIDC without MFA requirement when accessing the application from a Bosch internal local network (**intranet**). This includes as well clients, which are connected via Cisco Anytime VPN to the internal network like e.g. while working from home.

While accessing the application from **extranet** (public internet), MFA is required when doing the authentication.



Optional MFA setting - Need MFA from **intranet** and **extranet** (public internet) access

- MFA everytime
- MFA every 5 hours

This use case can be ordered via the Service Desk Form:

Entra ID App Security Settings

For applications with the requirement to a higher security level we offer to enable MFA authentication as well when accessing the application from the intranet in addition. There are two options:

For Administration at Bosch we have the SAW (Secure Admin Workstation) - a dedicated hardened Client. The access to applications can be enforced to SAWs only:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Optional SAW setting - Need **SAW** (intranet) access only

For applications with the requirement to a higher security level we offer to enable SAW access only, which will only be possible from the intranet (SAW VPN Gateway):

- require SAW

This use case can be ordered via the Service Desk Form:

Entra ID App Security Settings

3.9 Bosch Attributes and Claims

This is an Overview of Claims that can be configured in Enterprise Applications in the Azure Portal (Entra ID). A claim is a piece of information about a user that is sent from the identity provider (Entra ID) to the service provider (your application) in the token. Claims can include details such as the user's name, email address, roles, or other attributes.

Claims Overview

Source Attribute in Entra ID	Attribute name in AD	Description	Example
user.onpremisessamaccountname	SamAccountName	NT User ID of the user	doj1fe
user.userprincipalname	UserPrincipalName	unique value for the user including NT-ID and the domain in email format	doj1fe@bosch.com
user.givenname	GivenName	Firstname of the user	John
user.surname	Sn	Last name of the user	Doe

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Source Attribute in Entra ID	Attribute name in AD	Description	Example
user.mail	mail	Email Address(es)	john.doe@de.bosch.com
user.department	Department	Department abbreviation	CI/ISI2
user.displayname	DisplayName	Name as shown in eg Outlook	Doe John (CI/ISI2)
user.telephonenumber	telephoneNumber	the office telephone number of the user	+49(711)811-1234
user.streetaddress	StreetAddress	Street of office location	Borsigstrasse 4
user.city	City	Location	Stuttgart-Feuerbach
user.state	State	State of the User	Baden-Wuerttemberg
user.country	Country	Country Code	DE
user.comanyname	Company	Company name	Robert Bosch GmbH
user.physicaldeliveryofficename	Office	Room and building number	FE 701/2 J1.01

3.10 Groups and Authorization

SAML and OIDC are designed for Authentication of users. But with a SSO-configuration there also a lot of possiblilities for authorization and role concepts.

For this it is important to use AD groups. We are offering two different compliant group types: ITSP and IDM2BCD

Please make sure that you follow the right steps depending if you have a **SAML** or **OIDC** configuration!

Overview

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

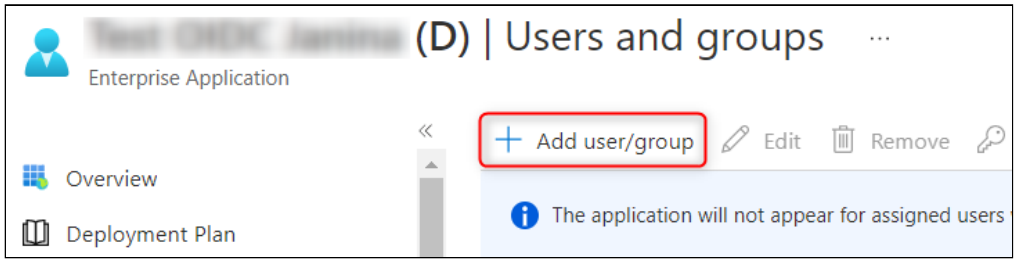
- Restrictions for nested Groups
- Usecase 1a: Restrict Access to Specific Groups
- Usecase 1b: Send Assigned Groups in Token
- Usecase 2: Send Roles in Token
- Usecase 3: Send Filtered Groups in Token
- Usecase 4: Grant Application Permission to another App
- Usecase 5: SCIM Provisioning
- Common Problems

3.10.1 Restrictions for nested Groups

Affects Usecase 1 and 2: For group assignment there is the restriction that groups nested within the directly assigned group won't have access. (Microsoft Documentation) . If you want to use nested groups (e.g. WOM-Groups) for your application Usecase 3 could be the solution. When an app is configured to receive group membership claims in the token, all nested groups in which the signed-in user is a member are included.

3.10.2 Usecase 1a: Restrict Access to Specific Groups

With this option you can restrict the access to your application directly in Azure. Only members of the assigned groups will get a token.

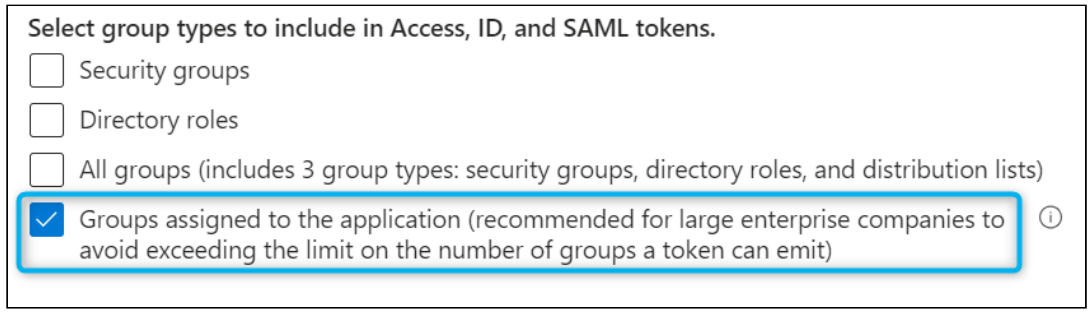
	Official Microsoft Documentation: here
1	Go to your Enterprise Application in Azure Portal *OIDC-Tip: To find the related Enterprise Application go to the Overview-Tab of the App Registration and follow the link of "Managed application in local directory" or search for the Application Name in "Enterprise Application" Service directly*
2	Assign the respective groups in the "Users and Groups" section of your Enterprise Application.  *Tip: If you want to assign many groups, you could upload them as well via Script as explained in our documentation*

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

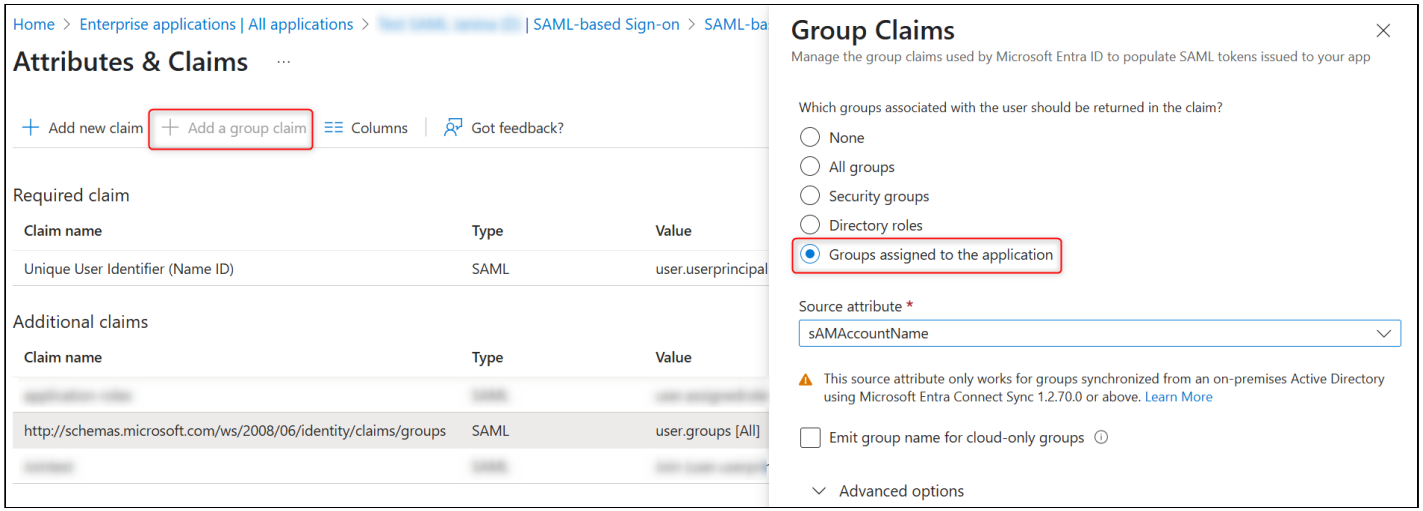
	Official Microsoft Documentation: here
3	Set "Assignment required?" to Yes in the "Properties" section of your Enterprise Application 

3.10.3 Usecase 1b: Send Assigned Groups in Token

With this option you can assign groups to the application and send only them in the token. This option can be combined with 1a (recommended)

	Offical Microsoft Documentation: here
1	Assign groups to your Application (see Step 1+2 from 1a)
2 - **OIDC**	Go back to your App Registration and go to "Token configuration" and click "Add groups claim". Select the option "Groups assigned to application"  *Tip: In case the option is not available, delete the currently existing group configuration in Token configuration*

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

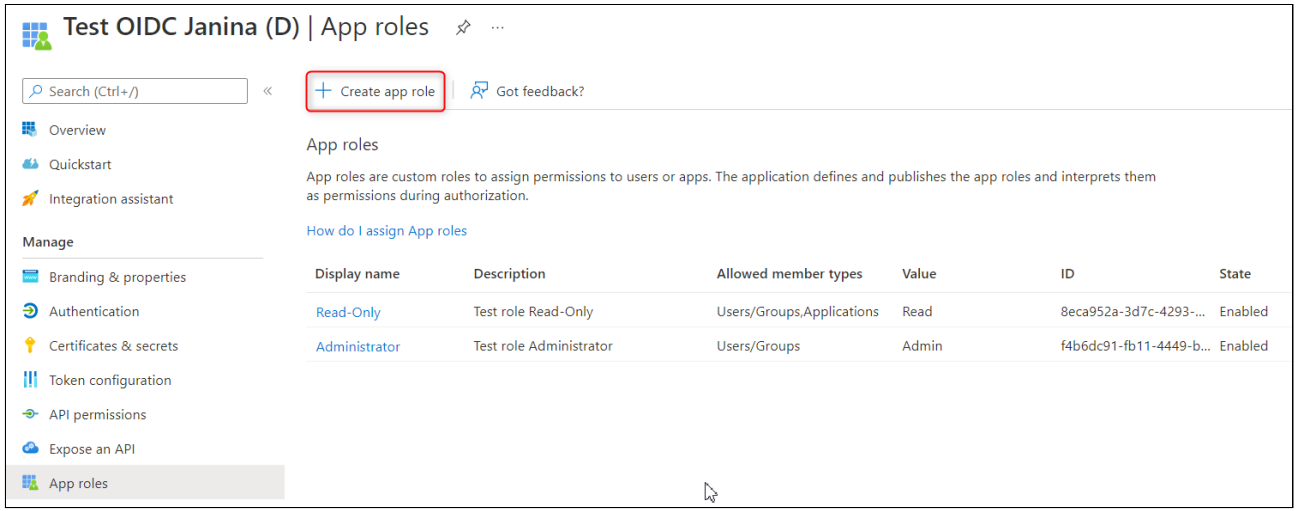
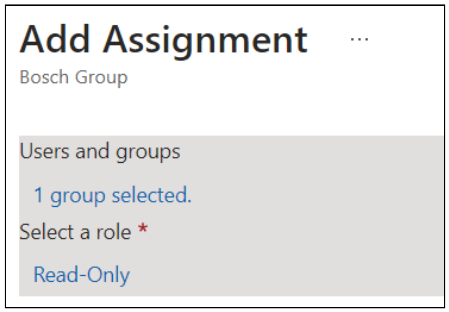
	Offical Microsoft Documentation: here
2 - **SAML**	Go to Single-Sign-On > Attributes and Claims and click "Add a group claim" Select the option "Groups assigned to application" and save the claim.  Under advanced options you could rename this claim

3.10.4 Usecase 2: Send Roles in Token

With this option you can define individual roles, map them to existing groups or users and send them in the token. There is currently a limit of roles per application, we recommend to max 1.000 roles (Service limits and restrictions - Microsoft Entra ID | Microsoft Learn)

	Official Microsoft Documentation: here
1	Go to your App Registration in Azure Portal

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
2	Add the desired App Roles in the "App Roles" section of your App Registration. For a standard user application it is enough to set Users/Groups as allowed member types. The "Value" is later send in the JWT-token. 
3	Add the Users and Groups to respective App Roles in your Enterprise Application (see instruction 1). 
Info **Automation**	If you want to assign many roles and groups, you could upload them as well via Script as explained in our documentation

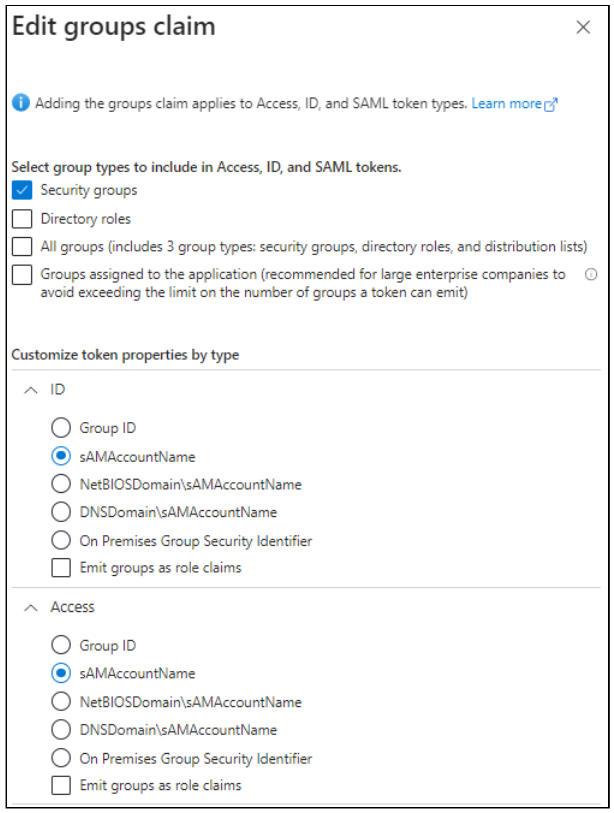
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
Info **OIDC**	These assigned app roles are automatically included in the ID tokens. `"roles": [ "Admin", "Read" ],` Special Case for e.g. Client Credential Flow: When your app is the API being called by an app the role assignment of applications is possible over "API permissions" and the roles are included in the access tokens.
Info **SAML**	The assigned app roles are automatically included in the SAML Response `<Attribute Name="http://schemas.microsoft.com/ws/2008/06/identity/claims/role"> <AttributeValue>Admin</AttributeValue> <AttributeValue>Read</AttributeValue> </Attribute>`

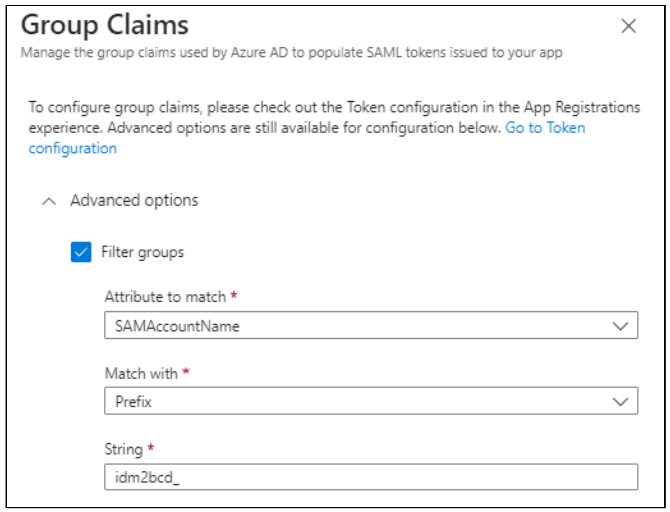
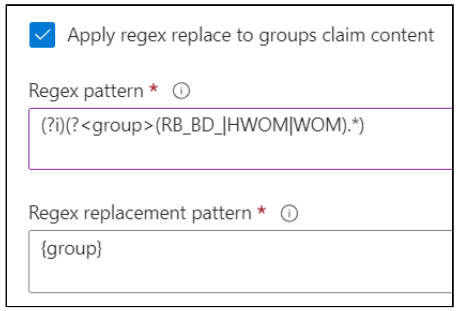
3.10.5 Usecase 3: Send Filtered Groups in Token

With this option, you can send groups that fit to a certain filter (e.g. IDM2BCD_myapplication). This option is recommended, if you have a large number / very dynamic groups that are relevant for your application. This is because you can exceed the limit of groups that can be send in a token and it is based on a name of a group and not it's unchangeable ID and therefore less secure. Additionally `sAMAccountName` attribute is available only on group objects synced from Active Directory and not on groups created in Entra ID or Office 365.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
1 - **OIDC**	Add Group Claim in Tab "Token Configuration" of your App Registration: Select Security Groups and select sAMAccountName as type for your ID-Tokens and/or Access-Tokens  Then go to the Enterprise Application of your App. In the Tab "Single-Sign-On" edit "Attributes and Claims". There you can "Add a group claim".
1 - **SAML**	In the Tab "Single-Sign-On" edit "Attributes and Claims". There you can "Add a group claim": Select "All groups" and as Source attribute select "SAMAccountName" in the section above. You can customize the name of the group claim if needed.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
2	Select Filter groups and add your desired Prefix-Filter in the field String:  Hint: You may have to some minutes and update the page until it is working to save the configuration in Azure. An alternative could be to select the Regex option below and define a pattern which is the more flexible option, **BUT** as soon as a user is member of more then 150 groups they won't be send in the token at all. Therefore this option is not recommended! 

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
3 **OIDC**	Adapt the Manifest of the App Registration: Microsoft Graph App Manifest (New): ... "api": { "acceptMappedClaims": true, ... "requestedAccessTokenVersion": 2, ... AAD Graph App Manifest (Deprecating Soon): ... "acceptMappedClaims": false, "accessTokenAcceptedVersion": null, ...

3.10.6 Usecase 4: Grant Application Permission to another App

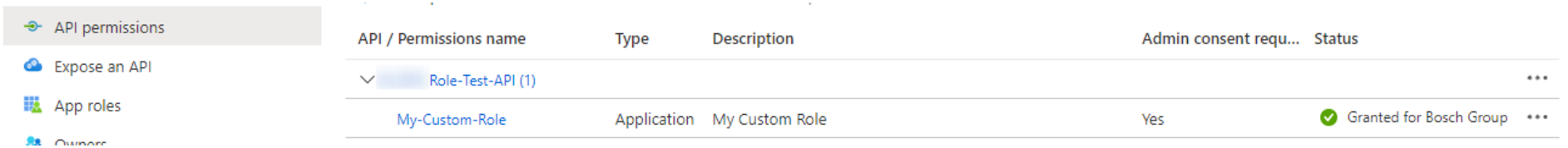
OIDC only!

With this option, you can assign application permissions of apps you own to other apps in the Bosch environment yourself. Unfortunately, Microsofts UI only supports Users and Groups (see Usecase 2) and you need to use the Microsoft graph API to achieve this.

	Official Microsoft Documentation: here
1	Create an App role as described in Usecase 2
2	Use the Microsoft Graph API to assign another application to the role: https://docs.microsoft.com/en-us/graph/api/serviceprincipal-post-approleassignedto The Microsoft Docs currently states that you need the '*Application.Read.All*' or '*AppRoleAssignment.ReadWrite.All*' application permission to list and add assignments in an application context without a user involved. However, that is not true and you will only need the '*Application.ReadWrite.OwnedBy*' application permission to use the following endpoints. The permissions above will not be granted to you, since it would give you access to every single application of Bosch. The calling user/application needs to be defined as an owner of the application that is publishing or providing the role. (Application can be added as Owners in Applications - IAP)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
3	You can see the assigned application permission in the API permissions overview of the application that was assigned. The permission will have the status Granted



3.10.7 Usecase 5: SCIM Provisioning

In case your application supports SCIM provisioning of users or groups, they can be automatically synced to your application. For this a separate app registration is required.
More information how to request it can be found here.

3.10.8 Common Problems

Please check out the common problems for OIDC here: Configure Claims in Token

3.10.9 How to configure PowerShell for Microsoft.Graph

The intention of this page is help you get up and running with the PowerShell Modules for Microsoft Graph.

- Setting up a local proxy with PX
- Setting up the PowerShell Profile(s)
- Installing the Microsoft.Graph modules

Microsoft has deprecated the "old" Azure / EntraID PowerShell modules and moved to a Microsoft Graph based approach. The new Modules are essentially just a wrapper around the "Microsoft Graph" Rest-API which exists for mostly all Microsoft offerings.
The new Modules are broken in various ways, one of them is properly working with proxy settings. Therefore we have to use a tool called PX to authenticate us against the proxy.

3.10.9.1 Setting up a local proxy with PX

Please assign "**Microsoft Visual Studio Code with Proxy Configuration (PX) (install)**" to your device via the IT Service Portal. As the Graph modules are less broken in PowerShell 7+ I would recommend also adding "**Powershell Core (install)**" if you haven't already.

*Hint: You can check the version of PowerShell you are running by having a look at the content of **$env:PSVersionTable**.*

Once the packages have been installed you can configure PX to automatically launch at startup using the following command:

```
& 'C:\Program Files\px\pythonw.exe' .\px.exe --install
```

This should result in a console opening up at each reboot.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.10.9.2 Setting up the PowerShell Profile(s)

PowerShell can be used in different applications - called PowerShell Hosts - with each having its own profile script. You can find the appropriate profile script by checking the content of $Profile. To create a new profile script simply execute in Powershell:

Notepad $profile

This will open up an editor with your profile file open, for PowerShell 7+ this should be "C:\Users\<your user>\Documents\PowerShell\Microsoft.PowerShell_profile.ps1".
Add the following lines to the file and save it:

$env:HTTP_PROXY = "http://localhost:3128"
$env:HTTPS_PROXY = "https://localhost:3128"

3.10.9.3 Installing the Microsoft.Graph modules

With the setup above completed you should be able to install the Graph Modules from the PowerShelll Gallery using:

Install-Module Microsoft.Graph -Scope CurrentUser

3.10.10 How to create App-roles/ AD-group-Mapping scripted

The intention of this page is to support the creation of app roles and the assignment of groups for SSO in Entra ID as **scripted creation for mass-uploads**

This script and documentation is an example of how you can connect to Microsoft Graph and using Powershell code for this task. IDP-Team is not responsible for the script, it maintenance or coding. In case of any problems with the script assign the roles/ groups manually or check the official Microsoft documentation

Connect MS-Graph
https://learn.microsoft.com/en-us/powershell/microsoftgraph/authentication-commands?view=graph-powershell-1.0
Administrate enterprise application with MS-Graph
https://learn.microsoft.com/en-us/graph/tutorial-applications-basics?tabs=powershell

Microsoft Limitations e.g. max 1.200 Manifest entries, impacting the number of roles per application
Service limits and restrictions - Microsoft Entra ID | Microsoft Learn

3.10.10.1

- Technical Prerequisites
- Upload Roles and Groups
  - Prepare .CSV File
  - Run the script
- Upload Groups only

3.10.10.2 Technical Prerequisites

Please refer to our documentation: How to configure PowerShell for Microsoft.Graph.
The user you are using to connect to Microsoft Graph needs to be the **owner** of the respective enterprise application and app registration.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.10.10.3 Upload Roles and Groups

3.10.10.3.1 Prepare .CSV File

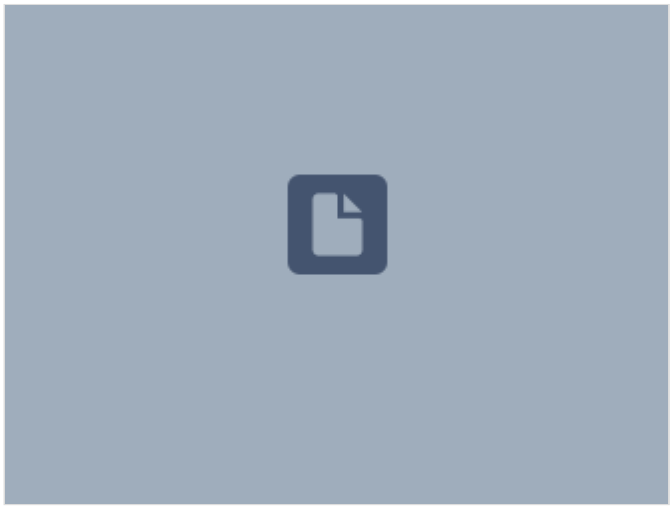
Create a .CSV with the columns Displayname (Groupname), Description, Value, RoleName and insert the values of your groups and roles. The column RoleName is optional.
The script is currently limited so that for each group there must be a different role (value) defined

Example:

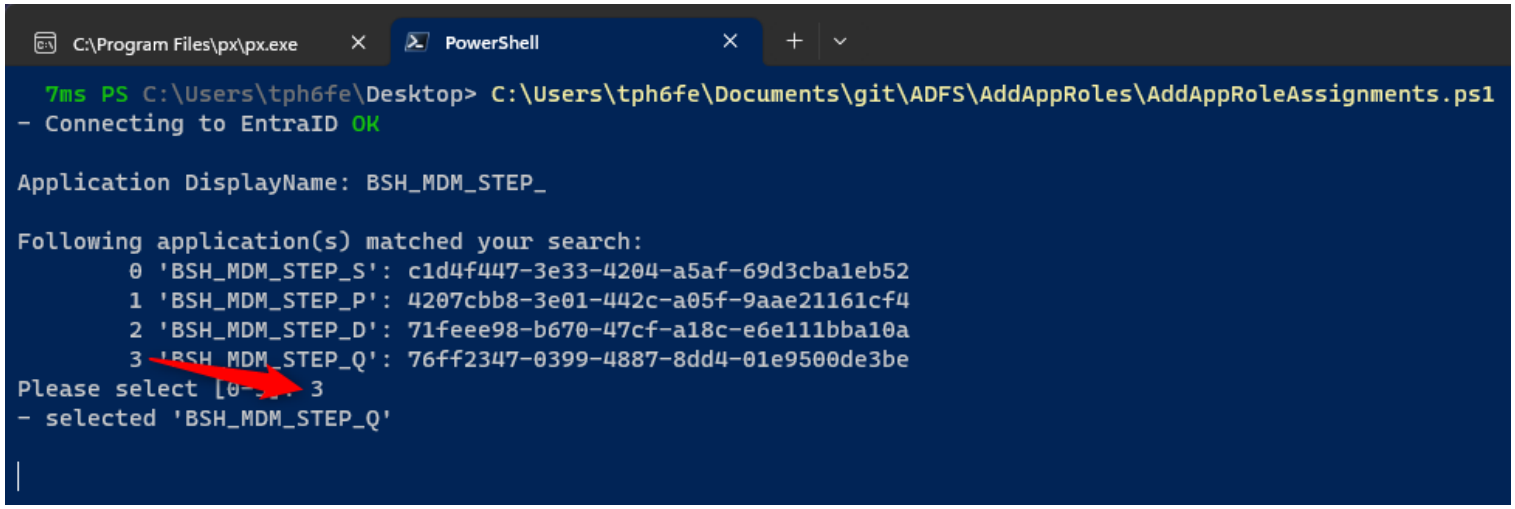
Displayname	Description	Value	RoleName
IDM2BCD_MYAPP_USER	Read Access to MYAPP	Reader	Reader-Role
IDM2BCD_MYAPP_POWERUSER	Admin Access to MYAPP	Admin	Admin-Role
...			

3.10.10.3.2 Run the script

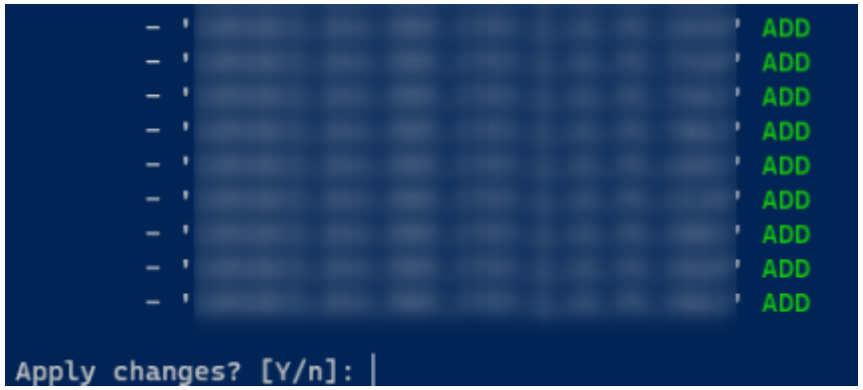
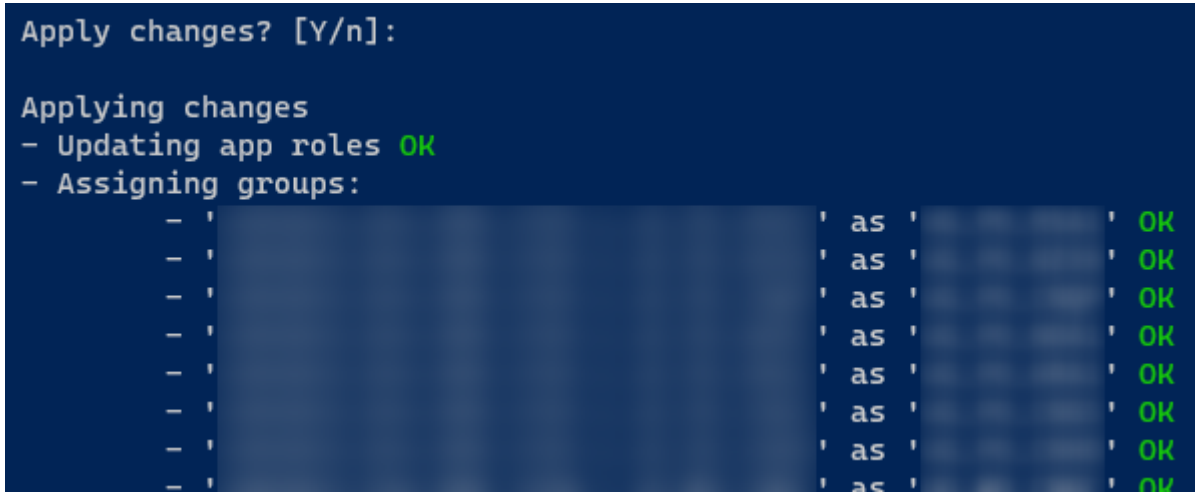
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
1 - Start Script	 To run the script you can simply drag & drop the downloaded script file into your PowerShell console window and hit enter. Make sure PX is running. You might be redirected to your browser window to sign in to EntraID.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
2 - Select Application	n the next step you will be prompted for the display name of your application. In case this results in a unique match the script continues, for multiple matches you have to enter the number of the application you intend to update: 
3 - Select .CSV File	The script shows a file open dialog (sometimes in the foreground, sometimes you have to ALT + TAB to find it) select your roles .CSV file

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
4 - Confirmation	After you have selected a file you are prompted with the necessary changes:  No changes have been made yet. In case a role already exists you will see a "SKIP" instead of "ADD" here. For a group that does not exist it will state "INVALID GROUP" and skip it. Hit ENTER or "Y" + ENTER to apply the changes.
5 - Processing	The script will now create the necessary new roles in the App Registration and assign/map them to the Enterprise Application accordingly. 

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Result of Example in Entra ID
1) App Registration → App Roles

Display name	Description	Allowed member types	Value
Admin-Role	Admin Access to MYAPP	Users/Groups	Admin
Reader-Role	Read Access to MYAPP	Users/Groups	Reader

2. Enterprise Application → Users and Groups

Display name	Object type	Role assigned
idm2bcd_[redacted]_poweruser	Group	Admin-Role
idm2bcd_[redacted]_user	Group	Reader-Role

3.10.10.4 Upload Groups only

Currently the script only supports to add roles and groups:

- Therefore you can manually create a default role in your app registration. Then you can assign all groups to this default role via the script.
- Or you just define a new role for each group and upload everything via the script

Follow the instruction from the chapter above.

3.10.11 SCIM - Authorization via SCIM interface

3.10.11.1 What is SCIM?

SCIM (System for Cross-domain Identity Management) is an open standard designed to facilitate the automation of user identity management across different systems and domains. SCIM aims to simplify the process of managing and exchanging identity data such as user profiles, roles, and permissions between cloud services, applications, and IT systems.
More information can be found here: SCIM - oneIDM Help Area

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3.10.11.2 Onboarding

SCIM Onboarding

SCIM is part of the IDM service at Bosch and will be provided by the responsible team.
To get consulting and start the SCIM onboarding process, please **contact the IDM integration mailbox** Mailbox.IdMIntegration@bosch.com

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4 Customer Information and Support

Overview

This page provides information for **customers with existing SAML / OIDC configurations on Entra ID / ADFS**

Page Overview:

- Stay Informed
- Our Support
  - How to request Troubleshooting if the SSO is not working?
  - How to do changes of the SSO configuration?
- Service Health
- Further Information

4.1 Stay Informed

For all kind of maintenance, certificate changes or planned downtimes we will **inform our customers via** the official process **SPoI**.
The notifications of our service can be subscribed with the following link: SPoI subscription

4.2 Our Support

4.2.1 How to request Troubleshooting if the SSO is not working?

Before you request troubleshooting:

- Please check out our common errors first: Microsoft Entra Authentication errors
- Please have a look on the Azure SSO-Logs: SSO Troubleshooting with Logs
- If possible: Please check with your Application Providers first

PS.: If you don´t have access to ITSM ticket tool:

- you can create it via IT Service Portal
- you can send an E-Mail to ITServiceDesk@bosch.com (and use the E-Mail Templates from above) or call here to the IT Service Desk

Create a new ticket Incident Overview | ServiceNow indispensably answering the following template:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Federation Service (SSO): Troubleshooting Request

- *Service: BD-FEDERATION SERVICE INFRASTRUCTURE OPERATION*
- *Service Offering: BD-FEDERATION SERVICE INFRASTRUCTURE OPERATION - SUPPORT*
- *Solution Group: Active Directory Services*
- *Summary: SSO Troubleshooting <Your Summary>*
- *Template: "Federation services template_EN"*

```
Template:
++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++
I: CI-HOTLINE: Please answer all questions.
++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++
```

ITSD: Please translate all answers to English !

Dear customers, you may use this template for incidents/problems/requirements for additional configuration, etc...

THIS IS A REQUEST FOR Federation Service Team !

Q:Are you receiving a token from the Identity Provider? if so, have you already contacted the vendor to ensure it's not a problem in the application configuration itself?
A:

Q: What's the entityID/identifier/ClientID or the name of your app (e.g. https://bshg.eositpm.com/saml/metadataor name e.g. BSH EOS Portfolio Tool (P)):
A:

Q: Which protocol are you using to perform Single Sign On (SSO)? Its it: SAML or OAuth 2.0 + OIDC?:
A:

Q: How can the customer be reached:
( ) Desk phone; number: ?
( ) Mobile phone; number: ?
( ) E-Mail; address: ?
A: (Please write the contact):

Q: Problem description/ Requirements / changes of configuration (Please be specific, and attach screenshots if needed):
A:

```
++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++
```

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



4.2.2 How to do changes of the SSO configuration?

Changes can be done by you in IAP/ Entra ID Portal in Azure.
If you need consulting you can get in contact with us via Onboarding.Bosch-IdP@de.bosch.com

4.3 Service Health

More details about the current Service Health of our Federation Services can be found here.

4.4 Further Information

- ADFS signing and decryption certificate renewal for BSH ADFS (stfs.bshg.com)
- ADFS signing and decryption certificate renewal for NGW (BOSCH-P ADFS system)
- Retrieve SAML response in base64-encoded, deflated and base64-encoded, or plain XML format
- BPC Customers only
- Authentication fails with bad password on ADFS from internet access
- ADFS signing and decryption certificate renewal for RB-ADMIN (stfs.bosch-org.com)
- Enablement of SAML configurations for self management
- SSO Troubleshooting with Logs
- SSO with multiple Accounts

4.5 ADFS signing and decryption certificate renewal for BSH ADFS (stfs.bshg.com)

Change number: CRQ000001071123
Note:
Please note that this change only affects application which are onboarded to
BSH ADFS (**stfs.bshg.com**) but
NOT to applications using Bosch ADFS (stfs.bosch.com), WAM/WAF or which are already using Entra ID (https://sts.windows.net/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/) as IdentityProvider (idP) for SSO.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

If your application is using stfs.bshg.com for SAML/OIDC SSO please also note that SSO might stop working if your application does not receive the new cert automatically or the cert is changed manually.
The ADFS signing and encryption certificates has to be replaced every 3 years due to security purposes.
Applications need those certificates to validate that the SAML tokens comes from a trusted relying Identity Provider (In this case, BSH-P ADFS which is **stfs.bshg.com**).

measurements:
1 - Make sure you are subscribed in the official communication channel with ADFS team which is the SPOI: https://rb-wam.bosch.com/spoi/directLinkSubscription.do?distId=ASGACUQOG9EEEAPOQJH4PNSZDAYMQU to receive all relevant information
2 - Please ensure your application is able to retrieve the certificates automatically . We have a lot different applications onboarded with different behavior in this regards.
Therefore we can not give a statement how your application is handling certificates. Please ask your application vendor if you have any doubts.
Helpful is maybe also the Q & A section at the end of this page
If your application is able to auto-update it will use the ADFS metadata file therefore

ADFS metadata https://stfs.bshg.com/federationmetadata/2007-06/federationmetadata.xml

The new certificates will be available from **CW3/2025** (15th January 2025) as secondary in the ADFS metadata (URL please see above). We will also attach the certificates to the SPOI messages and for download on this page.
Depending on the behavior of your application (see Q&A section of this page) please decide of your application will do an automatic update (with the ADFS metadata) or if you need to manually download and import the ADFS metadata or the plain certificates.

- If your application is not getting the new certificate automatically (confirm that with vendor in case of doubts), please be ready to do it manually on **28th January at 13:00 pm** CEST (Central European Summer Time, Berlin time). This is the planned certificate change window.
- After validating or replacing the certificates manually please get rid of browser cookies and cached data and try to login to your application to validate (or simply use the incognito, private browser mode to validate).

3 - If application is no longer needed, please provide us the entity ID (app identifier. something like https://application.bshg.com:433/web-sso/SAML) or it`s trust name (something like RPT-example-SAML), send this info to the onboarding email (Onboarding.Bosch-IdP@de.bosch.com), thus we can disable them and delete after 1 week.

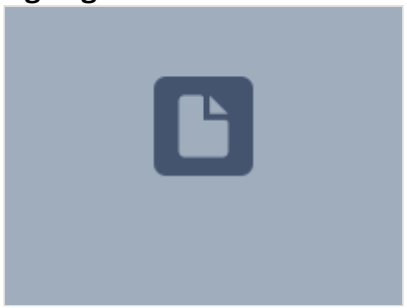
4 - Certificate will be attached to this page in CW3/2025, 15th January 2025 (please find them down below)

5 - New certificates:
Decrypting

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Signing



4.5.1 Q&A

Currently we get a lot of questions about the upcoming certificate rollover. Some important questions will be anwersed in this Q&A section

4.5.1.1 Is the new certificate already valid and can be used in my application?

No! Currently the "old" certificate is used to sign the token and so the related public key which has to be used in the application.
Technical description:
ADFS can hold two certificates in parallel, a primary and a secondary. Only one of them can be used to sign the token. This is always the primary.
The secondary certificate will be used to generate and distribute the new and upcoming certificates in advance.
*It will get the primary when we do the switch on **28th January 2025** at 13:00 (German Time).*
Before the rollover only the old certificate is valid. After the rollover only the new one is valid.

4.5.1.2 *Can I store both certificates in my application?*

This question cannot be answered in general. It depends on the application if the application can hold multiple token signing certificates (Public key).
If you are able to store both, the old and the new one, you don't need to change the certificate in time when we do the rollover as the application will select the correct one.
Please ensure with your vendor/developer/provider how your application works and what is possible. Maybe there are other techonlogies we are not aware of.

In summary the following option are possible:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- If the connected application uses the metadata URL or metadata XML file from your ADFS environment, and it supports 2 Token Signing/ Decryption certificates, the metadata can be updated in the application already in CW3/25 (starting on 15th January 2025)
- If the connected application uses the metadata URL or metadata XML file from your ADFS environment, and it supports only 1 Token Signing/ Decryption certificate, the metadata should be updated in the application on the date the certificates are rolled over (28th January 2025)
- If the connected application allows the import or configuration of individual certificates and it supports at least 2 Token Signing/Decryption certificates, the import or configuration of individual certificates can be done already in CW/25 (starting on 15th January 2025)
- If the connected application allows the import or configuration of individual certificates and it supports only 1 Token Signing/Decryption certificate, the import or configuration of individual certificates should only be done on the date the certificates are rolled over (28th January 2025)

4.6 ADFS signing and decryption certificate renewal for NGW (BOSCH-P ADFS system)

Attention! You have to ACT!or your SSO could work anymore!: Please note that the authentication might stop working for your application if it does not get the new certificate, or you don't manually replace it.
Change number: CRQ000001019018
Brief: The ADFS signing Certificate has to be replaced every 3 years due to security purposes. Applications need those certificates to ensure that the SAML tokens comes from a relying Identity Provider (In this case, Bosch-P ADFS).

1 - Make sure you are subscribed in the official communication channel with ADFS team which is the SPOI: https://rb-wam.bosch.com/spoi/directLinkSubscription.do?distId=ASGACUQOG9EEEAPOQJH4PNSZDAYMQU
2 - Please ensure your application is able to retrieve the certificates automatically (we have no knowledge on that, if you are not sure, please contact application vendor) from the ADFS metadata https://stfs.bosch.com/federationmetadata/2007-06/federationmetadata.xml. The new certificates will be available from **March 27th on**, as secondary in the ADFS metadata URL. We will also attach them to the SPOI messages.

- If your application is not getting the new certificate automatically (confirm that with vendor in case of doubts), please be ready to do it manually on **April 8th at 16:30 pm** CEST (Central European Summer Time, Berlin time). This is the planned certificate change window.
- Please after Validating or replacing the certificates manually. Get rid of browser cookies and cached data and try to login to your application to validate (or simply use the incognito, private browser mode to validate).

3 - If application is no longer needed, please provide us the entity ID (app identifier. something like https://application.bosch.com:433/web-sso/SAML) or their trust name (something like RPT-example-SAML), send this info to the on-boarding email (Onboarding.Bosch-IdP@de.bosch.com), thus we can disable them and delete after 1 week.

4 - Certificate will be attached to this page around end of March.

5 - New certificate:

Signing

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



4.6.1 Q&A

Currently we get a lot of questions about the upcoming certificate rollover. Some important questions will be answered in this Q&A section.

4.6.1.1 Is the new certificate already valid and can be used in my application?

No! Currently the "old" certificate is used to sign the token and so the related public key which has to be used in the application.
Technical description:
ADFS can hold two certificates in parallel, a primary and a secondary. Only one of them can be used to sign the token. This is always the primary. The secondary certificate will be used to generate and distribute the new and upcoming certificates in advance. It will get the primary when we do the switch on 8th of April 2024 at 16:30 (German Time). Before the rollover only the old certificate is valid. After the rollover only the new one is valid.

4.6.1.2 *Can I store both certificates in my application?*

This question cannot be answered in general. It depends on the application if the application can hold multiple token signing certificates (Public key). If you are able to store both, the old and the new one, you don't need to change the certificate in time when we do the rollover as the application will select the correct one. Please ensure with your vendor/developer/provider how your application works and what is possible. Maybe there are other technologies we are not aware of.

4.6.1.3 If my app use EntraID as IDP, do I have to take actions?

No, this change need attention from customers using on-prem environment only

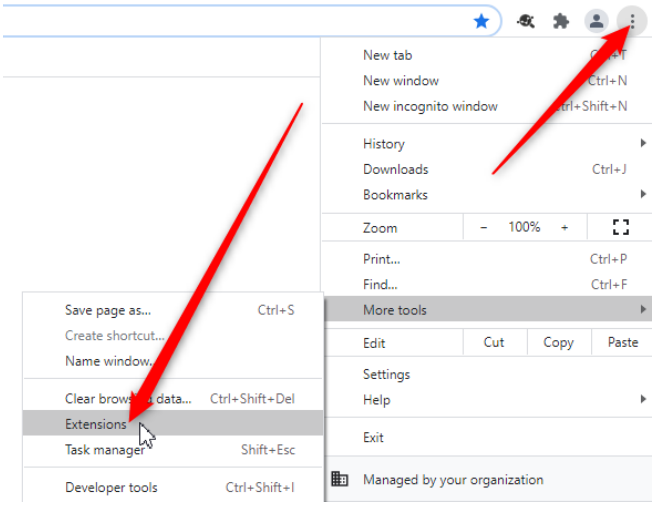
4.7 Retrieve SAML response in base64-encoded, deflated and base64-encoded, or plain XML format

Hello dear customers,

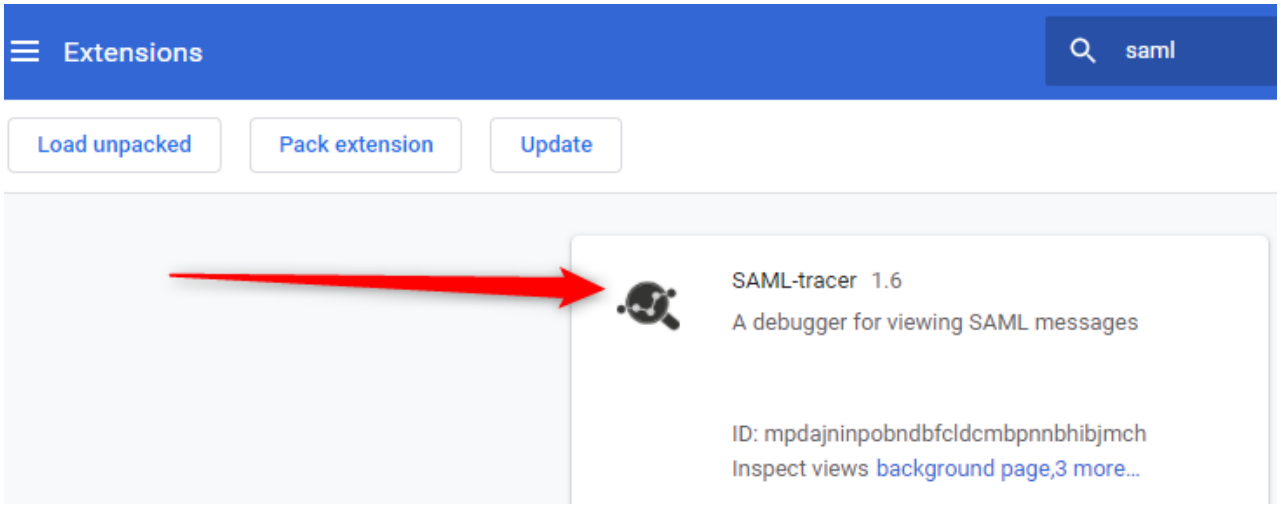
Here is a small tutorial to help you use a simple tool named SAML tracer.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

You can use Firefox and Chrome for example, and is it installed as an extension

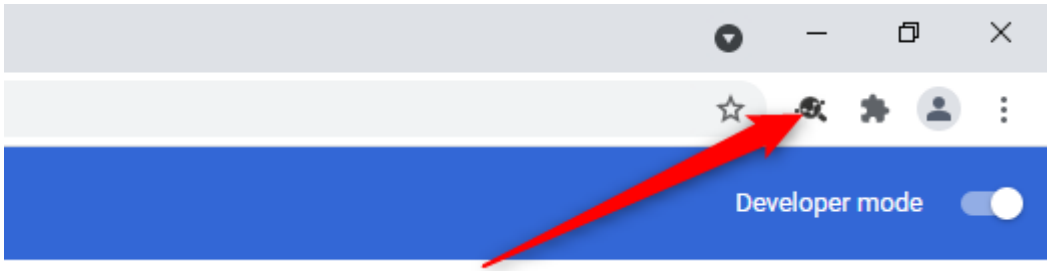


Install it

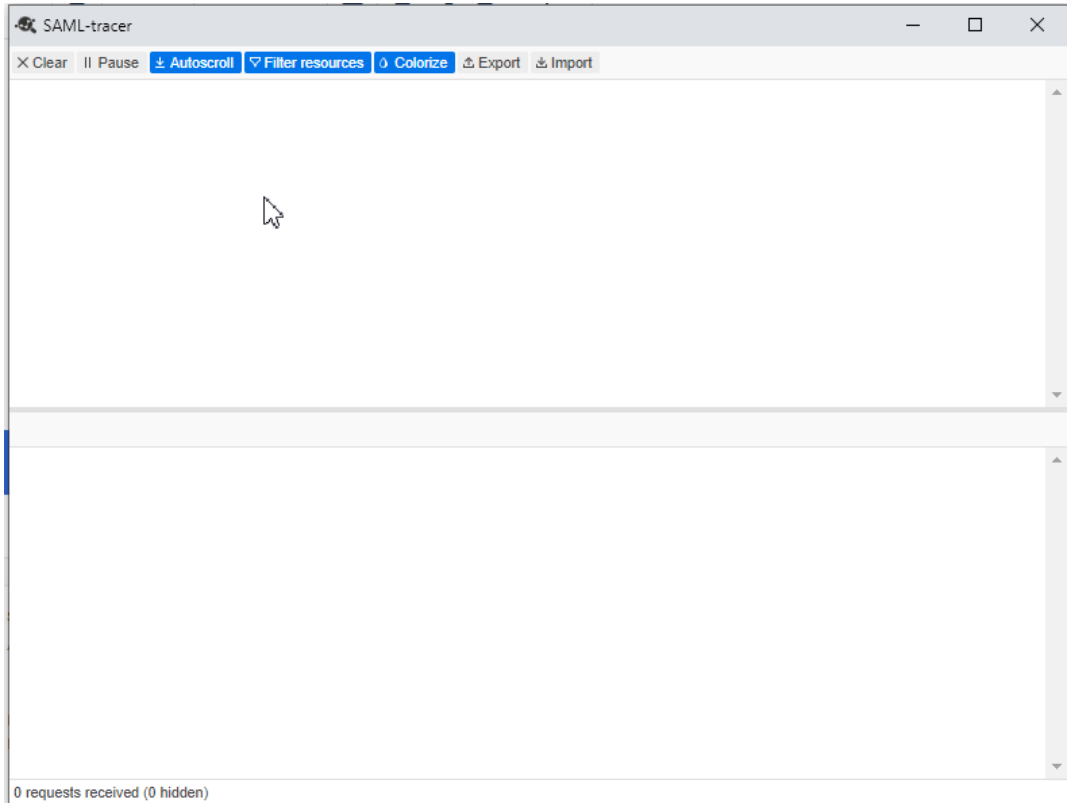


After installing you will see the shortcut in the browser

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



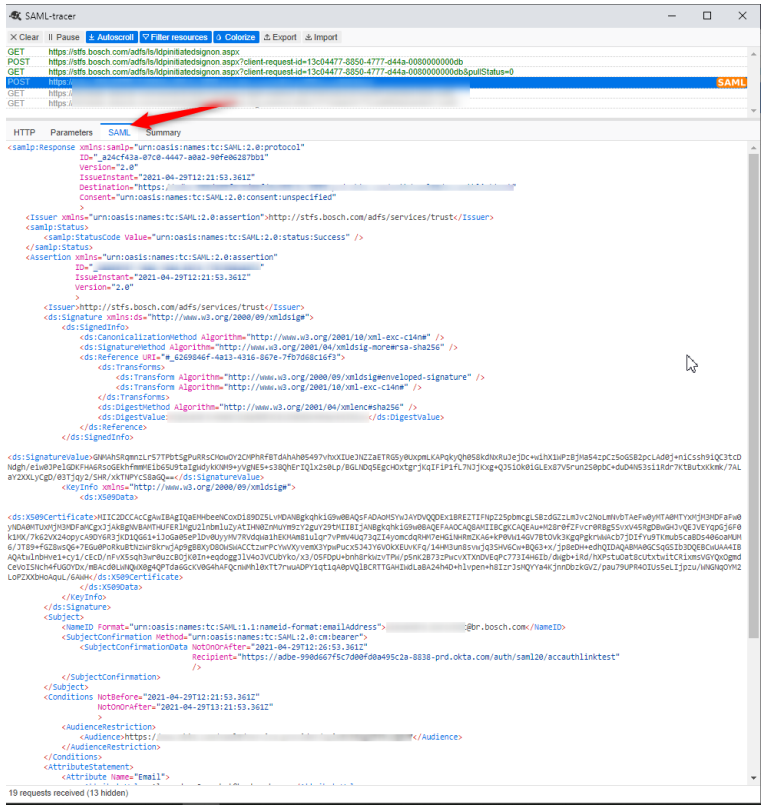
This is how it looks like:



Leave it opened while your attempts to login to your application (or any attempt to retrieve a SAML token)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

It will capture the data in XML (in the example below, the trust does not have an encryption certificate, hence claims are in plain text):



After the capture, go to the packet with tag "SAML" in to the right and then click "SAML" in the middle of screen as the red arrow show in the picture above

Hope this help you all.

4.8 BPC Customers only

This section includes some tips dedicated to Bosch Private Cloud Customers
(Linked Documentation: Federation Service / SSO - Bosch Private Cloud - Docupedia II)

4.8.1 Configuration

Owner: Please select your BPC Cloud Project Group as Owner of the SSO-configuration

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Authorization: Every BPC Cloud Project has IdM Roles that are created by default (IDM2BCD_SMCP_<Cloud-Project UUID>_<role>). It is possible to send them as group claims in the token and use them as roles in the application. More information about the default roles can be found in the BPC Documentation.

4.9 Authentication fails with bad password on ADFS from internet access

Currently some users facing the issue, that after a successful password change, authentication on mobile devices will not work properly. When authentication on the windows client with the same password works well.
The problem is caused by a feature on e.g. iOS devices, which is called "Smart punctuation", which changes some special characters, like " or ' or - to different ones. If you have such special characters in your password, the iOS device will send another ASCII code and so the password is interpreted as a wrong one.

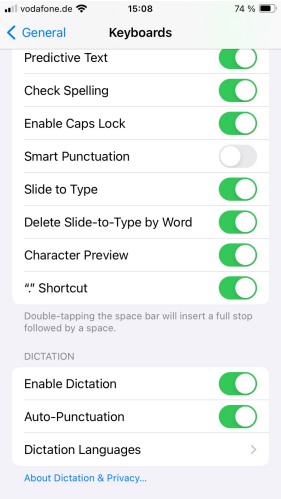
4.9.1 Solution/Workaround

Currently we have two possible workarounds:

- The first option (preferred) is not to use some special characters, like quotation marks (**", ´**) or dashes (-). From these we know that they can cause the described issues.
  There could be more characters affected, we do not know currently.

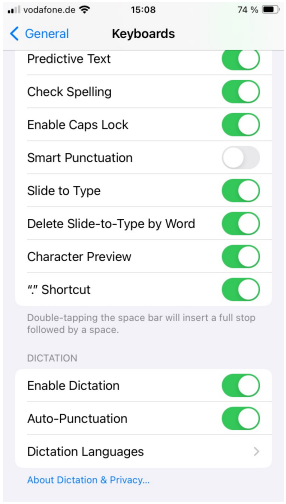
- The second option is to turn off the feature "Smart punctuation" on your iOS device. Follow the steps below to achieve it:

1. Open "Settings" on your mobile device
2. Navigate to General and open "Keyboard within the general settings.



3. Search for the feature "Smart Punctuation and disable it.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



You can find more information on the apple support website:
https://support.apple.com/guide/numbers-iphone/format-dashes-and-quotation-marks-tane7f9690fb/ios

4.10 ADFS signing and decryption certificate renewal for RB-ADMIN (stfs.bosch-org.com)

Change number:
Note:
Please note that this change only affects application which are onboarded to
RB-ADMIN (**stfs.bosch-org.com**) but
NOT to applications using Bosch ADFS (stfs.bosch.com), WAM/WAF or which are already using Entra ID (https://sts.windows.net/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/) as IdentityProvider (idP) for SSO.

If your application is using stfs.bosch-org.com for SAML/OIDC SSO please also note that SSO might stop working if your application does not receive the new cert automatically or the cert is changed manually.
The ADFS signing and encryption certificates has to be replaced every 3 years due to security purposes.
Applications need those certificates to validate that the SAML tokens comes from a trusted relying Identity Provider (In this case, RB-ADMIN which is **stfs.bosch-org.com**).

measurements:
1 - Make sure you are subscribed in the official communication channel with ADFS team which is the SPOI: https://rb-wam.bosch.com/spoi/directLinkSubscription.do?distId=ASGACUQOG9EEEAPOQJH4PNSZDAYMQU to receive all relevant information

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

2 - Please ensure your application is able to retrieve the certificates automatically . We have a lot different applications onboarded with different behavior in this regards.
Therefore we can not give a statement how your application is handling certificates. Please ask your application vendor if you have any doubts.
Helpful is maybe also the Q & A section at the end of this page
If your application is able to auto-update it will use the ADFS metadata file therefore

ADFS metadata https://stfs.bosch-org.com/federationmetadata/2007-06/federationmetadata.xml

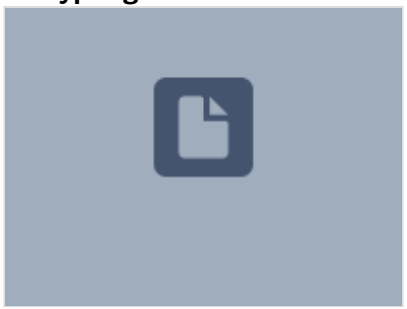
The new certificates will be available from **CW6/2025** (3rdFebruar 2025) as secondary in the ADFS metadata (URL please see above). We will also attach the certificates to the SPOI messages and for download on this page.
Depending on the behavior of your application (see Q&A section of this page) please decide of your application will do an automatic update (with the ADFS metadata) or if you need to manually download and import the ADFS metadata or the plain certificates.

- If your application is not getting the new certificate automatically (confirm that with vendor in case of doubts), please be ready to do it manually on **13th February at 13:00 pm** CEST (Central European Summer Time, Berlin time). This is the planned certificate change window.
- After validating or replacing the certificates manually please get rid of browser cookies and cached data and try to login to your application to validate (or simply use the incognito, private browser mode to validate).

3 - If application is no longer needed, please provide us the entity ID (app identifier. something like https://application.bshg.com:433/web-sso/SAML) or it`s trust name (something like RPT-example-SAML), send this info to the onboarding email (Onboarding.Bosch-IdP@de.bosch.com), thus we can disable them and delete after 1 week.

4 - Certificate will be attached to this page in CW6/2025, 3rd February 2025 (please find them down below)

5 - New certificates:
Decrypting



Signing

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



4.10.1 Q&A

Currently we get a lot of questions about the upcoming certificate rollover. Some important questions will be anwersed in this Q&A section

4.10.1.1 Is the new certificate already valid and can be used in my application?

No! Currently the "old" certificate is used to sign the token and so the related public key which has to be used in the application.
Technical description:
ADFS can hold two certificates in parallel, a primary and a secondary. Only one of them can be used to sign the token. This is always the primary.
The secondary certificate will be used to generate and distribute the new and upcoming certificates in advance.
*It will get the primary when we do the switch on **13th February 2025** at 13:00 (German Time).*
Before the rollover only the old certificate is valid. After the rollover only the new one is valid.

4.10.1.2 *Can I store both certificates in my application?*

This question cannot be answered in general. It depends on the application if the application can hold multiple token signing certificates (Public key).
If you are able to store both, the old and the new one, you don't need to change the certificate in time when we do the rollover as the application will select the correct one.
Please ensure with your vendor/developer/provider how your application works and what is possible. Maybe there are other techonlogies we are not aware of.

In summary the following option are possible:

- If the connected application uses the metadata URL or metadata XML file from your ADFS environment, and it supports 2 Token Signing/ Decryption certificates, the metadata can be updated in the application already in CW6/25 (starting on 3rd February 2025)
- If the connected application uses the metadata URL or metadata XML file from your ADFS environment, and it supports only 1 Token Signing/ Decryption certificate, the metadata should be updated in the application on the date the certificates are rolled over (13th February 2028)
- If the connected application allows the import or configuration of individual certificates and it supports at least 2 Token Signing/Decryption certificates, the import or configuration of individual certificates can be done already in CW6/25 (starting on 3rd February 2025)
- If the connected application allows the import or configuration of individual certificates and it supports only 1 Token Signing/Decryption certificate, the import or configuration of individual certificates should only be done on the date the certificates are rolled over (13th February 2025)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4.11 Enablement of SAML configurations for self management

4.11.1 Information about SAML self-service in EntraID

Beginning of 2025 we started with the self-service for SAML Identity provider configurations. For applications, which have been onobarded before the launch of the self-service we will now start to enable the self-service for all of these configurations. We will inform all application owners via mail, once the configuration was done. On these docupedia page, you can find all information you need after the enablement.
The enablement will not do any technical changes or issue any outage for your application. Anything stays as before. What exactly will be changed:

- You will be technical owner on the EntraID SAML configuration, which means you can maintain and manage settings of your SAML Idp configuration by yourself and take over the full responsibility of the configuration.
- We implement monitoring for some security relevant settings (more information below)
- Your application will be registered in our IAP management portal (https://rb-iap.bosch.com)

4.11.1.1 Which actions you need to take?

There is no technical action for you to take to enable the self-service.
Benefits of the SAML self-service

- Renewal of token signing certificate without the need of requesting support via SMT ticket
- Changing technical settings, like claims, EntityID, login and logout urls or assigning Users and groups without the need of requesting support via SMT ticket
- Adding and managing owners for your configuration
- Access login logs for your configuration

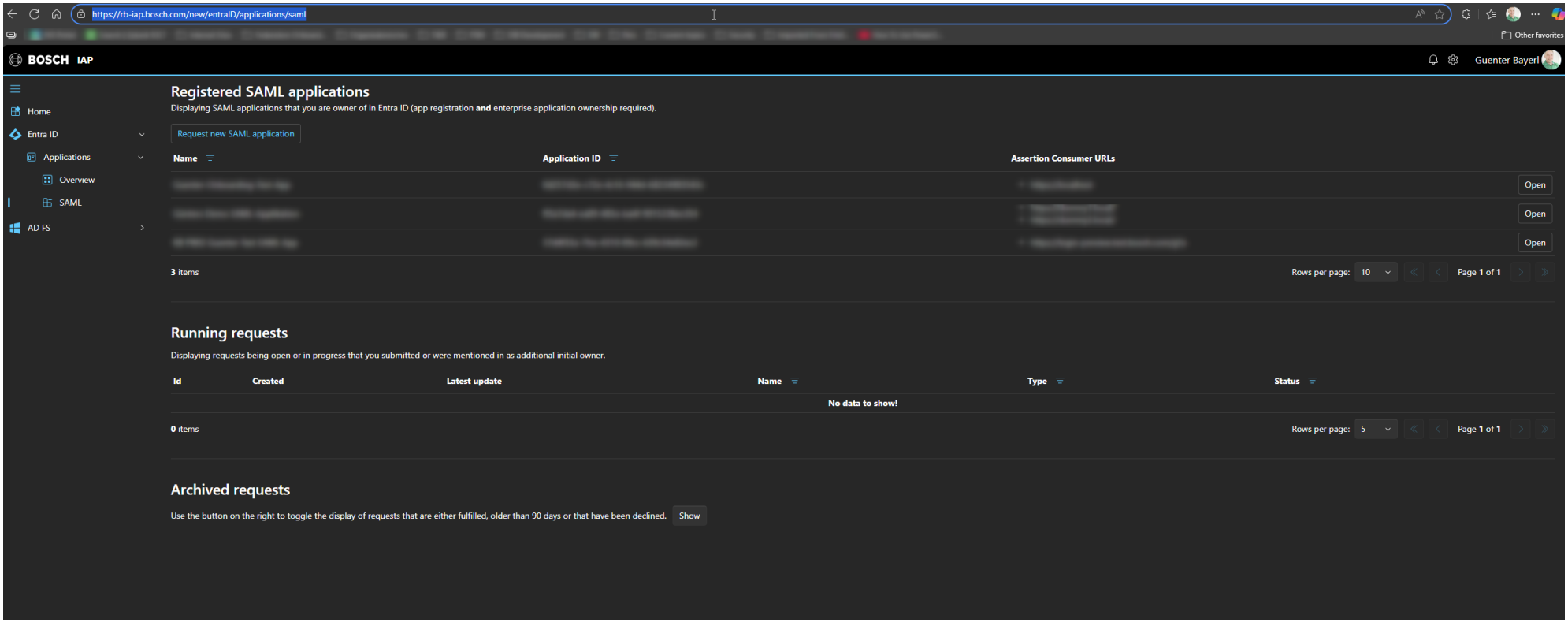
4.11.1.2 Technical support and consulting

Once the SAML configuration has been enabled for the self-service, you have the full responsiblity for the configuration, including management of certificates and technical parameters.
This would not mean, that we will be completely out. Of course we are there for you to support you in case you have any questions and issues (following the support process, you can find here: https://inside-docupedia.bosch.com/confluence/x/FyoLZg) and as well for consulting.
The big adavantage and key benefit for you is, that you are more flexible organizing changes and troubleshootings with the vendor, provider or developer.

4.11.2 How to access and manage your configuration

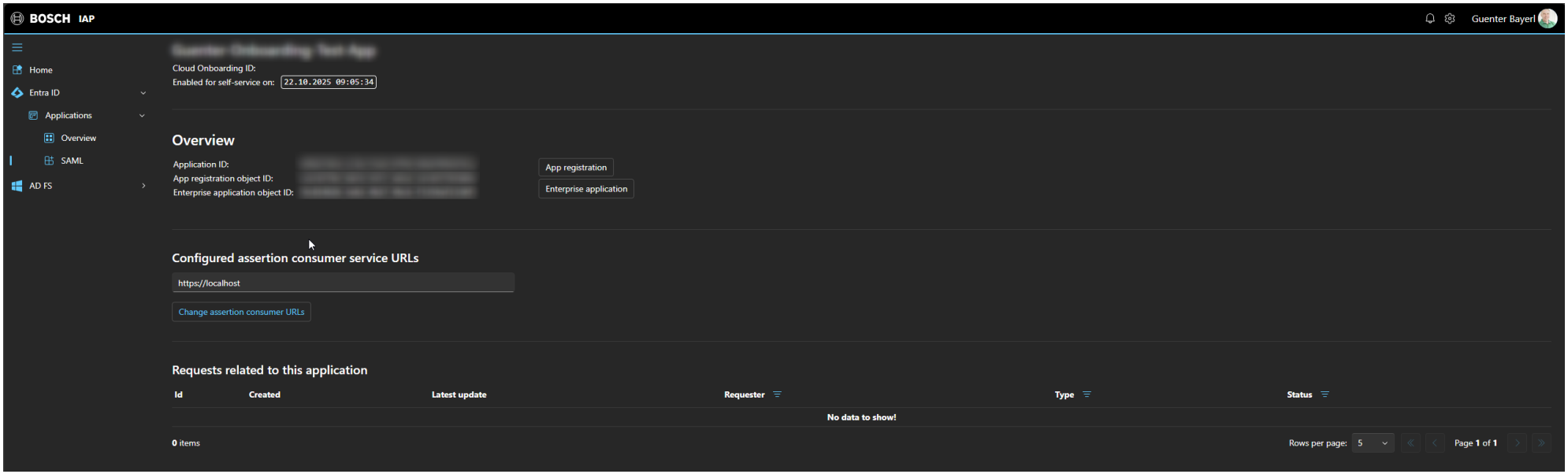
The single point of management is the SAML application tab in the IAP portal (https://rb-iap.bosch.com/new/entraID/applications/saml). As you can see in the screenshot below, you can find all SAML configurations, you are owner of, in the section "Registred SAML applications".
Clicking the "Open" button will bring you to the detail view of the configuration (screenshot 2).

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



1 Screenshot 1 | IAP SAML overview

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



2 Screenshot 2 | IAP SAML application details

In the details section you can direclty access the "Enterprise application", where you can configure the SAML parameter for your application. Please follow the instructions of our onboarding documentation (https://inside-docupedia.bosch.com/confluence/x/hNxATwE) to configure your enterprise application.

4.11.3 FAQ

4.11.3.1 Why do I get email regarding expired token signing certificate?

In case your configuration holds an already expired certificate, you will get an email from our self-service backend. It doesn't matter if it is the active one or the inactive one. This means, in case, you already renewed your certificate but the old expired one was not deleted, you will get this email on a weekly base.

4.11.3.1.1 Solution

Please delete always the old certificate after the successful renewal. As soon as you are using the new one, the old is not needed anymore and causes the mail once it is expired. Change SAML Signing Certificate - Directory Services - Docupedia

4.11.3.2 Why do I get email regarding missing Owner?

There must be always at least two owners added to the configuration. Once, this is not the case, we inform you on a regular base that there is a violation against this rule

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4.11.3.2.1 Solution

Please add at least another owner to the configuration to avoid this situation. You can add as many owners you want to the configuration. Please be aware, that every owner has full access to the SAML configurations. Please also ensure that every owner knows about the rules and howtos of the self-service.

4.11.3.3 Why do I get an email regarding signing certificate lifetime exceeded?

The total lifetime of a certificate should be limited to two years as defined EISA-CRY-107.6 - Standards for Asymmetric Cryptographic Key Material. The total lifetime of your application is currently set for a longer period

4.11.3.3.1 Solution

Replace the signing certificate in Azure as documented in Entra ID SAML Application Certificate Expiration Replacement Process - Directory Services - Docupedia and adapt it in your application

4.11.3.4 What if I am not the application owner anymore?

While the enablement to the self-service, we set the accounts from our onboarding documentation as the technical owners in the EntraID configuration. If you handed over the responsibility to someone else but did not inform us about the change, you can correct this now by adding the new owner to the configuration and remover yourself. Please take care, that at any point there are at least two persons as owners in the configuration. If not, you will get the mail, mentioned one question before. To change owner, please follow our instructions Request new SAML application via Self-Service | Part 2 - EntraID.

4.11.3.5 Is it possible to add other owners to the configuration

You can add as many owners to the configuration as you need. Please follow our instructions here Request new SAML application via Self-Service | Part 2 - EntraID to maintain the owners. Please be careful as all owners will have the full permission to maintain and change the SSO settings.

Is it possible to change the SAML Certificates?

Yes, now you can do this task on your own, without finding appointments with the IDP-Team. The SAML Signing certificate needs to be exchanged before it expires, see Change SAML Signing Certificate - Directory Services - Docupedia

If you have further question or you need some more information, don't hesitate to contact us at Onboarding.Bosch-Idp@de.bosch.com

4.12 SSO Troubleshooting with Logs

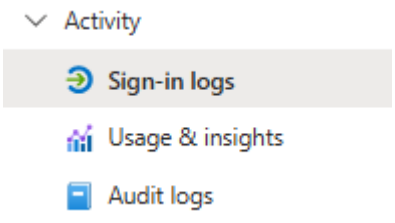
This page shows how to access and read the application logs in Entra ID (Azure)

For Troubleshooting of Single-Sign-On Issues, we recommend to check with the vendor of your application first!
If there is an error message from Entra, please have a look on our common errors: Microsoft Entra Authentication errors
If you are totally lost, you can create a ticket as explained in Customer Information and Support - Directory Services - Docupedia

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

For SAML and OIDC the Activiy Logs can be found in the "Enterprise Application" part of your application in Azure/ Entra Portal (https://portal.azure.com/).
In order to access the Logs you must be configured as Owner of the application

4.12.1 Overview



Sign-In Logs

- lists of users that logged on to your application (details)

Usage & Insights

- This report is empty for you!

Audit Logs

- Recent changes on your application in Entra ID

Further Links from Microsoft:

- Sign-in logs in Microsoft Entra ID - Microsoft Entra ID | Microsoft Learn
- Learn about the audit logs in Microsoft Entra ID - Microsoft Entra ID | Microsoft Learn

4.13 SSO with multiple Accounts

This page provides some hints how to have a smooth SSO-experience when using several Accounts in parallel (e.g. Q9 Accounts, Admin Accounts, etc.).
Normally you are already logged in to your Browser with your standard account and therefore you are automatically logged on with this user to all other applications automatically.

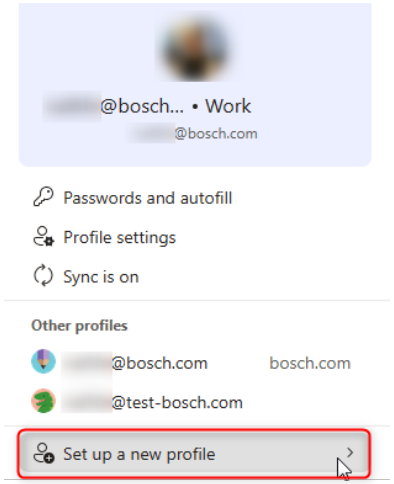
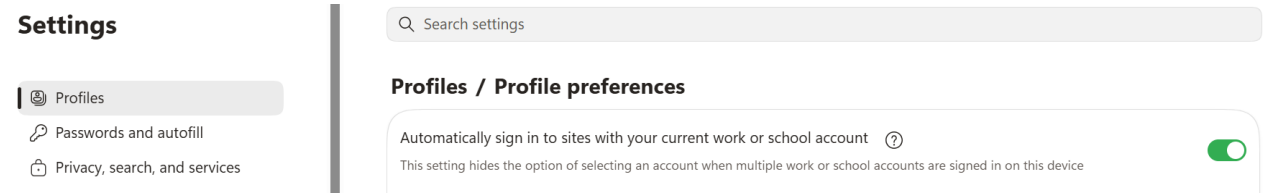
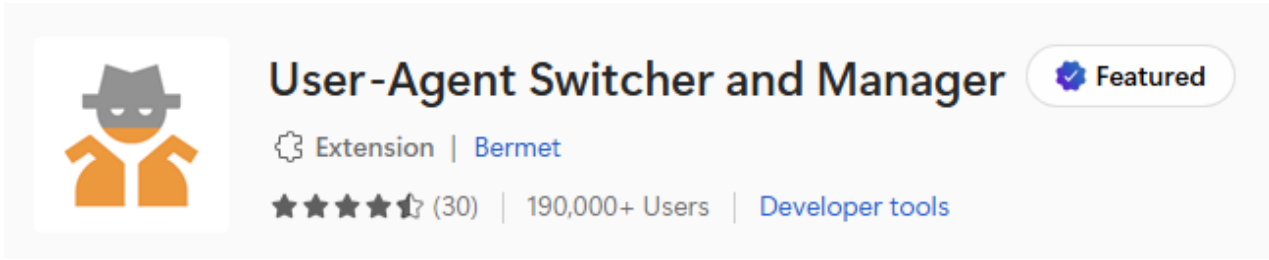
4.13.1 Quick Solution

Open a private / incognito Window and you can logon with you second Account
There is a limited SSO experience as you have to type your password every time you open the private / incognito Window

4.13.2 Our recommended Edge Solution

Edge Browser Profiles and adapted SSO-settings

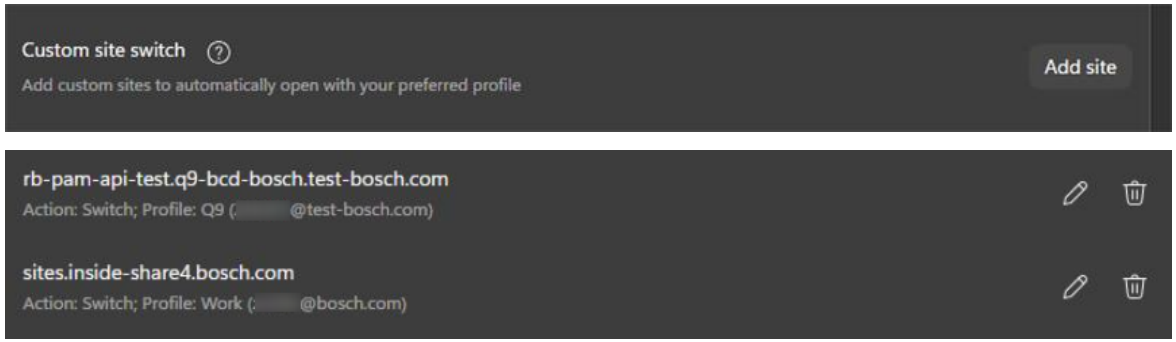
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description	Pictures
1	In the Edge Browser you can create a **new profile** for your second User Account. • With this setup you can switch easily between the Profiles • You can also set some different background colors for each Profile	
2	For the separate Browser Profile you can set profile preferences: "Automatically sign in to sites with your current work or school account" to prevent the SSO of the Office Account with Entra ID and other applications	
3	Install **Browser Plugin** "User Agent Switcher" (approved via CSC)	

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description	Pictures
4	In the Plugin Settings of "User-Agent Switcher" in every separate Profile you need to save these custom mode options: `{ "stfs.bosch.com": "NO-SSO" }` ...to prevent the SSO of the Office Account with ADFS.	

4.13.2.1 Additional Settings

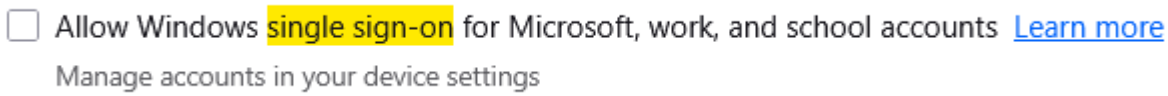
Name	Description	Pictures
Custom Site Switch	This will open certain pages always with the selected profile It's very helpful if you only need to open a few pages with the second Account!	

4.13.3 Firefox Solution

There is a different plugin available for Firefox:

1. Install **Browser Plugin** "Firefox Multi-Account Containers" (approved via CSC)
2. Configure Containers for each account
3. Disable SSO in the Firefox Browser Settings:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5 Authentication Flows & more

Overview

This page is a collection of topics around Federations with SAML and OIDC with detailed insights. Feel free to have a look on the different topics

Protocol Overview

- OAuth2.0 / OpenID Connect with ADFS
- OAuth2.0 / OpenID Connect with Entra ID (formerly AzureAD)
- SAML 2.0 flow

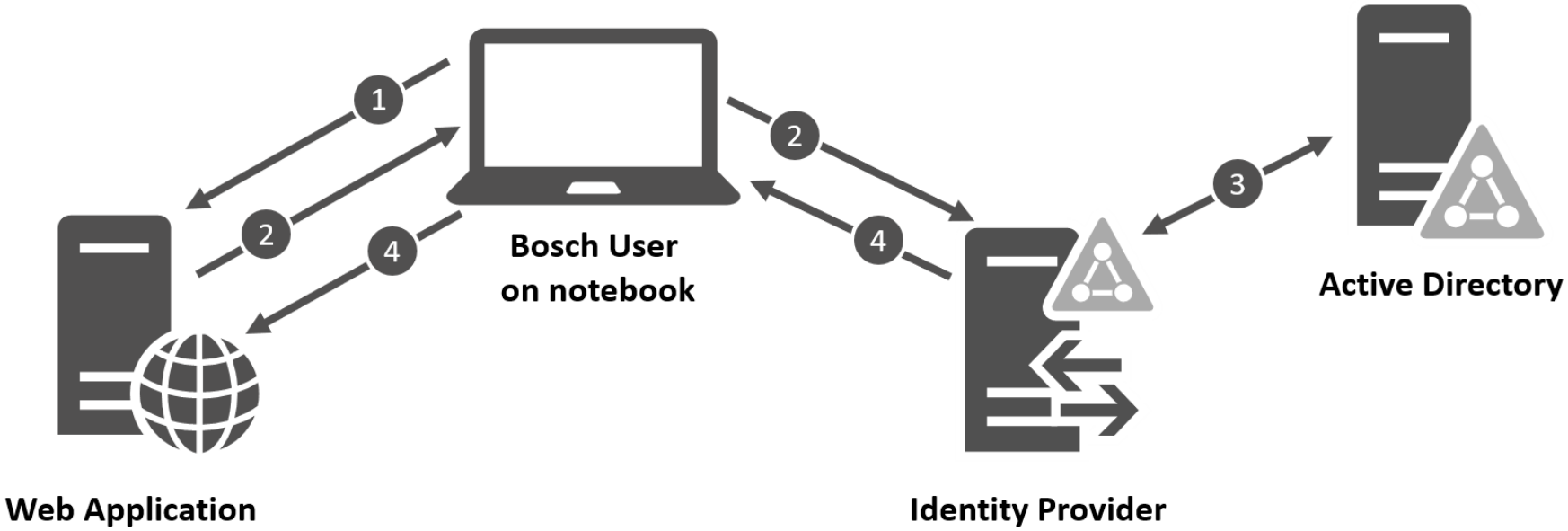
Technical Background Information

- Authentication
  - Basic Authentication Flow
  - User Provisioning
  - MFA for External Access
- Token Signing Certificate
  - Find the certificate
  - Current token signing certificate
  - Certificate Rollover (SAML only)
- Cookies and Tokens
  - Supported SSO types
  - Token lifetimes

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.1 Authentication

5.1.1 Basic Authentication Flow



1	The user browses to the applications URL to access to the application
2	The Application redirects the user to the configured Identity Provider (IdP) with a token request.
3	Based on the delivered information (in the token request and the Kerberos token) of the already authenticated user in Active Directory, the IdP creates the response token according to the configuration (including the claims with information about the SSO user)
4	The user will be redirected to the configured application endpoint with the token. Access to the application will be granted for the user after internal validation of the token.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.1.2 User Provisioning

E.g. for a SAML federation the value of the Name ID identifier has to match with the unique user ID in the local user database of the federated application. This means there must be at least an entry of the user with the same unique ID as the value of the Name ID claim. To find a way to populate the user database of your application please also have a look to the Bosch IdM docupedia sites for User Provisioning. A lot of Applications also offer "Just in Time Provisioning" which means that the user will be generated automatically at the first login.

5.1.3 MFA for External Access

If you want to access your application from the public Internet (e.g. with your Bosch managed Smartphone) a Multifactor Authentication is required.
Therefore MFA needs to be enrolled on a device. More details about the process and MFA in general can be found on this blogpost.

5.2 Token Signing Certificate

Tokens which will be issued by one of our Identity Providers will be signed with the Token Signing certificate, which is a self-signed certificate that has be renewed on a regular basis (every 2-3 years).
To proof that the token is valid and that the issuer is the Bosch Identity Provider the application needs the public key of the token signing certificate.

5.2.1 Find the certificate

For OIDC either in the "well-known configuration" or on the keys endpoint (e.g. "https://stfs.bosch.com/adfs/discovery/keys")
For SAML it is available in the "Federation Metadata file".



Figure 1 - Token signing certificate in the Federation Metadata

ADFS Azure AD

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.2.2 Current token signing certificate

Enivronment	Download certificate	Valid until
ADFS RB-NGW (stfs.bosch.com)	ADFS_STFS-BOSCH-COM_TokenSigning.cer	15th of April 2024
ADFS RB-Q9 (stfs.test-bosch.com)	ADFS_STFS_TEST-BOSCH-COM_TokenSigning.cer	27th of March 2025
ADFS BSH (stfs.bshg.com)	ADFS_STFS_BSHG_COM_TokenSigning.cer	2nd of February 2025
ADFS RB-Admin (stfs.bosch-org.com)	ADFS_STFS_RB-Admin_TokenSigning.cer	19th of Februrary 2025

In some cases the certificate will be needed as a .cer file. In this case you can download it here (see above). Alternatively the conversion of a cer file is described here:

1. Open a notepad or any other text editor
2. Write **-----BEGIN CERTIFICATE-----** at the beginning of the file
3. Copy the text between <X509Certficate>…..</X509Certificate
4. Write **-----END CERTFICATE-----** at the end of the file
5. 5. Save file with the ending .cer

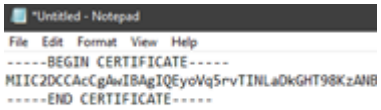


Figure 2 - Create certificate file from text

5.2.3 Certificate Rollover (SAML only)

The Token Signing Certificate expires every 3 years and then the public key has to be exchanged on Application side. As there is only one single certificate for all our customers the exchange has to be planned in advance. We will inform you via SPOI about upcoming changes.
You didn't subscribe to our channel "FEDERATION SERVICE INFRASTRUCTURE OPERATION"? Click here to do it now.

ADFS Azure AD

In Azure each application gets an individual signing Certificate which needs to be renewed every two years.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.3 Cookies and Tokens

5.3.1 Supported SSO types

Session SSO

Session SSO cookies are written for the authenticated user which eliminates further prompts when the user switches applications during a particular session. However, if a particular session ends, the user will be prompted for their credentials again.
AD FS will set session SSO cookies by default if users' devices are not registered. If the browser session has ended and is restarted, this session cookie is deleted and is not valid any more.

Persistent SSO

Persistent SSO cookies are written for the authenticated user which eliminates further prompts when the user switches applications for as long as the persistent SSO cookie is valid. The difference between persistent SSO and session SSO is that persistent SSO can be maintained across different sessions.
AD FS will set persistent SSO cookies if the device is registered. AD FS will also set a persistent SSO cookie if a user selects the “keep me signed in” option. If the persistent SSO cookie is not valid any more, it will be rejected and deleted.

Application specific SSO

In the OAuth scenario, a refresh token is used to maintain the SSO state of the user within the scope of a particular application.
If a device is registered, AD FS will set the expiration time of a refresh token based on the persistent SSO cookies lifetime for a registered device which is 7 days by default for AD FS 2012R2 and up to a maximum of 90 days with AD FS 2016 if they use their device to access AD FS resources within a 14 day window.

5.3.2 Token lifetimes

The Token lifetimes describe how long a SSO token (cookie) is valid. The values are different depending if the client is Bosch managed or unmanaged, like e.g. private devices.

ADFS | Azure AD

Example 1: Managed device + KMSI enabled: Token lifetime 90 days
Example 2: Unmanaged device + KMSI enabled: Token lifetime 30 days
Example 3: Unmanaged device without KMSI: Token lifetime: 1 day

Identity Provider	Token lifetimes	
All ADFS environments	**SSO lifetime** *Default SSO cookie lifetime for non Bosch managed (registered) devices.*	1 day

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Kmsi lifetime *Cross session cookie lifetime for non Bosch managed (registered) devices.*	30 days	
Persistent SSO lifetime *Cross session persistent cookie for Bosch managed (registered) devices with Keep me signed in enabled.*	90 days (device has to be used at least all 14 days)	
Access token *OIDC token*	1 hour	
Id token *OIDC token*	1 hour	
Refresh token *OIDC token*	Unmanaged : Managed:	8 hours 90 days (device has to be used at least all 14 days)

ADFS Azure AD

In Azure Token lifetimes are different.
Content tbd.

5.4 OAuth2.0 / OpenID Connect with ADFS

We are switching to AzureAD as the primary Identity Provider. Please consider to use to AzureAD instead. See here **for more information**

OAuth 2.0 is an open standard for access delegation, commonly used as a way for users to grant websites or applications access to their information on other websites but **WITHOUT** giving the password to them. OpenID Connect (OIDC) is used for the authentication part.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.4.1 Terminology

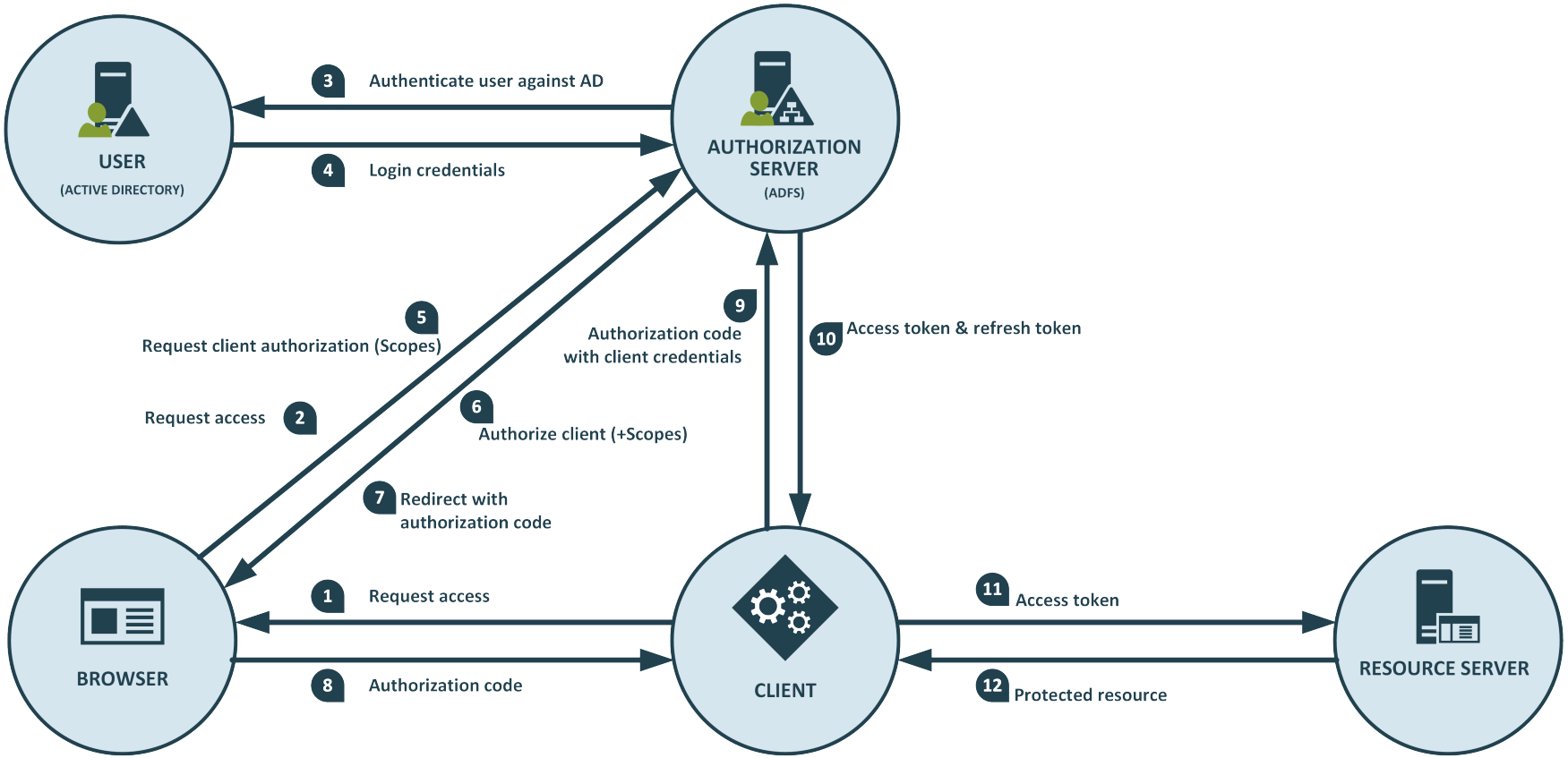
Access Token	A token used to access protected resources on APIs
Authorization code	An intermediary token generated when a user authorizes a client to access protected resources on their behalf. The client receives this token and exchanges it for an access token
Client	An application which accesses protected resources on behalf of the resource owner (such as user). The client could be hosted on a server, desktop, mobile or other device.
Grant	A grant is a method of acquiring an access token.
Resoucre server	A server which sits in front of protected resources (APIs) and is capable of accepting and responding to protected resource requests using access tokens.
Resource owner	The user who authorizes an application to access their account. The application's access to the user's account is limited to the "scope" of the authorization granted (e.g. read or write access)
Scope	A permission
JWT	A JSON Web Token is a method for representing claims (attributes) securely between two parties as defined in RFC 7519

5.4.2 Which Grants are avaialable and when to use which one?

5.4.2.1 Authorization Code Grant

The Authorization Code Grant flow is the most secure flow as it gets the access (and refresh) token through a back channel communication. Other as in the Implicit Grant flow the token will not be send public through the browser or app.
This flow has to be used if you are able to store the client credentials and token in a secure way. A backend application (client) is per definition a secure place.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

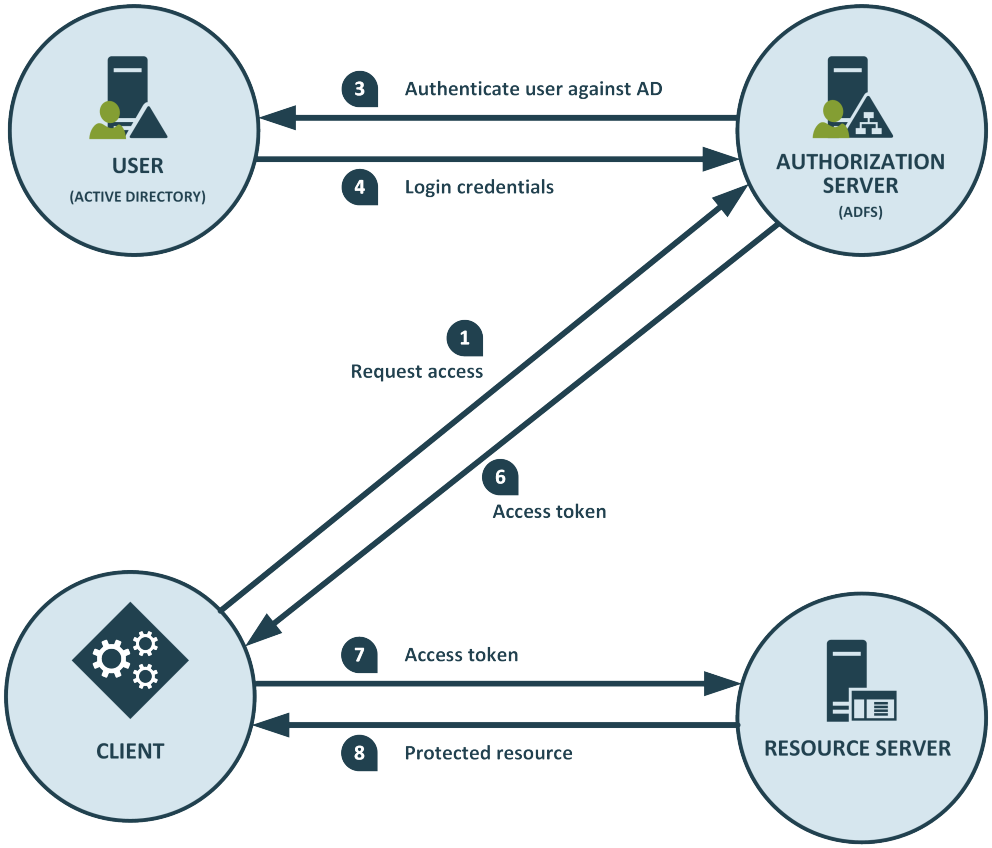


If you are using the Authorization Code Flow **with PKCE**, you might run into CORS issues if you're domain isn't part of *.bosch.com, *.test-bosch.com, *.bosch-org.com, *.bosch.tech or localhost. In this case feel free to contact us via our Mailbox Onboarding.Bosch-IdP@de.bosch.com.

5.4.2.2 Implicit Grant

If there is no possibility to store information in a secure way like in a native mobile app or One-Page Websites a Shared Secret cannot be used. The Implicit Grant Flow is exactly designed for those scenarios. Instead of sending a code through the front channel to the client
and exchange the code then afterwards through the back channel with an access token the access token will be sent directly to the client. In this scenario it is not possible to use a refresh token.

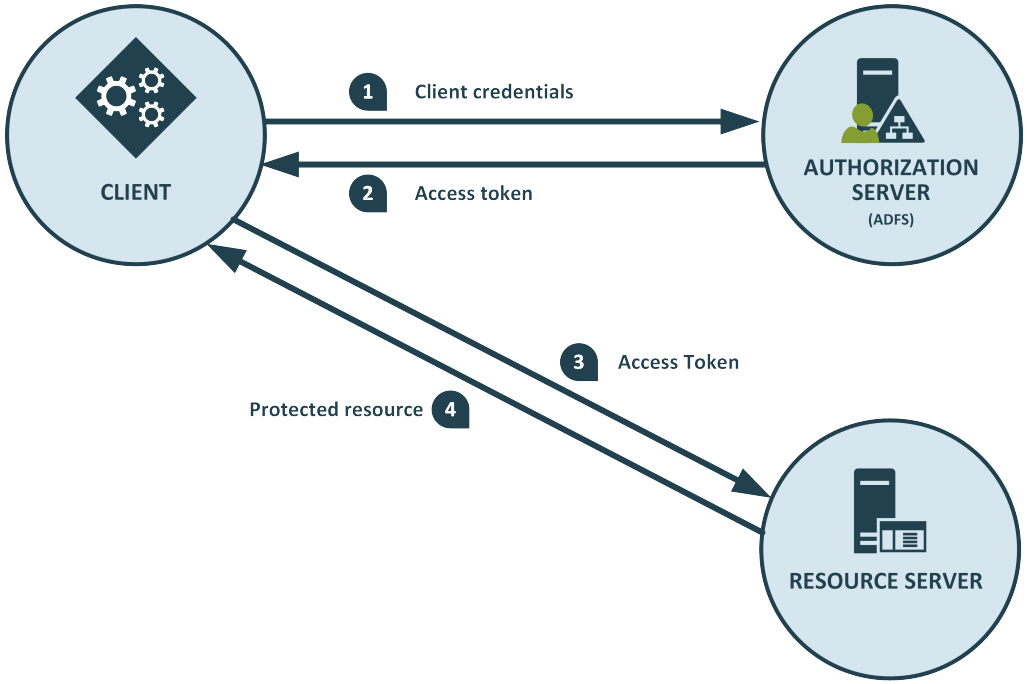
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



5.4.2.3 Client Credential Grant

If you have a machine to machine communication a user interaction is not possible. In this Grant there is no real delegation proces. this flow is only to use in the scenario without any user interaction.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



5.4.3 Scopes (permissions)

With ADFS there is no userinfo endpoint available. Information about the user have to be setup with claim rules. The default scopes we activate for your API are **allatclaims** and **openid**. If you need any custom scopes, please reach out to the onboarding mailbox (Onboarding.Bosch-Idp@de.bosch.com)

5.4.3.1 Available scopes

Scope name	Description	Activated per Default
allatclaims	Requests the access token claims also in the id token.	yes
aza	Scope allows broker client to request primary refresh token.	no
openid	Request use of the OpenID Connect authorization protocol.	yes
user_impersonation	Request permission for the application to access the resource as the signed in user.	no

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.4.4 Detailed flow (external link to Microsoft)

You can find a detailed description of the steps within the Code Authorization Grant flow here: https://docs.microsoft.com/en-us/azure/active-directory/develop/v1-protocols-openid-connect-code

5.5 OAuth2.0 / OpenID Connect with Entra ID (formerly AzureAD)

The OAuth2.0 Protocol allows Users to sign into third-party applications without as separate User/Password Management implemented in it. It also offers the possibility to sign in applications (without a User involved) to invoke automated processes.
The Term 'third-party applications' refers to all non-Microsoft developed or Entra ID integrated applications. This includes applications from other vendors than Bosch as well as CI developed applications.



The basic procedure is as follows. A desktop application or a web app obtains a so called 'Bearer token' (or 'Access token') for a specific User from the Microsoft Identity Platform. A Bearer Token is an Implementation of the JSON Web Token (JWT) standard and proves cryptographically that the user is signed in. This token can then be used to perform authenticated HTTP requests against an API that is protected by Entra ID. These APIs can be anything from Entra ID integrated interfaces, such as the Microsoft Graph API, to self-developed applications that use Entra ID as an identity provider.
Besides that, there are also flows which do not require user interaction and their passwords.

5.5.1 OAuth2.0 vs OpenID Connect

OAuth2.0 and OpenID Connect are often used as synonyms for the same thing (as on this page). This is true in most cases, but there are differences. OAuth2.0 is a protocol framework for authorization against protected endpoints, whereas OpenID-Connect is an industry standard that builds on and extends OAuth2.0. For example OAuth2.0 specifies that a endpoint has to exist, where a token can be obtained, where as the OpenID Connect standard specifies a document containing the location of this endpoint.

5.5.2 Flows

The OAuth2.0 implementation in Entra ID defines different Flows to get an access token. To decide which flow is suitable for you, please take a look at this page.

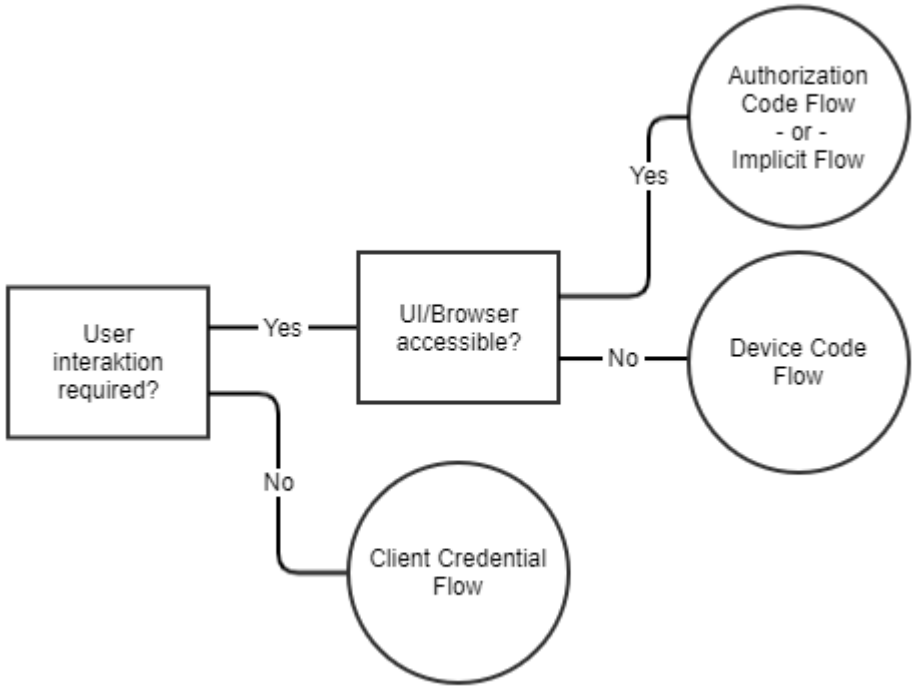
- Authorization Code Flow
  - For Web Applications where the Backend needs to talk to an Entra ID protected API.
- Implicit Flow
  - For Web Frontends that need to perform REST calls to an Entra ID protected API.
- Client Credential Flow
  - For Backend Applications that need to perform automated operations without a user involved.
- Device Code Flow
  - When you have to use a User-based Sign-In Method and there is no possibility to open a UI (like a Web Browser)
- **Resource Owner Password Credential Flow**
  - Not possible inside Bosch as User passwords are not synced to Entra ID.
  - For a detailed description, please take a look at the Microsoft Documentation.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.5.3 Libraries

Microsoft publishes a number of libraries for different programming languages for you to use to handle Authentication with the Entra ID.
A List of these libraries can be found here

5.5.4 Deciding which Flow to Use



- **User interaction required?**
  Whether you want to sign in an User or an Application without a User involved, to do some automated background tasks
  Logging in a User requires User interaction as the User may have to enter his/her password or is asked to use MFA.
- **UI/Browser accessible?**
  Whether a UI (like a Web Browser) is accessible for the User. E.g. If a CLI (Command Line Interface) is unable to open a Web Browser for the user to Sign in, the answer is No.

5.5.4.1 Authorization Code Flow vs Implicit Flow

The decision between these 2 flows is a bit more complicated. First of all both Flows are used for Signig in Users in a Web-Browser, a native Application or a mobile Application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Authorization Code Flow aims to replace the Implicit Flow as the Implicit Flow is now disabled by default in the AzureAD App Registration. **Therefore the recommendation is to use the** Authorization Code Flow.

The difference is that with the Implicit Flow, a token is passed to the application via an Http redirect immediately after successful login, whereas with the Authorization Code Flow, an authorization code is passed at first.
To use the authorization code to get an access token, the application has to provide a code challenge via PKCE. In a productive environment, this is likely handled by a library from Microsoft and you don't have to worry about PKCE.

5.5.4.1.1 Benefits of using an Authorization Code

Using the Authorization Code Flow comes with the following benefits. These benefits only apply to Applications that uses the Authorization Code Flow with PKCE.

5.5.4.1.1.1 Increased User Experience

The Authorization Code Flow enables you to use so-called refresh tokens and thereby improves the performance of your Application. (only with PKCE)
An access token is only valid for one hour. This means that every hour, your user needs to be redirected to the AzureAD Endpoint to get a new access token. Even with SSO (Single-Sign-On), this can be quite time consuming (a few seconds), as the user has to follow through some further redirects until he/she gets redirected back to the application. Without SSO, the user would have to enter his/her password every hour.
When utilizing refresh tokens, your app can refresh the acces token in the background without the user noticing it.

There were other methods to silently refresh the acess token besides using refresh tokens, but since all modern browser block the usage of thrid-party-cookies, these methods no longer work and refresh tokens are the way to go.

5.5.4.1.1.2 Increased Security

There are 2 reasons or scenarios where using the Authorization Code Flow, or rather using PKCE, will increase the security of your login.

Redirects are insecure

Native Applications and mobile Apps register specific URLs in the Operating System to be handled by the Application so that the Operating system automatically opens the App when trying to access these URLs.
Applications use this feature to automatically get the access tokens or authorization codes forwarded from the browser to the Application, but there is no guarantee that there was no malicious Application in the middle that recorded the transmitted data.
Using the Implicit Flow, the malicious Application would then have the access token and thereby the same permissions as your Application → very bad
Using the Authorization Code Flow, the malicious Application only receives an authorization code which cannot be used without the 'code_verifier' defined in PKCE.
This makes the authorization code useless for the malicious Application and ensures that only your Application gets a hold on the access token.

Only the Backend receives the access token

This only applies to a scenario when you have a frontend + a backend in place where only the backend needs the access token. If your frontend needs the access token, the following does not apply.
A Users computer tends to be less secure than a server, so it makes sense that only the backend receives the access token.
Using Implicit Flow, the access token will be forwarded from the Browser (the Users computer) to the Backend and malicious Software or browser Addons can intercept this.
Using the Authorization Code Flow, the users computer only receives an authorization code and PKCE ensures that only the backend can resolve this to an access token.

5.5.5 Authorization Code Flow

This page provides a high level description of the OAuth2.0 Authorization Code Flow with AzureAD. A detailed technical documentation can be found in the Microsoft Docs.

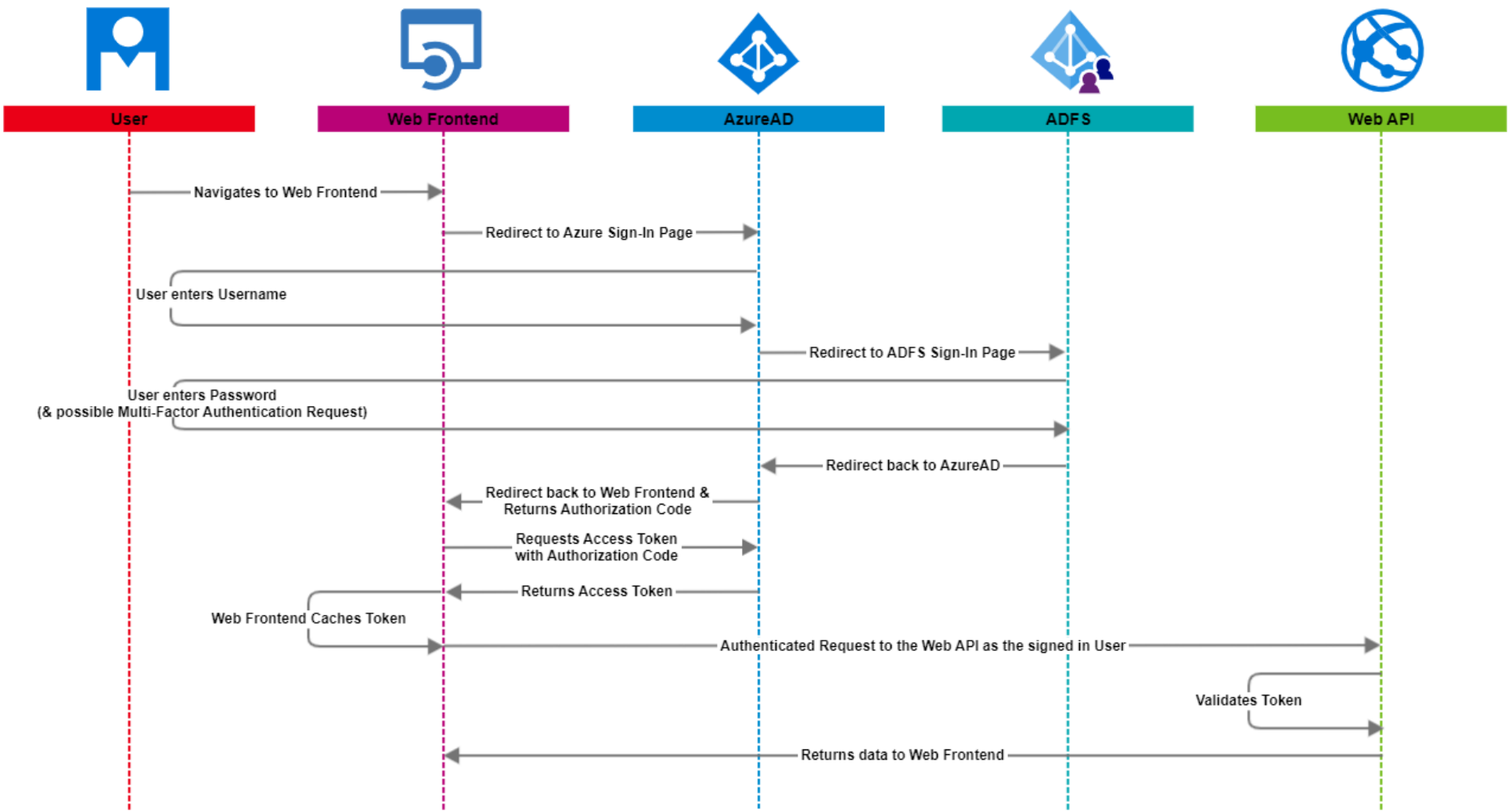
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The Authorization Code Flow is suitable for Web Applications, native Applications and mobile Applications that are not able to securely store secrets that the user should not have access to. (e.g. like an Application Secret)
For an overview on when you should use the Authorization Code Flow, take a lok at Deciding which Flow to Use.

5.5.5.1 Roles

- **User**
  The User that wants to login into an application
- **Web Frontend**
  The Web Frontend is the technical actor that initiates the Sign-In for the User. It is also responsible for storing the Token and calling an API with it. A Web Frontend can be anything from a website to a desktop or mobile application.
- **AzureAD**
  The AzureAD is the Identity Provider during the Sign-In. Since Bosch Passwords are not synced to the cloud it utilizes the ADFS to perform the Sign-In.
  The Web API has to have the AzureAD configured as a valid Identity Provider to validate the Token.
- **ADFS**
  An OnPremise Identity Provider that performs Sign-Ins for Bosch Users from the OnPremise Active Directory (the Identity Provider for the Windows Workstations).
- **Web API**
  A Web Application that handles HTTP Requests und uses AzureAD as an Identity Provider. The Web API can be an Azure integrated System like Microsoft Graph or any self developed Application

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



5.5.6 Implicit Flow

This page provides a high level description of the OAuth2.0 Implicit Flow with AzureAD. A detailed technical documentation can be found in the Microsoft Docs.

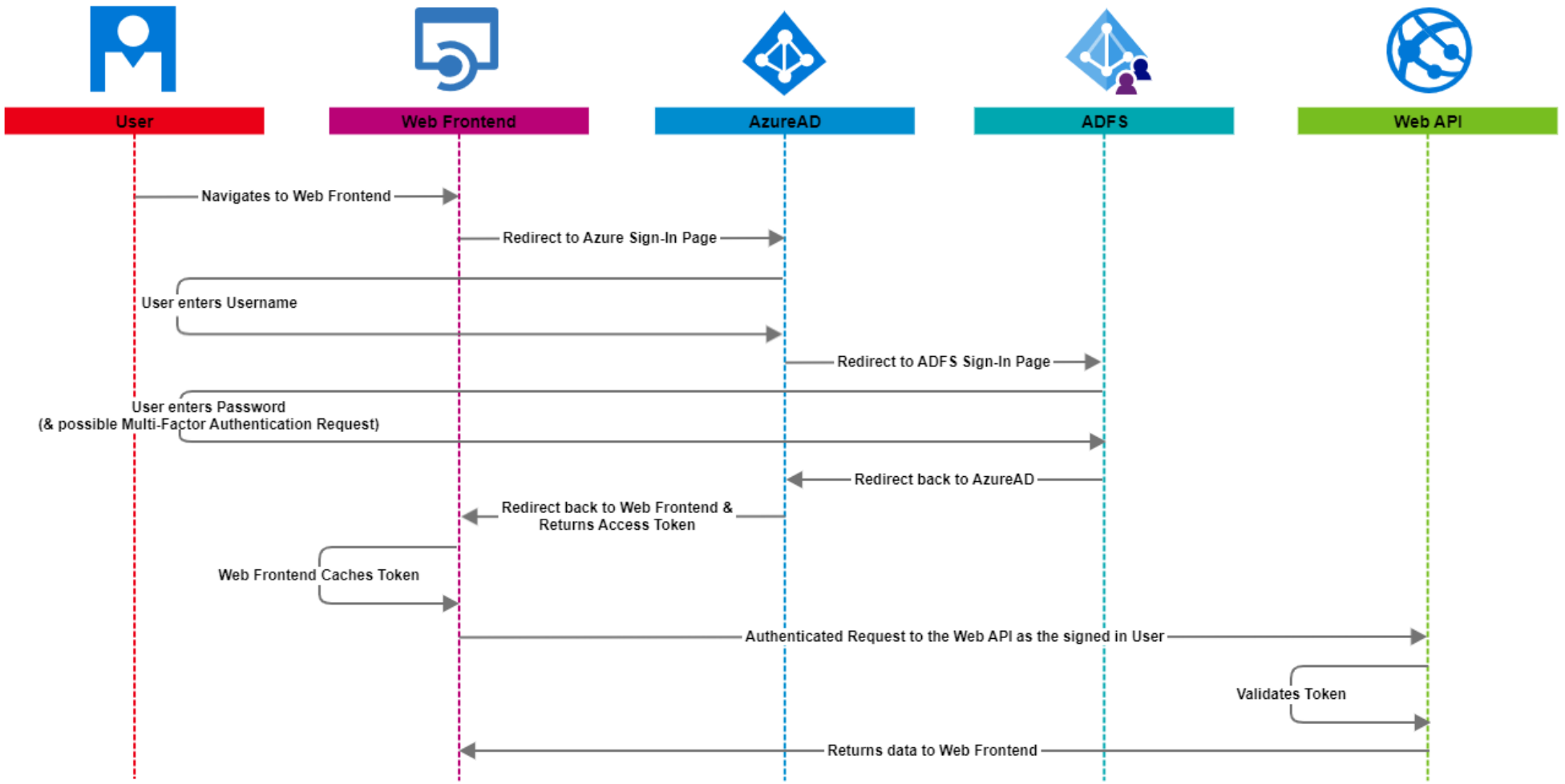
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The Implicit Flow is suitable for, but not limited to, Web Applications that are not able to securely store secrets that the user should not have access to. (e.g. like an Application Secret)
For an overview on when you should use the Implicit Flow, take a lok at Deciding which Flow to Use.

5.5.6.1 Roles

- **User**
  The User that wants to login into an application
- **Web Frontend**
  The Web Frontend is the technical actor that initiates the Sign-In for the User. It is also responsible for storing the Token and calling an API with it. A Web Frontend can be anything from a website to a desktop or mobile application.
- **AzureAD**
  The AzureAD is the Identity Provider during the Sign-In. Since Bosch Passwords are not synced to the cloud it utilizes the ADFS to perform the Sign-In.
  The Web API has to have the AzureAD configured as a valid Identity Provider to validate the Token.
- **ADFS**
  An OnPremise Identity Provider that performs Sign-Ins for Bosch Users from the OnPremise Active Directory (the Identity Provider for the Windows Workstations).
- **Web API**
  A Web Application that handles HTTP Requests und uses AzureAD as an Identity Provider. The Web API can be an Azure integrated System like Microsoft Graph or any self developed Application

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



5.5.6.2 Flow Example

In the following flow, we will use the App Registration Overview of the Azure Portal: https://portal.azure.com/#blade/Microsoft_AAD_IAM/ActiveDirectoryMenuBlade/RegisteredApps

In this Example, the Azure Portal (https://portal.azure.com) takes on the role of the *Web Frontend*. It will fetch all your App Registrations from the Microsoft Graph API, which takes on the role of the *Web API*.

1. User opens a Browser and visits https://portal.azure.com/#blade/Microsoft_AAD_IAM/ActiveDirectoryMenuBlade/RegisteredApps

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

2. If the Azure Portal already has a stored Access Token that is not expired, it will skip the following steps and continues with step 6.
   If the Azure Portal has no valid Access Token stored (first time visiting or token expired), it will redirect the User to the Azure Active Directory.

3. The AzureAD tries to perform Single-Sing-On (SSO). It uses Cookies and Browser Sessions to validate the Identity of the User.
   If the AzureAD cannot find a valid Session for the User, it will ask for the Username.
   After Entering the Username, the AzureAD realizes that it has no stored password of the User and redirects him to the ADFS.

4. The ADFS also tries to perform SSO. It uses the Windows Logon Session to validate the Users Identity so that the User does not have to enter his password.
   If this fails or the User is not logged on to a Bosch managed device, it will prompt the User for a password.
   Based on the result of the Conditional Acces Policies from Azure, the User will also be prompted for Multi-Factor-Authentication).
   After the Successfull Authentication of the User it will redirect back to AzureAD with a proof that the User is authenticated.

5. The AzureAD has confirmed the Identity of the User an redirects back to the Azure Portal with an OAuth2.0 Access Token.
   At this point the Implicit Flow is completed and the Azure Portal is in posession of a valid Access Token.

6. The Azure Portal stores the Token and performs a HTTP Request to Microsoft Graph to fetch all Owned App Registrations of the signed in User.

7. Microsoft Graph validates the Token and extracts the User-ID of the signed in User. It then returns all owned App Registrations.

8. The Azure Portal visualizes the returned data.

5.5.7 Device Code Flow

> This flow is only allowed for special use cases and requires an exception approval. Please continue reading to understand the framework and conditions.

5.5.7.1 What is the Device Code Flow?

The Device Authorization Grant (commonly referred to as Device Code Flow) is an authentication method defined in OpenID Connect (OIDC) and OAuth 2.0.
Unlike standard web logins where your browser opens a login page directly, the Device Code Flow works in two steps across two separate interfaces:

1. **On your terminal or tool:** You initiate a login command (e.g., in a CLI tool). It outputs a short alphanumeric code (e.g., `ABCD-WXYZ`) and a login URL.
2. **On your secondary device or browser:** You visit the provided link, paste the code, sign in, and complete Multi-Factor Authentication (MFA). Once verified, your CLI tool receives an access token automatically.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

What Was the Original, Legitimate Use Case?

Device Code Flow was specifically designed for "input-constrained" devices environments that cannot display a rich web browser or easily capture user input.
Legitimate example:

- Developer CLI Tools & Remote Terminals: Developers operating inside SSH sessions, cloud shells, or containerized build environments that lack a local desktop browser to handle redirects.

For engineers, it provided a smooth bridge between headless command-line interfaces and company single sign-on (SSO).

How Bad Actors Misuse It (The Phishing Vector)

While convenient, attackers realized that the Device Code Flow has an architectural loophole: the person typing the code does not have to be on the same network or machine that requested it.
How an attack works:

1. **Attacker triggers the flow:** The attacker runs a script against our corporate identity provider and receives a real, valid device code.
2. **Lure the victim:** The attacker sends a convincing phishing email or MS Teams message e.g., *"Urgent: Re-authenticate your OneDrive"* or *"IT Support: Confirm your device"*
3. **Victim approves the code:** The message directs the victim to the genuine, trusted company login page and tells them to enter the code.
4. **Legitimacy bypasses suspicion:** Because the prompt happens on the real company identity portal with genuine MFA prompts, users believe it is legitimate and approve the request.
5. **Token handoff to attacker:** As soon as the user finishes the sign-in, the access token is delivered directly to the attacker's terminal, giving them full access to the victim's mailbox, files, and internal repositories often bypassing conditional access rules.

Why We Are Blocking It Tenant-Wide

Device code phishing (often dubbed *DeviceJacking*) has become a leading attack method by advanced cyber threat groups because:

- **It bypasses traditional MFA protections:** The user legitimately performs MFA themselves, validating the attacker’s session.
- **No malicious links required:** The URL sent to the user is the legitimate login portal, defeating most standard email link scanners.
- **Hard to distinguish:** Without deep logging, the resulting token appears as an authorized sign-in.

Because modern developer tools now widely support more secure alternatives - such as local web redirects and PKCE (Proof Key for Code Exchange) - disabling the Device Code Flow closes a major attack vector without impacting day-to-day work for the vast majority of employees.

How to Request an Exception for Legitimate Use Cases

We understand that certain specialized automated processes, headless builds, and CLI workflows still genuinely require this flow. We have established an OneIDM role for the exception to accommodate these needs.
Eligibility Criteria
To be granted an exception, your use case should meet the following conditions:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- You are operating in a headless, non-interactive, or remote terminal environment where a local browser loopback (`http://localhost:<port>`) is technically impossible.
- Alternative authentication mechanisms (e.g., Service Principals, Managed Identities, personal access tokens with scoped keys) are not viable.
- The access will be tied to an identifiable developer or service owner.

Request Process

- OneIDM role for exception of the block policy can be requested for the following target system and role (https://inside-docupedia.bosch.com/confluence/x/pAKYI):
  - target system: Microsoft Azure
  - role: IdM2BCD_DeviceCodeFlow-Exception
- manager of the applicant must approve the request
- once the exception is no longer required, please revoke the assigned OneIDM role as soon as possible

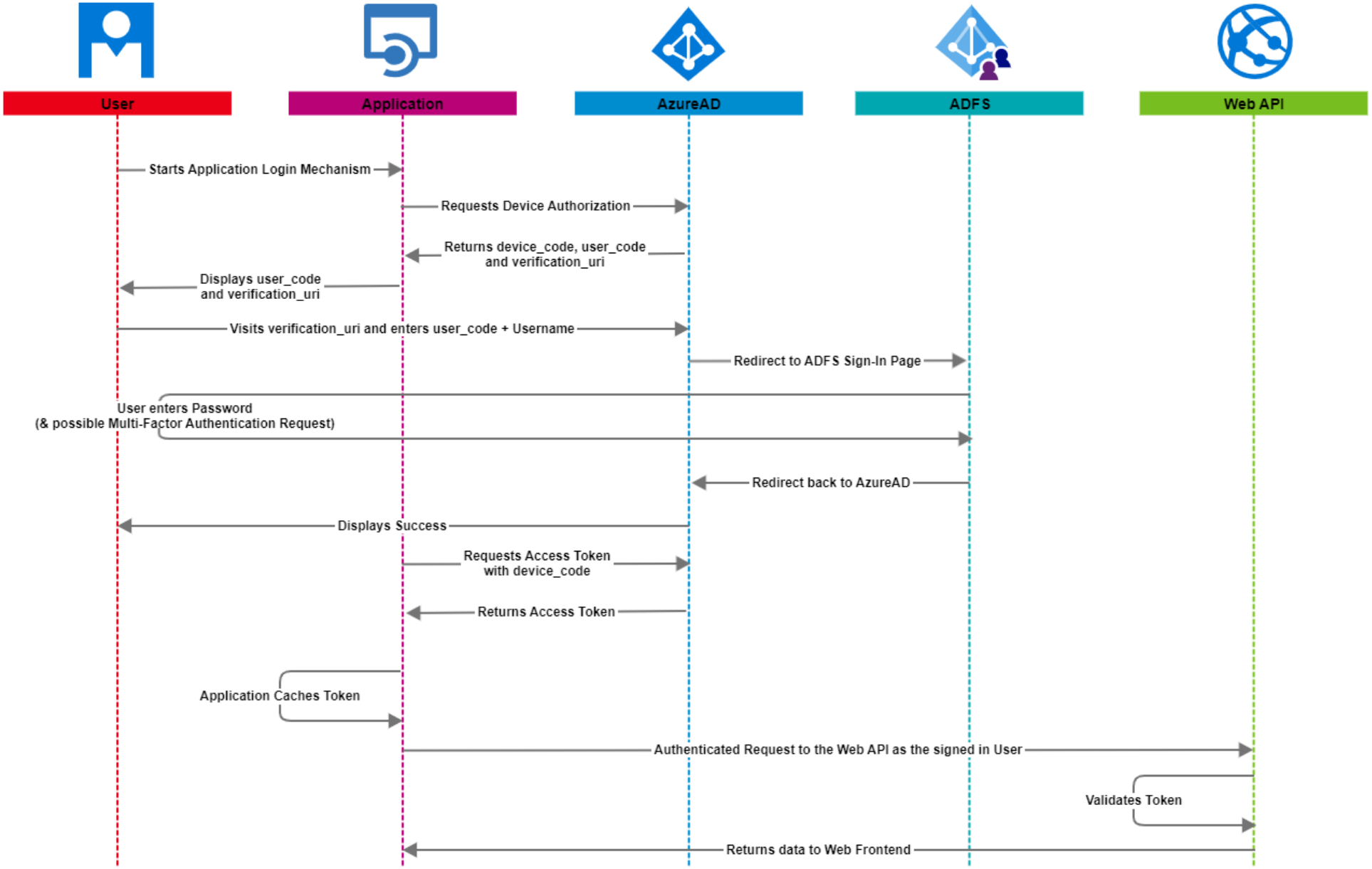
5.5.7.2 General Flow information

This page provides a high level description of the OAuth2.0 Device Code Flow with AzureAD. A detailed technical documentation can be found in the Microsoft Docs.
The Device Code Flow is suitable for Applications that are unable to open a Browser for the User to sign in.
For an overview on when you should use the Device Code Flow, take a lok at Deciding which Flow to Use.

5.5.7.3 Roles

- **User**
  The User that wants to login into an application
- **Application**
  The Application is the technical actor that initiates the Sign-In for the User. It is also responsible for storing the Token and calling an API with it.
  The Application can be anything from a website to a CLI (Command-Line-Interface).
- **AzureAD**
  The AzureAD is the Identity Provider during the Sign-In. Since Bosch Passwords are not synced to the cloud it utilizes the ADFS to perform the Sign-In.
  The Web API has to have the AzureAD configured as a valid Identity Provider to validate the Token.
- **ADFS**
  An OnPremise Identity Provider that performs Sign-Ins for Bosch Users from the OnPremise Active Directory (the Identity Provider for the Windows Workstations).
- **Web API**
  A Web Application that handles HTTP Requests und uses AzureAD as an Identity Provider. The Web API can be an Azure integrated System like Microsoft Graph or any self developed Application

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

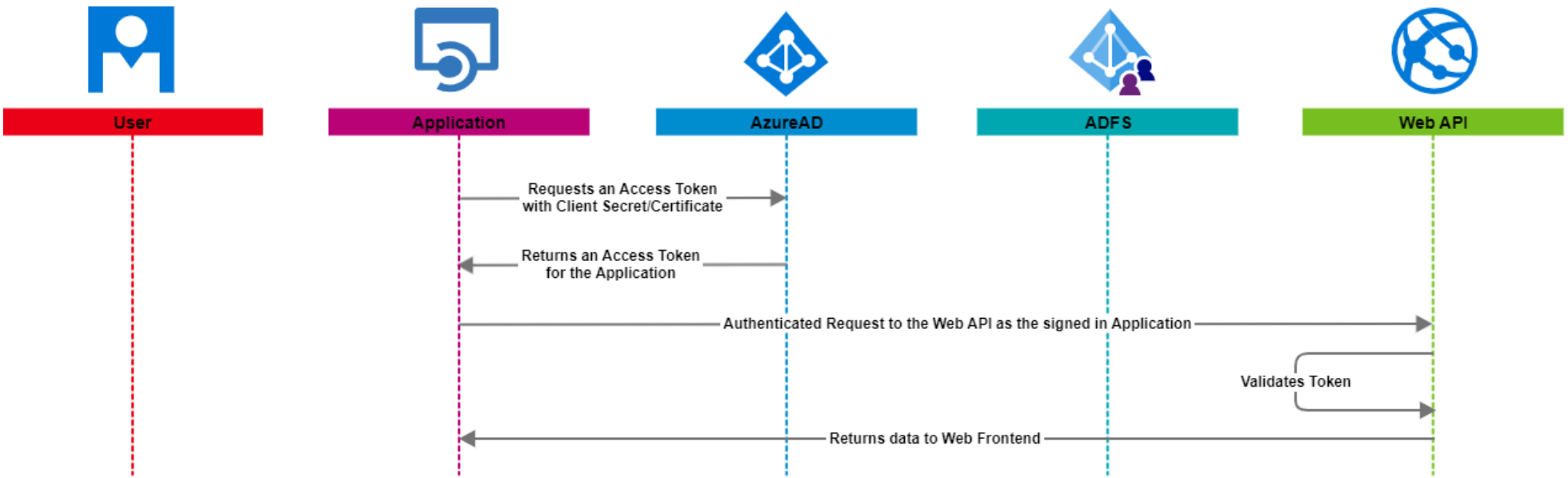
5.5.8 Client Credential Flow

This page provides a high level description of the OAuth2.0 Client Credential Flow with AzureAD. A detailed technical documentation can be found in the Microsoft Docs.
The Client Credential Flow is suitable for Signing in Applications without a User involved, like a scheduled task on a server.
For an overview on when you should use the Client Credential Flow, take a lok at Deciding which Flow to Use.

5.5.8.1 Roles

- **User**
  The User that wants to login into an application
- **Application**
  The Application is the technical actor that initiates the Sign-In. It is also responsible for storing the Token and calling an API with it.
  The Application can be anything from a scheduled task on a server to a Web-Backend.
- **AzureAD**
  The AzureAD is the Identity Provider during the Sign-In. Since no User is involved during the Sign in, the AzureAD is the only Identity Provider involved in this Flow.
  The Web API has to have the AzureAD configured as a valid Identity Provider to validate the Token.
- **ADFS**
  An OnPremise Identity Provider that performs Sign-Ins for Bosch Users from the OnPremise Active Directory (the Identity Provider for the Windows Workstations).
- **Web API**
  A Web Application that handles HTTP Requests und uses AzureAD as an Identity Provider. The Web API can be an Azure integrated System like Microsoft Graph or any self developed Application

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



5.5.9 JSON Web Token (JWT)

A JSON Web Token (RFC7519) contains Key-Value based data, signed by a trusted Authority. The OAuth2 protocol uses a specific of the JSON Web Tokens, a Bearer Token, to validate HTTP Requests. By validating the signature of ther JWT, a Web-API can verify that the JWT token was created by a trusted Authority and its content is trustworthy and was not altered.
The token consists of three Base64url-encoded string seperated by dots:

- **JOSE Header**
  The Header of the JWT contains metadata about the type of the token and the cryptographic algorithms used to sign its contents.
- **JWS payload**
  The Payload of the JWT contains Key-Value based data, so called Claims. These can be a Username, Group Memberships, Roles, etc. When verifying the JWS signature, an application can confirm that the JWS payload was issued by the trusted Identity provider and has not been altered.
- **JWS signature**
  The Signature can be used to check the integrity of a JWT. By validating the Signature, a Web-API can ensure that the Payload has been created by a trusted Authority and was not altered afterwards.

5.5.9.1 Example

The following JSON Web Token

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJSb2JlcnQiOiJCb3NjaCIsIkpXVCI6IkV4YW1wbGUiLCJDSSI6IklTSTIifQ.3f6LjJ9OYTieTdIWFYaMb95aFbybfDldyHkGT1pP1Pk
```

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

decodes to the following Content

Header	Payload	Signature
`{ "alg": "HS256", "typ": "JWT" }`	`{ "Robert": "Bosch", "JWT": "Example", "CI": "ISI2" }`	`HMACSHA256( base64UrlEncode(header) + "." + base64UrlEncode(payload), SECRET )`

5.5.9.2 Bearer Token

A bearer token is a JWT which contains some specific OAuth2 related properties in the payload. For example, the Bearer Token specificationr equired a JWT to have the 'aud' property, which contains an identifier of the issuing Identity Provider.Bearer Token

5.5.10 OAuth2.0 Glossary

Key	Description
API	API is short for Application Programming Interface and usually refers to a Backend that publishes resources via REST over HTTP.
Backend	
Claim	A Claim usually refers to a Key-Value pair that is issued and signed by an Identity Provider. An OAuth2.0 Token is a container of mutiple Claims that provide the accessed application with basic information about the signed in user. For example, an OAuth2.0 Token could contain the Claim 'username' = 'XYZ2FE', which basically prooves to the application that the person that provided the token really is the user with the username 'XYZ2FE'.
Frontend	
Identity Provider	

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Key	Description
OAuth 2.0 Client	
OAuth 2.0 Token	
HTTP	HTTP is short for Hypertext Transfer Protocol and defines a technical transport protocol that is the foundation of alll Browser-based communication via the Internet.
Redirect URL	see Reply URL.
Reply URL	A Reply URL defines the endpoint where a generated OAuth2.0 Token should be sent to after the login has been completed. For example, if you use http://localhost:8080/login as a Reply URL, then the Identity Provider (e.g. AzureAD or ADFS) will redirect the user to this URL and add the token as a query parameter. The Frontend (or Backend) that is located under this endpoint can then use and cache this token to make authenticated requestests to an API in the name of the user. A Reply URL has to be preconfigured in the Identity Provider to limit the usage of the OAuth2.0 Client. Be sure to only enter Reply URLs of Domains that you can trust, because whoever is behind the entered domains can use the OAuth2.0 Client to login Bosch Users and perform all the actions the OAuth2.0 Client is allowed to do in the name of the User.
REST	REST is short for Representational State Transfer and an umbrella term for different patterns of providing resources over HTTP.
URL	

5.6 SAML 2.0 flow

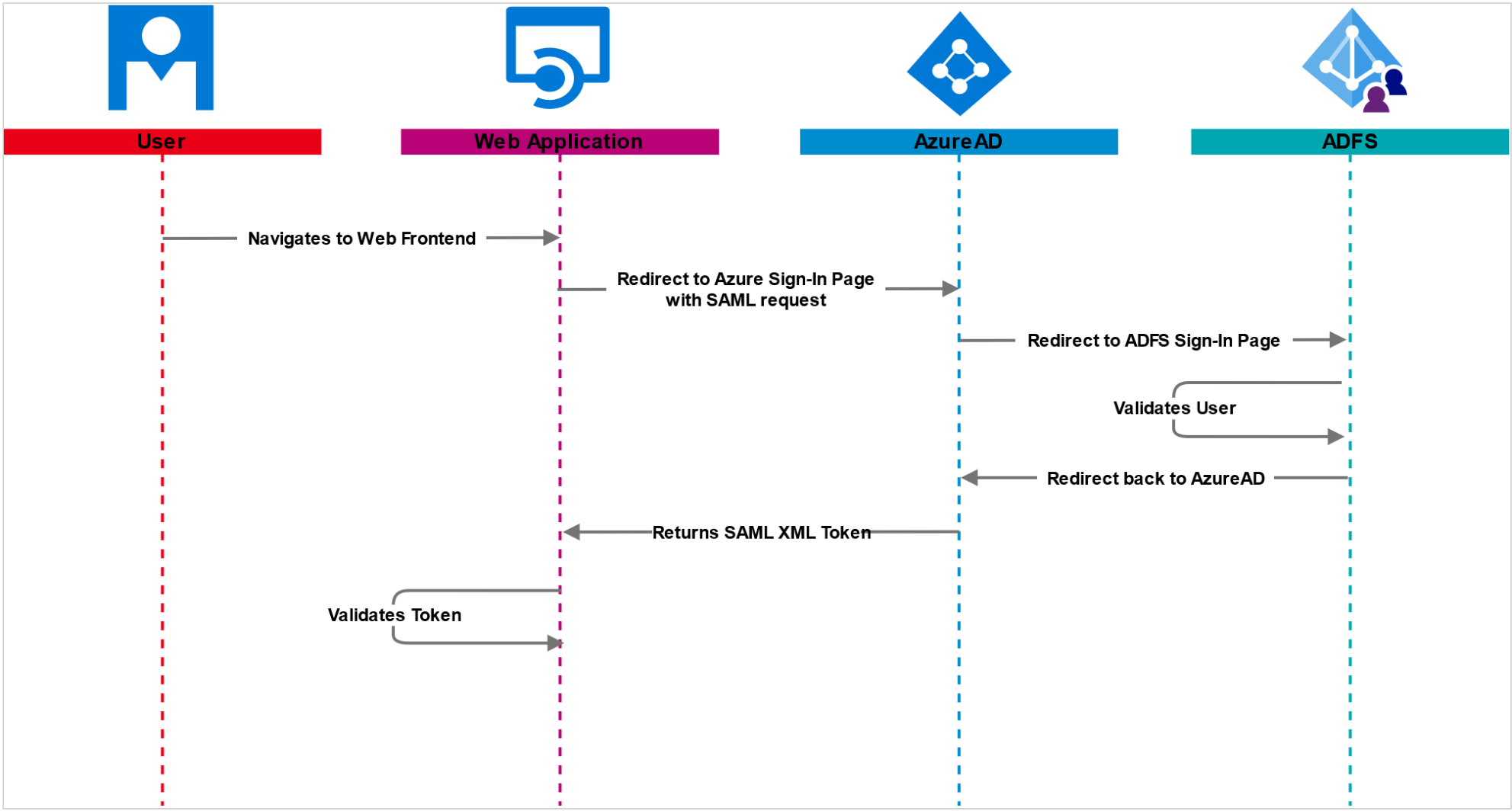
Overview

SAML (Security Assertion Markup Language) is an open standard (xml token) for exchanging authentication and authorization between an Identity Provider (IdP) and a Service provider (SP).

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Mainly this will be used for SSO (single sign on) to an application with a web browser for on premises and cloud hosted web applications. Official description from Microsoft can be found here

This is a high level description of the SAML 2.0 Flow with AzureAD. A detailed technical documentation can be found in the Microsoft Docs.



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

1. The user browses to the applications URL to access to the application (Web Application / Service Provider)
2. The Service Provider (SP) redirects the user to the configured Identity Providers (IdP / Azure AD) Login Endpoint with a xml based SAML token request. The request contai amongst other things the EntityID of the application and the Assertion Consumer URL of the application.
3. The Azure AD creates a request to ADFS and based on the delivered information and the Kerberos token of the already authenticated user in BCD (Active Directory) the AD sends a response to the Identity Provider (Azure AD). The IdP creates the SAML response according to the configuration.
4. The user will be redirected with the SAML response (XML token) to the configured Assertion Consumer URL endpoint of the application (SP). The response includes claim with information about the SSO user. The application can validate the token and let the user access it.

Alternative: IdP initiated SSO Flow
This flow starts at Azure AD, so with the IdP Federation server creating a Federation SSO Response and redirecting the user to the SP with the response message.
This flow is not recommended by us.
Link Structure: https://stfs.bosch.com/adfs/ls/idpinitiatedsignon.apsx?logintoRP=<EntityID of application>

5.6.1 Federation Metadata

The SAML metadata document is also part of the SAML standard. It describes a SAML deployment (either Identity Provider or Service Provider). Metadata documents are shared to establish a baseline of trust and interoperability. Therefore the following metadata must be shared as a minimun: Entity ID, Cryptographic keys and protocol endpoints.
Example: Federation Metadata Identity Provider ADFS P

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Federation Metadata	Explanation
	**1) EntityID** = unique identifier of the entity (ADFS P) **2) IDPSSODescriptor** = role element for Identity Provider (A Service Provider metadata would include the "SPSSODescriptor" element) **3) KeyDescriptor** = Includes the Public Key of the Signing Certificate **4) SingleSignOnService** = URI for Binding / IdP Login Endpoint **5) Attributes** = defines SAML attributes supported by the identity provider (here: UPN)

5.6.2 Token Request and Response

SAML Token Request (SP to IdP)

Example: AuthnRequest LeanIX Application

AuthnRequest	Explanation
	1) AuthnRequest = Authentication Request (Step2) 2) AssertionConsumerServiceURL = Redirect URI of Application (optional) Destination = IdP Login Endpoint (optional) ID = Identifier for the Request 3) Issuer = SP, used to identify the application on IdP side 4) NameIdPolicy = For NameID Attribute specifications

SAML Token Response (IdP to SP)

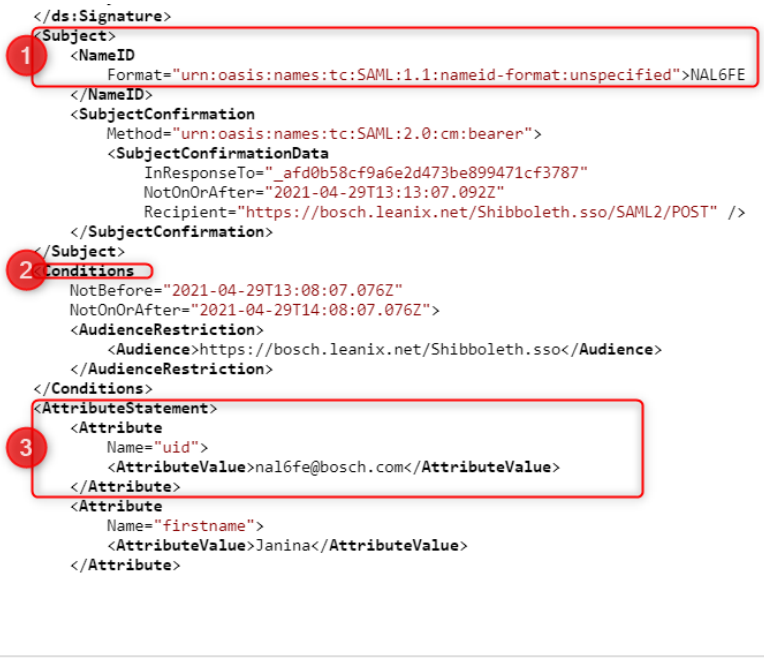
Example: Response ADFS P

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Response	Explanation
 ... 1) Response = Answer to AuthnRequest (Step 3) 2) Destination = Redirect URI of Application 3) InResponseTo =ID from AuthnRequest 4) Issuer = IdP, used to identify the application on SP side 5) Status Code = success or failure of sign-on 6) Assertion = Assertion Statement which includes all the details below 7) Signature = Signature from IdP (with Signing Certificate)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Response	Explanation


`</ds:Signature>`
`<Subject>`
`<NameID`
`Format="urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified">NAL6FE`
`</NameID>`
`<SubjectConfirmation`
`Method="urn:oasis:names:tc:SAML:2.0:cm:bearer">`
`<SubjectConfirmationData`
`InResponseTo="_afd0b58cf9a6e2d473be899471cf3787"`
`NotOnOrAfter="2021-04-29T13:13:07.092Z"`
`Recipient="https://bosch.leanix.net/Shibboleth.sso/SAML2/POST" />`
`</SubjectConfirmation>`
`</Subject>`
`<Conditions`
`NotBefore="2021-04-29T13:08:07.076Z"`
`NotOnOrAfter="2021-04-29T14:08:07.076Z">`
`<AudienceRestriction>`
`<Audience>https://bosch.leanix.net/Shibboleth.sso</Audience>`
`</AudienceRestriction>`
`</Conditions>`
`<AttributeStatement>`
`<Attribute`
`Name="uid">`
`<AttributeValue>nal6fe@bosch.com</AttributeValue>`
`</Attribute>`
`<Attribute`
`Name="firstname">`
`<AttributeValue>Janina</AttributeValue>`
`</Attribute>`
...
`</AttributeStatement>`
	1) Subject = Contains NameID to identify the User (Alternative: Attribute from AttributeStatement)
	2) Conditions = Validity of the Token and Audience (Issuer from AuthnRequest)
	3) Attribute Statement = Claims about the user (Key-Value Pairs)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

6 Migration Process: ADFS to Azure IdP

In 2023, we switched the Identity Provider (IdP) from ADFS to EntraID (former known as Azure AD) to perform authentication (Single Sign-On) with modern auth protocols like SAML and/or OIDC for your applications.
As we started directly to onboard applications only to EntraID from this time, we still kept applications on ADFS and did not directly start to migrate them to the new Identity provider as we wanted to provide you a much better user experience in future.
We are happy to tell you, that we have released now the self-service as well for SAML applications (OIDC is in place since the beginning).
Now lets forward together to migrate your configuration from the on prem ADFS to the cloud based EntraID including the self-service and benefit from the more modern envrionment with more security features and a much better user experience without slow and complex excel sheets. We will be supporting you on the way to migrate your configuration smooth and the less possbile influence to your customer.

6.1 Table of Content

- Table of Content
- Migration of SAML based applications
- Migration for OIDC based applications
- Benefits of EntraID IdP

6.2 Migration of SAML based applications

1. **Inventory and Update of the current situation | in the first step only for applications, using SAML as the protocol**
   In the first step, we will send you an excel and ask you to provide an update of your configuration (See more details below)
   As the onboardings partly are quite old, we need to update the status of all of them.
   Some are...
   a. not needed anymore and has not been requested for deletion
   b. already migrated but were not been disabled/deleted on ADFS side
   c. need to be migrated as they are in productive use and still connected to ADFS
   d. outdated in terms of responsitilibty as there were organizational changes and so the owner of the application changes

2. **Onboarding the configuration for your application to EntraID via our self-service (**https://inside-docupedia.bosch.com/confluence/x/vvfWTAE**)**
   Following the documentation in the link, you can create the SAML configuration in EntraID in parallel without influencing the current configuration.
   As long as the application still redirects the user to ADFS for authentication, nothing will change for you and your customer.
   We highly recommend to do a copy of the configuration and configure endpoints and claims the same way as it is in ADFS to avoid a different user experience and behavior for your customer. If you need to do changes e.g. at the claims, we recommend to do changes later and ensure as the

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

first step to get the authentication running as is.

3. **Reconfiguring the application to connect to EntraID as the Identity provider instead of ADFS**
   If you the configuration from ADFS has been copied to EntraID, the next step is to change the configuration on application side. We recommend to make a copy and/or screenshots from the current configuration (with ADFS) to be able to fall back in case of any issues.
   As long as we do not delete/disable the configuraiton on ADFS side (last step), you are always in the position to switch back to ADFS as Identity provider.

4. **Disabling/Deletion of the configuration in ADFS**
   If everything is reconfigured and users will be authenticated with EntraID, we can disable and delete the old application in ADFS. Doing this final step, we will wait for your approval and will not take action without it.

6.3 Migration for OIDC based applications

We have now started to enforce the migration of OIDC based applications. We are sending out E-Mails to all customers and planning to get all applications migrated until end of the year.
For OpenIdConnect (OIDC) **you can do the Migration** (we can support you if needed) with our Self-Services. Just create a new App Registration in Azure in parallel to the existing configuration, following our Onboarding Process.

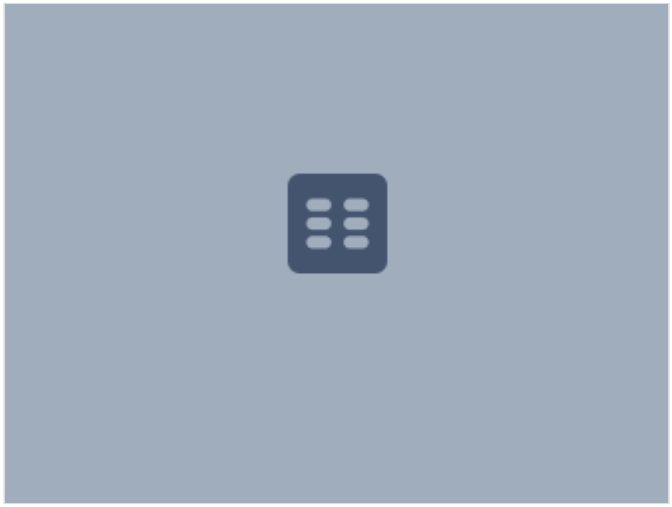
> Tip: To make sure that your application works directly after the switch, you should use the Admin Consent Pre-Approval (Instruction) before the change on application side!

With this setup you can easily switch to the new config, or switch back in case some settings are not correct yet.
After the successful migration:

- If your application was configured on IAP-Portal (OAuth2 Applications - IAP), please delete the ADFS configuration yourself in the IAP-Portal
- If your application was configured by our Operation Team, please request the deletion via E-Mail to Onboarding.Bosch-IdP@de.bosch.com or ITSD-Ticket to "Active Directory Services".

You can look and confirm if your application is on ADFS on-premises on the following document:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



6.4 Benefits of EntraID IdP

With this modern, secure and scalable cloud environment we bring a lot of benefits to you like...

- State-of-the-Art Identity Security and Identity Protection
- Full support of future Internet based clients
- Usage of RB-Secrets (HashiCorp Vault)
- cornerstone of the Zero Trust (see Zero-Trust principles). All new IT integrations must follow Zero-Trust-Framework according to G7 and BD roadmap
- Full Single-Sign-On (SSO) experience
- Access to Azure Identity API
- Read access to the configuration (SAML)
- Individual Token Signing certificate (important for certificate rollover for SAML)
- Fully automatable Application configuration (OIDC/OAuth 2.0)
- Support and Technology Driver of upcoming new Identity Frameworks like FIDO2/Passkey or SSI authentication capabilities

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.